

Processo: 107.097-5/25

Origem: SIGILOSO

Natureza: RELATÓRIO DE AUDITORIA GOVERNAMENTAL - AUDITORIA DE CONFORMIDADE

Observação: Verificar a adoção de controles e sua aderência às boas práticas de segurança da informação e segurança cibernética a fim de mitigar os principais riscos às informações e sistemas das organizações no âmbito da Administração Pública Estadual, por meio de uma auditoria de conformidade com contornos operacionais.

RELATÓRIO DE AUDITORIA GOVERNAMENTAL

DADOS DA FISCALIZAÇÃO

Número da fiscalização:	15/2025
Modalidade:	AUDITORIA DE CONFORMIDADE
Forma de autorização:	ORDINÁRIA
Ato originário:	PROCESSO TCE-RJ nº 302.662-1/2024
Jurisdicionados:	DADO SIGILOSO
Objetivo da fiscalização:	Verificar a adoção de controles e sua aderência às boas práticas de segurança da informação e segurança cibernética a fim de mitigar os principais riscos às informações e sistemas das organizações no âmbito da Administração Pública Estadual, por meio de uma auditoria de conformidade com contornos operacionais.
Ofícios de apresentação:	AUD/SGE/GAP 3232/25 a 3241/25, 3243/25 a 3268/25 todos de 06/08/2025.
Período abrangido:	agosto/25 a dezembro/25
Período de execução:	27/10/25 à 28/11/25
Equipe:	Augusto César Benvenuto de Almeida, mat. 02/4823 João Paulo de Freitas Ramirez, mat. 02/4820
Supervisão:	Bruno Mattos Souza de Souza Melo, mat. 02/4258

AUDITORIA Seginfo Estadual 2025

36
Organizações

33
Planos de ação

9
Controles CIS

27
Medidas básicas

O que o TCE-RJ fiscalizou?

A auditoria configura a segunda fase da fiscalização em segurança da informação e consistiu em:

- ✓ Verificar se órgãos e entidades do Estado do Rio de Janeiro adotam controles e medidas de segurança alinhadas às boas práticas da área;
- ✓ Analisar os planos de ação produzidos na primeira fase da auditoria, realizada em 2024;
- ✓ Incluir organizações de todos os poderes do Estado: Executivo, Legislativo, Judiciário, Ministério Público, Defensoria Pública e Tribunal de Contas.

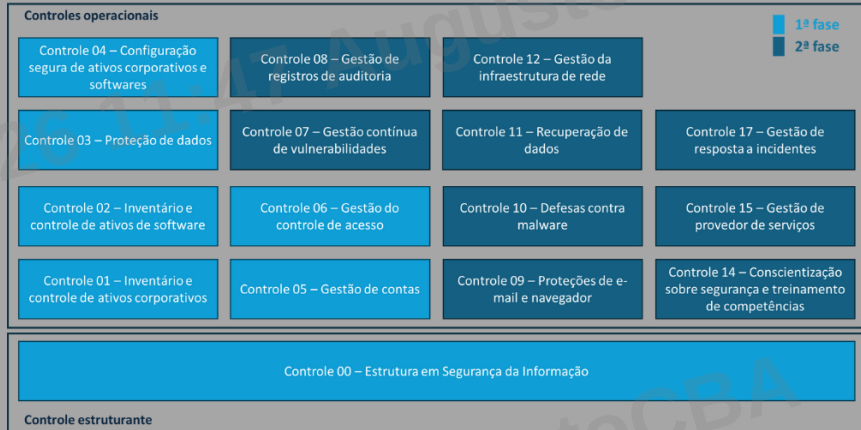
Por que a auditoria foi realizada?

- ✓ Relevância crescente da segurança da informação;
- ✓ Expansão dos serviços públicos digitais;
- ✓ Maior risco de vulnerabilidades cibernéticas;
- ✓ Necessidade de avaliar medidas de proteção existentes;

Quais os benefícios estimados?

- ✓ Fortalecimento da governança e da gestão de segurança da informação;
- ✓ Melhoria na gestão de riscos cibernéticos;
- ✓ Adoção de controles técnicos alinhados a boas práticas internacionais;
- ✓ Aumento do nível de maturidade e resiliência contra ataques cibernéticos;
- ✓ Valorização da cultura de proteção de dados;
- ✓ Melhoria na proteção das informações críticas do Estado e dos dados pessoais dos cidadãos.

Dimensões e controles avaliados



O que o TCE-RJ encontrou?

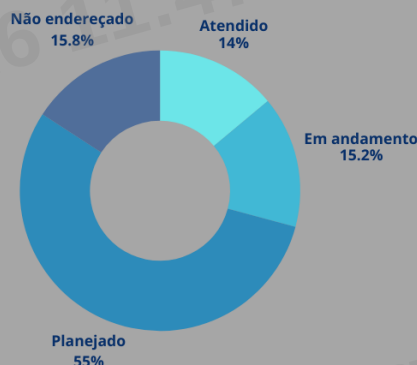
Os auditores constataram um cenário incipiente de maturidade das organizações estaduais do Rio de Janeiro aos controles essenciais de segurança da informação e segurança cibernética.

Em relação aos planos de ação, o trabalho identifica um cenário de alta capacidade de planejamento, porém ainda com baixo grau de execução das ações propostas.

Ao longo do trabalho, foram identificados nove achados de auditoria que apontam para um cenário de adoção insuficiente das medidas básicas de segurança cibernética. Com base nesses achados, foram propostos encaminhamentos com determinações e recomendações de até 27 medidas para que os órgãos jurisdicionados aprimorem seus controles de segurança da informação.

Planos de ação

Foram analisados um total de 645 encaminhamentos propostos na primeira fase às 36 organizações fiscalizadas, resultando em encaminhamentos: **não endereçados, planejados, em andamento e atendido.**



Índice de Adequação às medidas básicas de SegCiber

Para realizar uma análise quantitativa, foi elaborado o índice de adequação às medidas de segurança cibernética (iSegCiber), que varia de 0 a 1 e possui 4 faixas de classificação: **Inexpressivo (até 0,15), Inicial (0,15 a 0,4), Intermediário (0,4 a 0,7) e Aprimorado (acima de 0,7).**



SUMÁRIO

SUMÁRIO	3
LISTA DE ANEXOS	5
1. RESUMO	6
2. INTRODUÇÃO	8
2.1 Antecedentes	8
2.2 Objetivo e escopo	9
2.3 Limitações	9
2.4 Critérios aplicados	9
2.5 Metodologia utilizada	10
2.6 Benefícios estimados	11
3. VISÃO GERAL DO OBJETO	12
2.1. Família ISO 27000	13
2.2. Controles CIS	13
2.3. Base legal (Normativos aplicáveis)	14
2.3. Primeira fase da fiscalização de segurança cibernética	15
4. RESULTADOS DA AUDITORIA	16
4.1. Avaliação dos planos de ação elaborados em atendimento a fase 1 da fiscalização	16
4.1.1. Visão geral	17
4.2. Índice de segurança cibernética básica (iSegCiber)	21
4.2.1. Controles com maior aderência	23
4.2.2. Maiores riscos	24
4.2.3. Análise de Dados	26
4.2.4. Desafios e Deficiências em Segurança da Informação	27
4.3. Achados de Auditoria	28
4.3.1 Achado 1 – Medidas básicas de segurança cibernética insuficientes na gestão de vulnerabilidades	28
4.3.2. Achado 2 – Medidas básicas de segurança cibernética insuficientes na gestão de registros de auditoria (logs)	34
4.3.3. Achado 3 – Medidas básicas de segurança cibernética insuficientes nas proteções de e-mail e navegador web	40
4.3.4. Achado 4 – Medidas básicas de segurança cibernética insuficientes nas defesas contra malware	45
4.3.5. Achado 5 – Medidas básicas de segurança cibernética insuficientes no processo de recuperação de dados	50
4.3.6. Achado 6 – Medidas básicas de segurança cibernética insuficientes na gestão da infraestrutura de rede	55
4.3.7. Achado 7 – Medidas básicas de segurança cibernética insuficientes no programa de conscientização e treinamento em segurança	59
4.3.8. Achado 8 – Medidas básicas de segurança cibernética insuficientes na gestão de provedores de serviços	66
4.3.9. Achado 9 – Medidas básicas de segurança cibernética insuficientes na gestão de respostas a incidentes	70
5. COMENTÁRIOS DO GESTOR E ANÁLISE DA EQUIPE	75
5.1. Achado 1 - Medidas básicas de segurança cibernética insuficientes na gestão de vulnerabilidades	76
5.2. Achado 2 - Medidas básicas de segurança cibernética insuficientes na gestão de registros de auditoria (logs)	

5.3. Achado 3 - Medidas básicas de segurança cibernética insuficientes nas proteções de <i>e-mail</i> e navegador <i>web</i>	78
5.4. Achado 4 – Medidas básicas de segurança cibernética insuficientes nas defesas contra malware	80
5.5. Achado 5 – Medidas básicas de segurança cibernética insuficientes no processo de recuperação de dados.....	81
5.6. Achado 6 – Medidas básicas de segurança cibernética insuficientes na gestão da infraestrutura de rede	82
5.7. Achado 7 – Medidas básicas de segurança cibernética insuficientes no programa de conscientização e treinamento em segurança	83
5.8. Achado 8 – Medidas básicas de segurança cibernética insuficientes na gestão de provedores de serviços	84
5.9. Achado 9 – Medidas básicas de segurança cibernética insuficientes na gestão de respostas a incidentes	85
5.10. Avaliação dos gestores sobre a fiscalização	87
6. CONSIDERAÇÕES FINAIS	88
7. PROPOSTA DE ENCAMINHAMENTO	89

LISTA DE ANEXOS

ANEXOS	
Documento nº	Descrição
AN01	Ofícios de Apresentação (arquivo digital “AN01 - Ofícios de Apresentação.zip”)
AN02	Matriz de Planejamento (arquivo digital “AN02 - Matriz de Planejamento.pdf”)
AN03	Questionário iSegCiber, metodologia e resultado (arquivo digital “AN03 – Questionário iSegCiber e informações.zip”)
AN04	Evidências (arquivo digital “AN04 – Evidências dos achados.pdf”)
AN05	Respostas aos Questionários (avaliação de medidas de segurança e comentários do gestor) e planilhas de ajustes (arquivo digital “AN05 – Respostas aos questionários e ajustes.zip”)
AN06	Matriz de Achados (arquivo digital “AN06 – Matriz de Achados.pdf”)
AN07	Relatório Público (arquivo digital “AN07 – Relatório Público.pdf”)
AN08	Informações das organizações (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivos digitais “ANXX – [ORGANIZAÇÃO].zip”) * Os anexos 08 a 43 consolidam as informações de cada organização auditada, seus TSIDs, respostas, evidências encaminhadas, comentários do gestor e relatórios individuais.
AN44	Planos de Ação (arquivo digital “AN44 – Planos de Ação.zip”)

1. RESUMO

O que o TCE-RJ fiscalizou?

O Tribunal de Contas do Estado do Rio de Janeiro realizou auditoria de conformidade, com contornos operacionais, para verificar a adoção de controles de segurança da informação e segurança cibernética nas organizações da Administração Pública Estadual. Trata-se da segunda fase da fiscalização em segurança da informação, motivada pelo baixo nível de maturidade das organizações no tema e pela ampliação na oferta de serviços públicos digitais.

O objeto compreendeu as medidas básicas de segurança do *framework* CIS Controls v8.1(IG1), abrangendo 29 medidas remanescentes¹ e requisitos da ABNT NBR ISO/IEC 27001/27002. Adicionalmente, foi realizada avaliação dos planos de ação elaborados em atendimento à fase 1 (processo TCE-RJ nº 105.895-5/2024).

A auditoria abrangeu 36 organizações da Administração Pública Estadual, incluindo órgãos dos poderes Executivo, Legislativo e Judiciário, Ministério Público, Defensoria Pública e Tribunal de Contas. O período do trabalho ocorreu entre agosto e dezembro de 2025.

A metodologia combinou (i) questionário de autoavaliação, (ii) análise documental das evidências apresentadas (políticas, normas e registros técnicos), (iii) verificação do status dos prazos e metas dos planos de ação monitorados e (iv) consolidação comparativa por meio do Índice de Segurança Cibernética (iSegCiber), calculado a partir das respostas e validação de evidências, com classificação em quatro níveis de maturidade (Inexpressivo, Inicial, Intermediário e Aprimorado). Ao final, o Tribunal encaminhou relatórios individuais preliminares para contraditório e analisou as manifestações recebidas.

O que o TCE-RJ encontrou?

A auditoria constatou um cenário de maturidade predominantemente incipiente na segurança cibernética das organizações estaduais. O iSegCiber indicou que 63,9% dos jurisdicionados situam-se nos níveis “Inexpressivo” ou “Inicial”.

Em razão da sensibilidade das informações tratadas e visando preservar a segurança institucional, os resultados são apresentados de forma agregada e descaracterizada, sem identificação nominal das vulnerabilidades ou das manifestações de cada jurisdicionado.

A avaliação dos planos de ação elaborados em resposta à primeira fase da fiscalização demonstrou predominância de planejamento, com baixa execução. Dos 645 encaminhamentos avaliados, mais de dois terços encontram-se nas categorias “Planejados” ou “Em Andamento”, e apenas 14% como “Atendidos”. A análise dos prazos aponta que 31,4% das ações têm previsão de conclusão até o fim de 2025, mantendo-se janela de exposição a riscos no curto prazo.

¹ Refere-se às salvaguardas do Grupo de Implementação 1 (IG1) não auditadas na primeira fase da fiscalização, abrangendo agora os Controles 7, 8, 9, 10, 11, 12, 14, 15 e 17 do *framework* CIS Controls v8.1.

Registraram-se 9 achados em 29 situações encontradas. Destacam-se: ausência de programas de conscientização em segurança da informação; baixa adoção de processos de gestão e remediação de vulnerabilidades; e insuficiência na gestão de *logs* e de inventário de provedores de serviço – situações encontradas em praticamente todas as organizações.

A análise dos comentários dos gestores revelou convergência com o diagnóstico da auditoria em 82,6% dos casos. Os gestores apontaram como principais obstáculos a escassez crítica de recursos financeiros e humanos, a obsolescência tecnológica, a dificuldade de retenção de talentos técnicos e a necessidade de conciliar a operação diária com a formalização de processos. Das 99 discordâncias apresentadas, apenas 13,1% foram acatadas, ocorrendo nos casos em que foram apresentadas evidências que comprovavam controles eficazes.

Qual é a proposta de encaminhamento?

Propõe-se um conjunto articulado de determinações e recomendações para induzir o fortalecimento da governança e da gestão de segurança da informação nas organizações estaduais, com foco na adoção adequada das medidas básicas identificadas como inconformes. A proposta central é a estruturação de plano de ação para implementação dessas medidas, conforme detalhamento constante dos relatórios individuais.

Para as organizações em situação crítica quanto ao cumprimento dos encaminhamentos da primeira fase da fiscalização, será expedida determinação para que ajustem seus planos de ação, assegurando tratamento explícito e adequado das medidas apontadas. Às duas organizações que não enviaram plano de ação será reiterada uma determinação de planejamento e cumprimento dos controles cibernéticos.

Propõe-se ainda recomendação transversal às organizações para que priorizem a consolidação dos controles fundamentais da primeira fase da fiscalização: a estrutura de segurança e os inventários de ativos e *softwares*, que constituem pré-requisitos para a eficácia dos demais controles.

Os benefícios esperados incluem o fortalecimento da governança, o aprimoramento na gestão de riscos cibernéticos, a elevação do nível de maturidade e da resiliência contra ataques, bem como a promoção de cultura organizacional que valorize a proteção de dados críticos do Estado e dados pessoais dos cidadãos.

Quais os próximos passos?

O Tribunal acompanhará a implementação por meio de monitoramento e de avaliações futuras, nos termos da Resolução TCE-RJ nº 422/2023, com foco na execução dos planos de ação registrados no SEI e na evidência de institucionalização dos processos e controles recomendados.

2. INTRODUÇÃO

Trata-se de auditoria de conformidade autorizada no âmbito do processo TCE-RJ nº 302.662-1/2024 que tem por objeto os controles de segurança cibernética adotados pelas organizações da Administração Pública Estadual.

Os trabalhos foram conduzidos em conformidade com as Normas Brasileiras de Auditoria do Setor Público (NBASP) e de acordo com os padrões estabelecidos no Manual de Auditoria deste Tribunal de Contas do Estado do Rio de Janeiro (TCE-RJ).

2.1 Antecedentes

A presente fiscalização insere-se em um conjunto de atuações planejadas do Tribunal de Contas do Estado do Rio de Janeiro (TCE-RJ) para avaliar a maturidade da Segurança da Informação no âmbito estadual.

Inicialmente, auditoria desta Coordenadoria (processo TCE-RJ nº 109.009-4/2023) analisou aspectos de Governança e Gestão de TI nas organizações do Sistema Estadual de Tecnologia da Informação e Comunicação - SETIC. Naquela oportunidade, foram identificados achados relevantes, tais como a insuficiência de práticas na gestão da segurança da informação das organizações, indicando uma vulnerabilidade estrutural na proteção dos dados sob sua custódia.

Posteriormente, com vistas a detalhar as deficiências e induzir melhores práticas de segurança da informação às organizações, esta Coordenadoria especializada entendeu por relevante e oportuno o planejamento de trabalhos específicos nesse tema.

O trabalho inaugural na presente temática, realizado na primeira metade de 2024, foi o levantamento sobre sistemas críticos, tratado no processo TCE-RJ nº 100.749-5/2024, em que se identificaram os sistemas mais críticos da administração estadual, suas vulnerabilidades e impactos decorrentes de falhas.

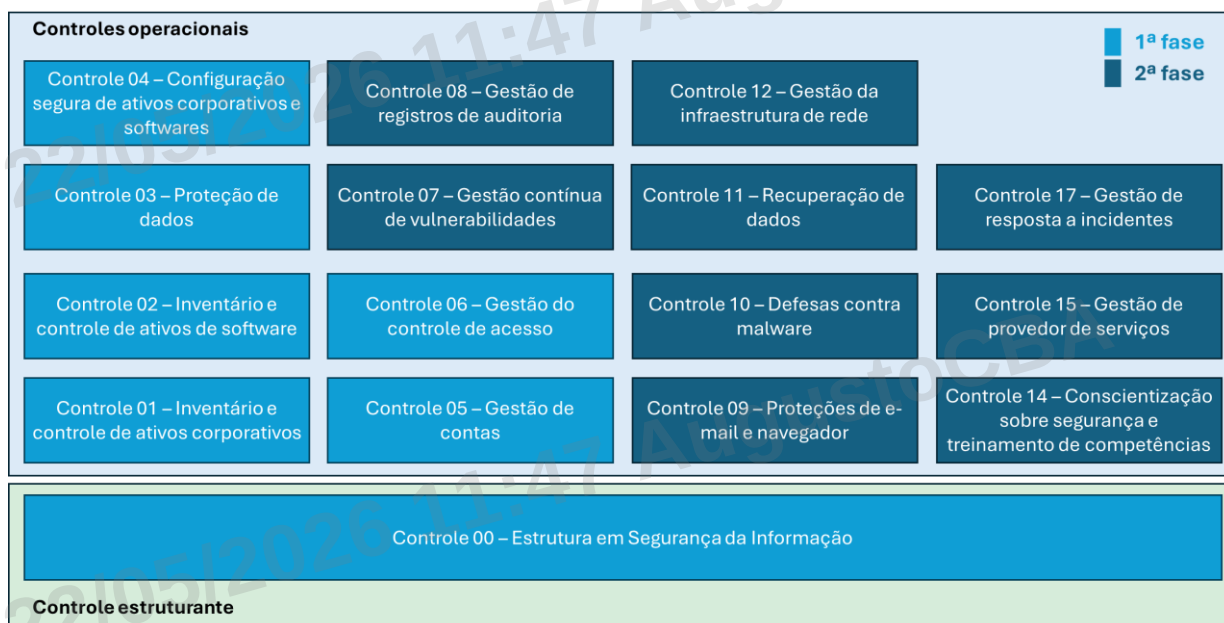
Em seguida, no segundo semestre daquele ano, planejou-se um trabalho específico para avaliação de controles de segurança, dividido em fases. Na primeira fase da auditoria de segurança cibernética, tratada no processo TCE-RJ nº 105.895-5/2024, avaliou-se um subconjunto de 27 medidas básicas do *framework* dos Controles CIS v8.1 (01 a 06) e a existência de uma estrutura básica em segurança da informação, baseada nos requisitos da Norma Técnica ISO 27001. Os resultados revelaram um cenário de maturidade predominantemente incipiente, com 66,7% dos jurisdicionados em níveis de maturidade "Inexpressivo" ou "Inicial", sendo determinada a elaboração de planos de ação para avaliação e implementação das medidas corretivas propostas.

2.2 Objetivo e escopo

O objetivo da fiscalização é finalizar a verificação da adoção de controles de segurança da informação e segurança cibernética pelas organizações da Administração Pública Estadual.

Dessa forma, será avaliada a adoção das medidas de segurança de higiene cibernética (IG1) restantes dos Controles CIS v8.1, quais sejam as 29 medidas dos Controles² 7, 8, 9, 10, 11, 12, 14, 15 e 17.

Figura 1 - Dimensões e controles avaliados



(Fonte: Elaboração própria)

O escopo da auditoria abrangeu 36 (trinta e seis) organizações da Administração Pública Estadual. O período de realização dos trabalhos de campo ocorreu entre agosto e dezembro de 2025.

2.3 Limitações

Não foram impostas limitações significativas ao trabalho da equipe de auditoria que pudessem comprometer a emissão de opinião sobre o objeto fiscalizado.

2.4 Critérios aplicados

Os principais critérios de auditoria utilizados para a análise da conformidade incluíram o *framework* CIS Controls v8.1 (com foco nas medidas de segurança do Grupo de Implementação 1 - IG1), as normas técnicas da série ISO/IEC 27000 (27001 e 27002) e os normativos

² Os controles 13 (Monitoramento e defesa da rede), 16 (Segurança de aplicações) e 18 (Testes de invasão) não foram incluídos no escopo do trabalho por não apresentarem medidas básicas de segurança cibernética. Esses controles apresentam apenas medidas dos grupos de implementação 2 e 3 (IG2 e IG3).

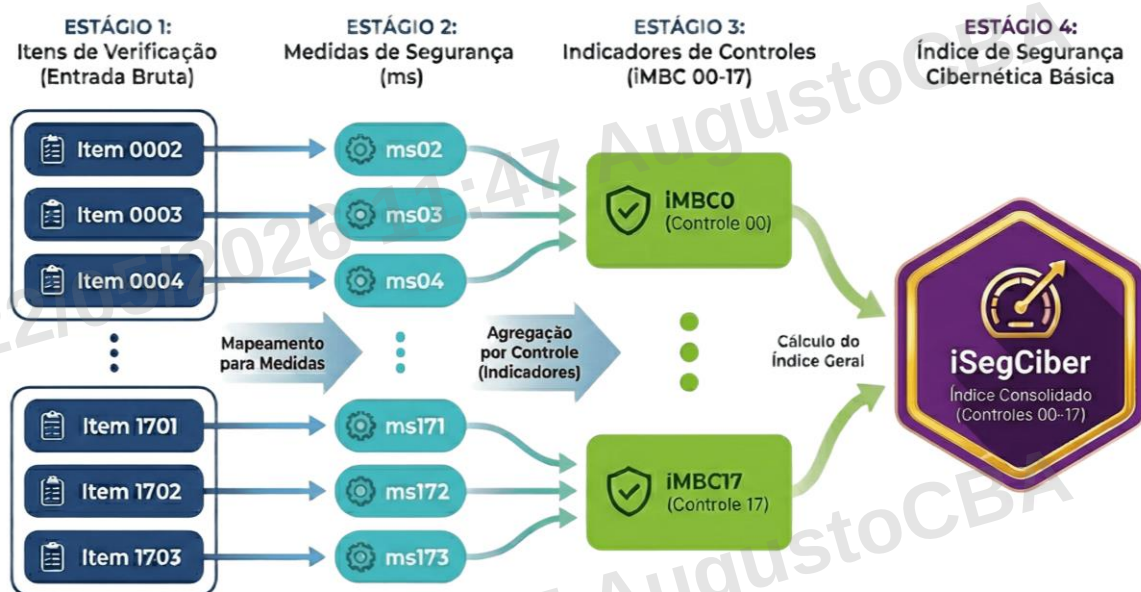
específicos aplicáveis, como a Instrução Normativa PRODERJ nº 07/2025, aplicável ao Poder Executivo, a Resolução TJ/OE nº 28/2022, aplicável ao Poder Judiciário e a Resolução CNMP nº 294/2024, aplicável ao Ministério Público.

2.5 Metodologia utilizada

A metodologia empregada envolveu a aplicação de questionário de autoavaliação baseado nas 29 medidas de segurança básica (IG1) restantes do CIS Controls v8.1, seguida de análise documental para verificação das evidências apresentadas (ex: políticas, normas, relatórios de configuração).

Para consolidar os dados obtidos e viabilizar a comparação entre as organizações auditadas, foi elaborado o Índice de Segurança Cibernética (iSegCiber) que mensura o grau de implementação das práticas recomendadas.

Figura 2 - Composição do índice iSegCiber



(Fonte: elaboração própria)

O índice, que varia de 0 a 1, é calculado a partir da combinação das respostas ao questionário e da validação das evidências comprobatórias. Com base no resultado, as organizações são classificadas em quatro níveis de maturidade, conforme metodologia detalhada no Anexo AN03: Inexpressivo (nota até 0,15), Inicial (nota de 0,15 a 0,4), Intermediário (nota de 0,4 a 0,7) e Aprimorado (nota acima de 0,7).

Ao final da fase de execução, buscando fortalecer o caráter dialógico da fiscalização, permitindo o esclarecimento de pontos obscuros, a correção de informações imprecisas ou inconsistentes, e o aperfeiçoamento das medidas propostas, foi encaminhado um relatório

individual preliminar³ para cada jurisdicionado contendo os achados da auditoria, com suas situações encontradas específicas e as propostas de encaminhamento sugeridas pela Equipe, bem como as respostas ajustadas em função da análise documental, permitindo que as organizações apresentassem suas considerações sobre os apontamentos.

Assim, os comentários remetidos pelos gestores foram avaliados para consolidação do resultado da fiscalização.

Na fase de elaboração do relatório, a Equipe de Auditoria produziu o presente documento sigiloso, bem como 35 relatórios individuais (todas as 36 organizações, exceto a RJPREV⁴) contemplando uma visão geral das medidas básicas de segurança cibernética da organização, os achados, as situações encontradas, as propostas de encaminhamento e um plano de ação específico para cada entidade.

Em prol da transparência e da promoção do controle social, a Equipe também elaborou um Relatório Público (AN07), destinado a demonstrar o trabalho realizado.

2.6 Benefícios estimados

Espera-se que esta fiscalização induza o fortalecimento da governança e da gestão de segurança da informação nas organizações estaduais. Os principais benefícios estimados incluem o aprimoramento na gestão de riscos cibernéticos e a efetiva adoção de controles técnicos alinhados às boas práticas internacionais, elevando o nível de maturidade e a resiliência dos órgãos públicos contra ataques cibernéticos.

Adicionalmente, a auditoria contribui para a promoção de uma cultura organizacional que valoriza a proteção de dados, induzindo melhorias na proteção das informações críticas do Estado e dos dados pessoais dos cidadãos.

³ Os relatórios preliminares individuais enviados aos jurisdicionados encontram-se presentes no TSID03 de cada anexo das organizações auditadas (AN08 a AN43).

⁴ Uma vez que a RJPREV está alocada dentro da infraestrutura da SEFAZ, conforme informado na etapa de coleta de informações, as medidas de segurança aplicáveis a ela são aquelas direcionadas à Secretaria.

3. VISÃO GERAL DO OBJETO

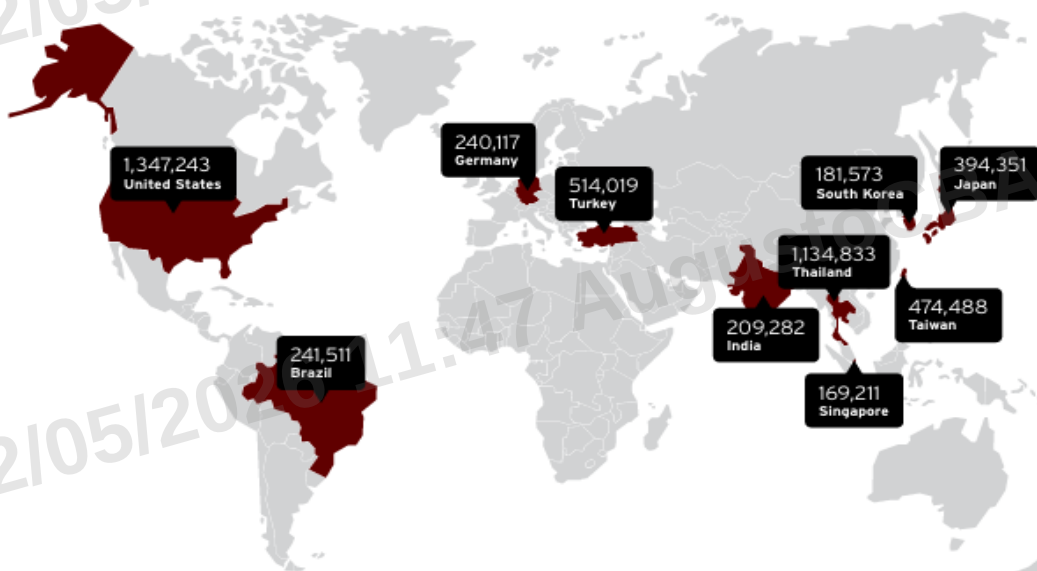
A crescente integração de tecnologias da informação nos negócios, aliada ao aumento da conectividade, tem impulsionado avanços significativos em diversas áreas da sociedade, incluindo a transição do setor público para um Governo Digital mais eficiente e moderno.

No entanto, esses benefícios trazem consigo desafios igualmente complexos: a evolução constante das ameaças cibernéticas. O TCU destaca, em sua lista de alto risco da administração pública federal⁵, a falta de prioridade para a segurança cibernética por parte do Estado brasileiro, o que deixa pessoas e organizações vulneráveis.

Tal relatório aponta um aumento de incidentes de 3.402 em 2022 para 5.302 em 2024 no setor público, levantando preocupações sobre a capacidade de proteção de dados e a continuidade dos serviços. De acordo com a Corte de Contas Federal, nenhuma organização fiscalizada implementa a totalidade dos controles de segurança necessários para conter ataques de *ransomware* conhecidos.

Além disso, segundo o Relatório Anual de Cibersegurança de 2025 da Trend Micro⁶, o Brasil está entre os 10 países com as maiores quantidades de ataques por *ransomware* no ano. Destacam-se os dados que apontam o setor público como o mais afetado por essas ameaças, conforme ilustrado na Figura 3.

Figura 3 - Top 10 países em detecção de *ransomware* em 2025 (Trend Micro)



(Fonte: Relatório Anual de Cibersegurança de 2025, Trend Micro)

⁵ TRIBUNAL DE CONTAS DA UNIÃO. Segurança da Informação e segurança cibernética. 2024. Disponível em: https://sites.tcu.gov.br/listadealtorisco/seguranca_da_informacao_e_seguranca_cibernetica.html. Acesso em: 23 out. 2025.

⁶ TREND MICRO. Trend 2025 Cyber Risk Report. 2025. Disponível em: <https://documents.trendmicro.com/images-/TEx/articles/Research-Risk-Report-2025.pdf>. Acesso em: 23 out. 2025.

Diante desse cenário, torna-se imprescindível que as organizações públicas incorporem em seu planejamento medidas robustas para mitigar os crescentes riscos à segurança da informação. Essas medidas devem garantir a proteção da confidencialidade, integridade e disponibilidade das informações, independentemente do meio em que são armazenadas, processadas ou transmitidas.

Entre as práticas recomendadas para enfrentar esses desafios, destacam-se as normas da família ISO/IEC 27000 e o conjunto de controles críticos de segurança cibernética descritos no *framework* CIS Controls versão 8.1.

2.1. Família ISO 27000

As normas da família ISO/IEC 27000 fornecem um conjunto de requisitos, regras e diretrizes para se desenvolver, manter e melhorar continuamente um Sistema de Gestão de Segurança da Informação - SGSI.

Dentro dessa família, destacam-se a ISO/IEC 27001, que define os requisitos para um SGSI, além de detalhar como uma organização pode avaliar e tratar riscos de segurança da informação de forma sistemática e baseada em critérios bem definidos, e a ISO/IEC 27002, que fornece um conjunto abrangente de controles e diretrizes a serem implementados pelo SGSI para mitigar os riscos identificados.

2.2. Controles CIS

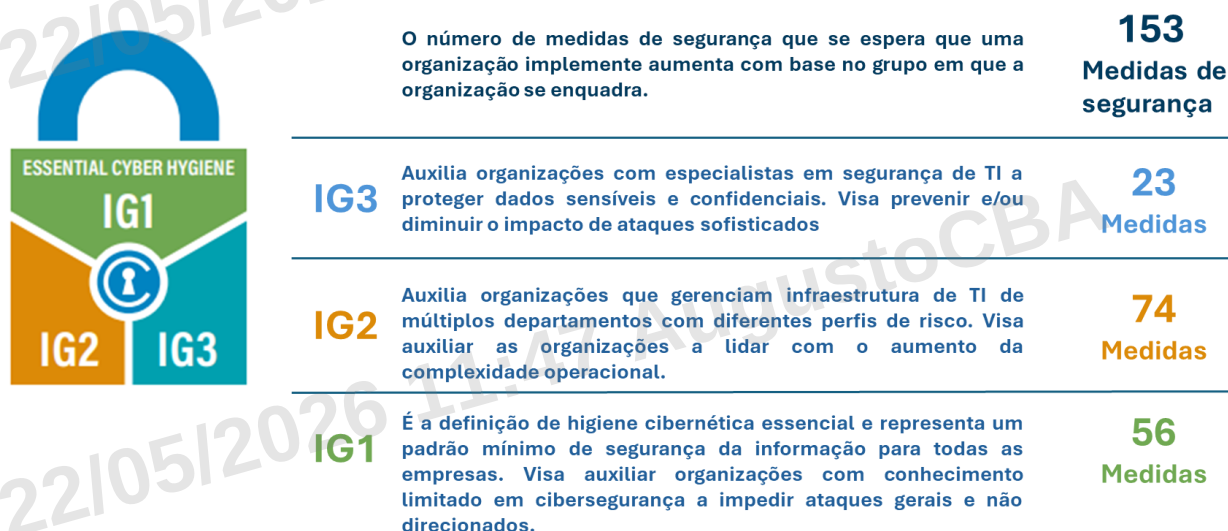
Os Controles CIS⁷ são um conjunto prioritário e prescritivo de práticas recomendadas de segurança cibernética, selecionadas por especialistas do *Center for Internet Security* – CIS⁸, para mitigar os ataques e ameaças de segurança mais frequentes.

Atualmente na versão 8.1, o *framework* consiste em 18 controles organizados em 153 medidas de segurança (*safeguards*) bem definidas. Para simplificar e priorizar a implementação eficaz dessas medidas, o CIS estruturou três Grupos de Implementação (IGs) - IG1, IG2 e IG3. Esses grupos são definidos com base no perfil de risco e nos recursos disponíveis para que cada organização implemente as salvaguardas propostas.

⁷ CENTER FOR INTERNET SECURITY. CIS Controls. Disponível em: <https://learn.cisecurity.org/cis-controls-download>. Acesso em: 6 nov. 2025.

⁸ O *Center for Internet Security* - CIS é uma entidade sem fins lucrativos cuja missão é "fazer o mundo conectado um lugar mais seguro desenvolvendo, validando e promovendo tempestivamente melhores soluções práticas que ajudem pessoas, negócios e governos a se protegerem contra ameaças cibernéticas". O CIS lidera uma comunidade global de profissionais de TI que melhoram continuamente essas soluções e proveem produtos e serviços para proteção proativa contra ameaças emergentes. Entre os produtos providos pelo CIS, destacam-se os Controles CIS v8.1.

Figura 4 – Grupos de Implementação do *framework* CIS Controls



(Fonte: Controles CIS v8.1)

Entre os grupos, o IG1 representa o conjunto de 56 medidas básicas de segurança cibernética que todas as organizações devem adotar para se proteger contra os ataques cibernéticos mais comuns. Conhecido como "higiene cibernética essencial", esse nível estabelece um padrão mínimo de segurança das organizações.

No contexto dos Controles CIS, o *Community Defense Model* (CDM), estudo elaborado pelo CIS para avaliar seus controles de segurança cibernética, demonstrou que os Controles CIS v8 são capazes de neutralizar 86% das técnicas e padrões de ataque mapeados no *framework* MITRE ATT&CK⁹ e que apenas as medidas de segurança do IG1 conseguem mitigar 74% desses ataques.

2.3. Base legal (Normativos aplicáveis)

A administração pública do Estado do Rio de Janeiro possui normativos específicos em matéria de segurança da informação.

No âmbito do Poder Executivo, além de normas intraorganizacionais, como Portarias e Políticas internas, a segurança da informação é regulamentada pelas Instruções normativas editadas pelo Diretor-Geral do SETIC¹⁰, atualmente sob a responsabilidade do PRODERJ.

Para regulamentar procedimentos de segurança da informação nos órgãos e entidades do Poder Executivo, o PRODERJ publicou a Instrução Normativa nº 07/2025, que substitui e revoga sua Instrução Normativa nº 02/2022. Essa norma estabelece, em seu art. 9º, que os

⁹ O *framework* MITRE ATT&CK, atualmente na versão 8.2, é uma referência mundialmente reconhecida que cataloga táticas e técnicas de ataques cibernéticos. Disponível em: [MITRE ATT&CK](https://mitre-attack.com/). Acesso em 07/11/2024

¹⁰ O Sistema Estadual de Tecnologia da Informação e Comunicação – SETIC, conforme Decreto Estadual nº 48.997/2024, representa o conjunto de recursos humanos, tecnológicos e de equipamentos voltados para o estabelecimento e a implementação de políticas para a informação e a comunicação pública do Estado do Rio de Janeiro.

procedimentos de segurança devem ser claros, objetivos, regularmente revisados e amplamente divulgados.

No âmbito do Poder Judiciário, foi elaborada a Estratégia de Segurança da Informação e Cibernética (ESIC-PJERJ) e a Resolução TJ/OE nº 28/2022, visando aprimorar o nível de maturidade em segurança cibernética. Essa estratégia visa tornar as informações e o espaço cibernético mais confiáveis, resilientes, inclusivos e seguros. Para o Ministério Público foi editada a Resolução CNMP nº 294/2024.

2.3. Primeira fase da fiscalização de segurança cibernética

A auditoria presente no bojo do processo TCE-RJ nº 105.895-5/2024 consiste na primeira fase da fiscalização de segurança cibernética na Administração Pública do Estado do Rio de Janeiro. Na ocasião foram verificados um subconjunto dos Controles CIS 8, do Controle 1 ao 6, além do Controle 0, que tange estruturas básicas de segurança cibernética.

Sobre esse aspecto, o resultado apontou, em linhas gerais, para um cenário incipiente de maturidade das organizações às medidas básicas de segurança cibernética em que 24 dos 36 jurisdicionados (66,7%) estão nos níveis de maturidade Inexpressivo ou Inicial.

A análise do Controle 0 (Estrutura de Segurança da Informação) revelou deficiências estruturais significativas: 28 das 36 organizações (77,8%) não possuíam uma estrutura básica atuante. A lacuna mais crítica e disseminada foi a ausência de uma Política de Segurança da Informação (PSI) formalmente estabelecida e mantida, verificada em 65,7% dos auditados.

Os achados mais recorrentes e graves relacionaram-se aos controles operacionais. As falhas na Proteção de Dados (Controle 3), na Configuração Segura de Ativos (Controle 4) e na Gestão de Contas e Controle de Acesso (Controles 5 e 6) foram quase universais, sendo identificadas em 35 dos 36 jurisdicionados (97,2%). A gestão de inventário de ativos e *softwares* (Controles 1 e 2) também se mostrou altamente deficiente, com 91,7% de inconformidade.

Nesse sentido, foram propostas até 27 medidas por auditado a serem adotadas para melhorias na segurança da informação das organizações, com determinação da elaboração de um plano que contemple as ações para o cumprimento dos respectivos encaminhamentos.

Na presente fiscalização, além da avaliação de novos controles, foram solicitados os referidos planos de ação elaborados pelas organizações em decorrência da fase 1. O objetivo é avaliar o grau de atendimento aos encaminhamentos propostos e monitorar a evolução da maturidade em segurança cibernética dos jurisdicionados.

4. RESULTADOS DA AUDITORIA

Devido à sensibilidade dos dados tratados e visando preservar a segurança das instituições, as informações, comentários e opiniões oferecidos pelas organizações nas fases de coleta não serão explicitados de forma nominal.

Diante disso, os dados serão apresentados de maneira agregada ou descaracterizada, focando na análise sistêmica dos problemas e nas soluções transversais para a Administração Pública, sem expor individualmente as vulnerabilidades ou manifestações de cada jurisdicionado.

4.1. Avaliação dos planos de ação elaborados em atendimento a fase 1 da fiscalização

A presente avaliação insere-se no monitoramento preliminar das determinações exaradas durante a primeira fase da fiscalização de segurança cibernética (Processo TCE-RJ nº 105.895-5/2024). Naquela etapa inicial, que verificou a existência de uma estrutura básica de segurança da informação e a aderência aos Controles CIS 1 a 6, o diagnóstico revelou um cenário de fragilidade sistêmica na Administração Pública estadual: 66,7% das organizações encontravam-se em níveis de maturidade Inexpressivo ou Inicial.

Em resposta a esse cenário crítico, foram expedidos até 27 encaminhamentos por organização, com a determinação expressa para a elaboração de Planos de Ação visando sanar as inconformidades descritas.

A decisão plenária contendo as determinações foi exarada em 26/05/2025, concedendo às organizações um prazo de até 60 dias para a elaboração e registro de seus respectivos planos de ação.

Visando aferir o cumprimento tempestivo dessa obrigação, a Equipe de Auditoria, solicitou aos auditados o envio dos planos consolidados em meados de setembro de 2025. Portanto, a presente avaliação considera o status e planejamento das organizações neste marco específico, momento em que o prazo regulamentar para planejamento já se encontrava expirado.

Para a aferição do atendimento dos encaminhamentos, a Equipe analisou 33 planos¹¹ submetidos pelas organizações auditadas. A metodologia consistiu no confronto direto entre cada encaminhamento proposto e a respectiva resposta do gestor, classificando-as segundo sua materialidade e tempestividade:

- **Atendido / Em Andamento:** Ações concluídas e iniciadas.
- **Planejado:** Ações futuras com prazo definido (promessas de execução).

¹¹ Destaca-se a ausência de 2 planos na avaliação, uma vez que não foram enviados tempestivamente à equipe de fiscalização, e que o plano da RJPREV não foi avaliado dado que parte significativa de seus controles tecnológicos foi considerada no escopo da avaliação da SEFAZ, dada a dependência de gestão. Planos avaliados estão no AN44.

- **Resposta insuficiente quanto ao objeto:** Respostas vagas, genéricas ou condicionadas a eventos incertos (ex: "aguardando reestruturação"), sem detalhamento técnico.
- **Item não endereçado:** Omissão completa do encaminhamento no plano de ação.

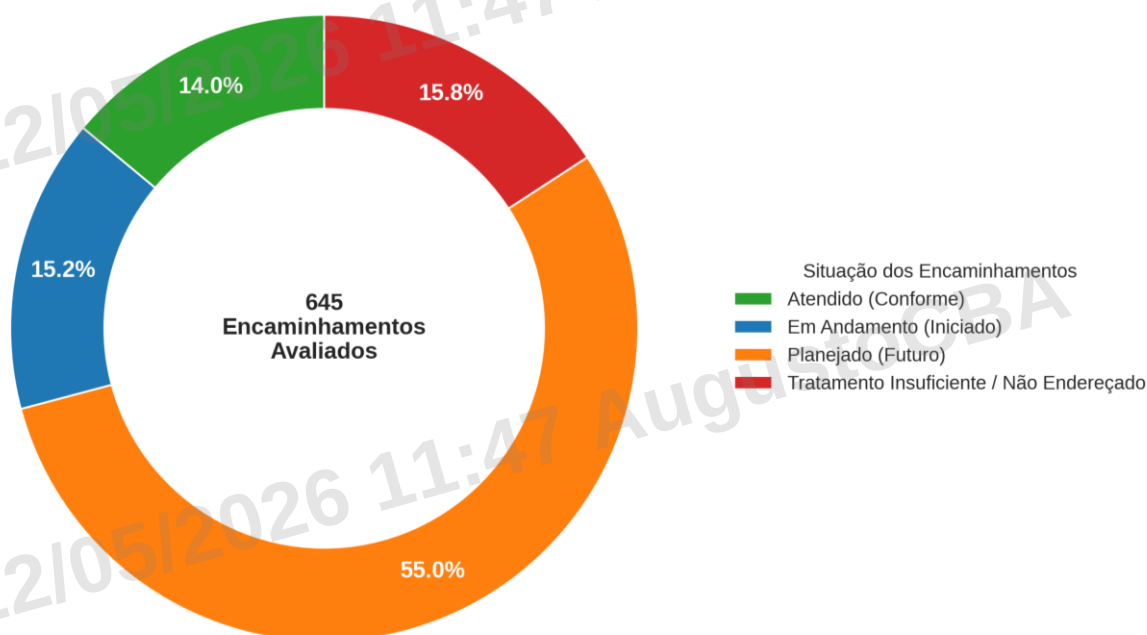
A partir dessa classificação, calculou-se o grau de cobertura dos encaminhamentos (percentual de encaminhamentos propostos que foram endereçados pelo plano).

Ressalta-se que o escopo desta avaliação se limitou à análise das informações prestadas nos planos apresentados. Nesta etapa as informações não foram validadas por meio de testes pela Equipe.

4.1.1. Visão geral

A análise dos planos de ação encaminhados revela um cenário de alta capacidade de planejamento, porém ainda com um baixo grau de execução das ações propostas. Identificou-se que, dos 645 encaminhamentos avaliados, mais de dois terços (70,2%) encontra-se nas categorias "Planejados" ou "Em Andamento". O percentual de itens efetivamente "Atendidos" (concluídos) ainda é baixo, de apenas 14%, conforme detalhado na Figura 5.

Figura 5 – Status consolidado dos encaminhamentos



(Fonte: elaboração própria)

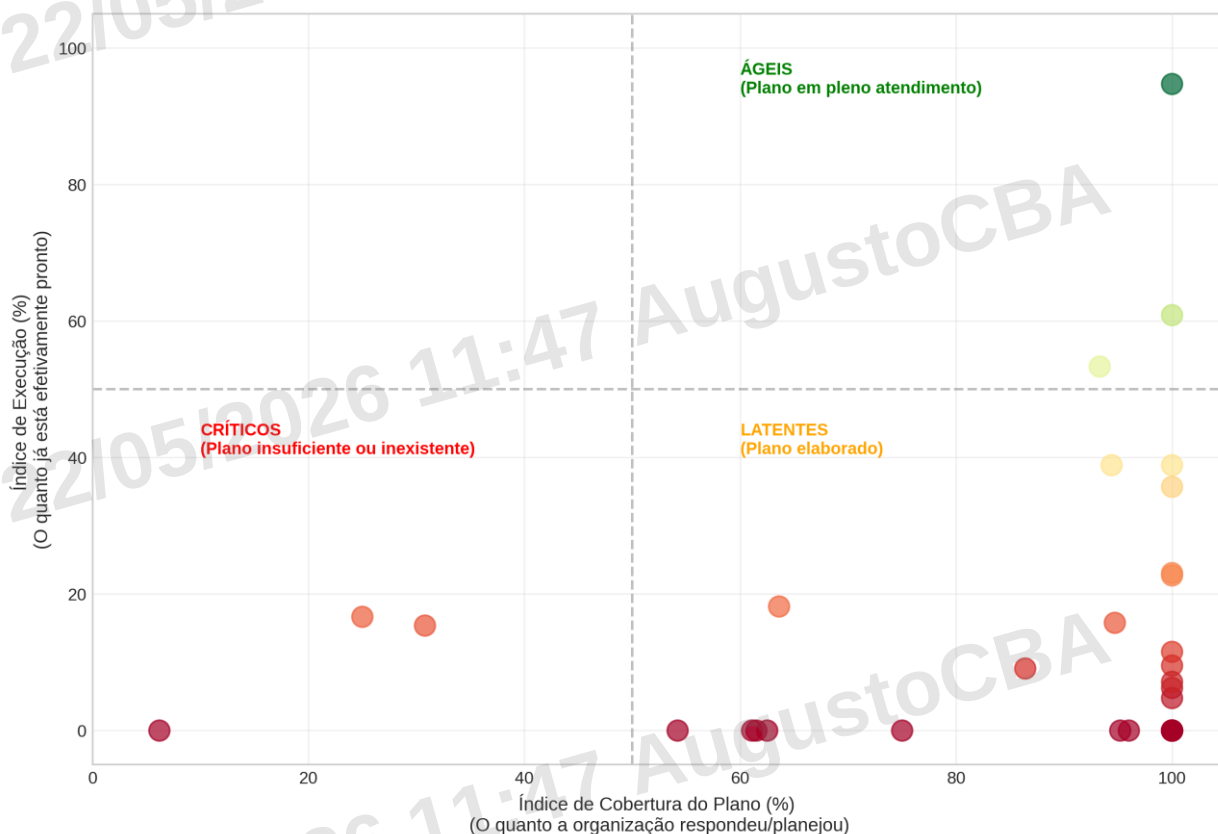
Dos encaminhamentos classificados como “Resposta insuficiente quanto ao objeto” observa-se uma confusão entre ferramentas e processos. Diversas organizações responderam à necessidade de se estabelecer um processo com a aquisição ou implementação de ferramentas. Ignora-se que a tecnologia sem o rito processual de formalização, fluxo e responsabilização não atende ao controle.

Ainda nessa classe, identificou-se o uso recorrente de reestruturações organizacionais ou ausência de setores formais como justificativa para não executar controles operacionais básicos, paralisando a segurança à espera de uma burocracia ideal. Também foi observada a transferência de responsabilidade para o provedor central de TI do Poder Executivo, o que mesmo quando cabível, não exime as organizações da responsabilidade de assegurar a adequada adoção das práticas apontadas.

Da análise dos itens classificados como "Item Não Endereçado", observou-se que controles técnicos essenciais não estão sendo adequadamente tratados, como os relacionados a governança da segurança (Gestão de riscos e Política de Segurança da Informação), o inventário de ativos/software e a utilização de autenticação multifator (MFA).

Por fim, a avaliação, apresentada na Figura 6, entre o índice de cobertura (grau de encaminhamentos propostos que foram endereçados pela organização) e o índice de atendimento aos encaminhamentos aponta para uma disparidade preocupante entre as organizações. Destaca-se o grupo dos “ágeis”, que demonstrou capacidade de resposta imediata. Em contrapartida, observa-se uma "cauda crítica" de entidades que falharam tanto em planejar quanto em executar. No meio termo encontra-se o grupo dos “latentes”, que apresenta uma capacidade de planejamento, mas cujos controles de segurança ainda não se manifestaram efetivamente no ambiente operacional.

Figura 6 – Matriz de cumprimento (Planejamento vs. Execução)



(Fonte: elaboração própria)

A análise de 398 prazos válidos apresentados para os encaminhamentos pendentes de conclusão (classificados como "Em Andamento" ou "Planejados") revela uma larga janela temporal de vulnerabilidade. Os dados apontam para uma concentração de esforços apenas a partir de 2026, com uma parcela alarmante de previsão de cumprimento para o médio e longo prazo.

Da avaliação, apenas 31,4% das ações serão concluídas até o fim de 2025. A maior concentração de entregas (41,2%) está prevista para o ano de 2026 e identificou-se que 27,4% das ações foram empurradas para um horizonte distante a partir de 2027, com destaque negativo a partir do ano de 2029 (21,1% das entregas previstas).

Esse cenário implica que a Administração operará, pelos próximos 12 a 48 meses, ciente das vulnerabilidades (riscos conhecidos), mas sem os controles mitigadores ativos.

Em complemento à análise documental dos planos, a Equipe de Auditoria coletou, via questionário enviado com o TSID2, a percepção dos gestores quanto aos obstáculos enfrentados para a materialização das ações de segurança. O confronto entre a realidade verificada (baixo índice de execução) e a visão interna das organizações revela gargalos estruturais críticos.

A análise das justificativas aponta a insuficiência de Recursos Humanos (Item A2.b do questionário) como o impedimento mais severo e transversal na Administração Pública. Diversas organizações sinalizaram que sua equipe técnica é insuficiente em número ou carece da capacitação necessária para implementar os controles do CIS v8.

Relatou-se explicitamente a dificuldade em "conciliar a execução diária das medidas de segurança com o tempo necessário para formalizar os procedimentos e normas", indicando que a rotina de "apagar incêndios" impede a maturação da governança.

A forma como a alta gestão acompanha o progresso do plano de ação (Item A3) correlaciona-se com a qualidade e agilidade dos planos. Organizações que relataram que o progresso é acompanhado de forma "*interna e informal*" ou "*não houve acompanhamento formalmente estabelecido*" apresentam um baixo índice de cobertura e execução do plano. Em contrapartida, entidades que reportaram monitoramento formal tendem a apresentar ações mais estruturadas e consciência dos riscos.

Apesar dos atrasos, as organizações que iniciaram a execução relatam ganhos tangíveis imediatos (Item A4) na segurança da informação da organização, validando a eficácia dos controles propostos, como exemplo:

- **Mudança Cultural:** Relatou-se maior engajamento dos usuários no reporte proativo de e-mails suspeitos (*phishing*). Outra entidade destaca a sinergia amplificada entre os setores de serviços e aumento da maturidade dos técnicos envolvidos no projeto. Também foi apontado um aumento no engajamento dos usuários e destaque para uma postura mais proativa, gerando mais visibilidade de seu ambiente e reduzindo os riscos.

- **Controle de Ativos e Shadow IT:** Houve apontamento sobre o desenvolvimento de mecanismos específicos para "controlar programas instalados no parque com base em um *baseline* definido", e a consolidação da elaboração consistente de inventário de ativos e *softwares*, atacando a raiz dos problemas de *softwares* não autorizados.
- **Proteção de Identidade:** Foi destacada a mitigação de riscos de acesso não autorizado através do bloqueio automático de tela e implementação de duplo fator de autenticação.
- **Elevação Estratégica da Segurança:** Relatou-se que a formalização da governança (Criação de Comitê e aprovação da PSI) gerou o benefício intangível, porém vital, de "elevar a segurança da informação à pauta estratégica da alta gestão".

Diante do cenário de risco apresentado será proposta **DETERMINAÇÃO** às organizações auditadas em situação crítica para que ajustem seu plano de ação a fim de que as ações presentes nele tratem explicita e adequadamente dos encaminhamentos apontados no item III do Acórdão nº 12.947/2025 referente à decisão plenária do Processo TCE-RJ nº 105.895-5/2024.

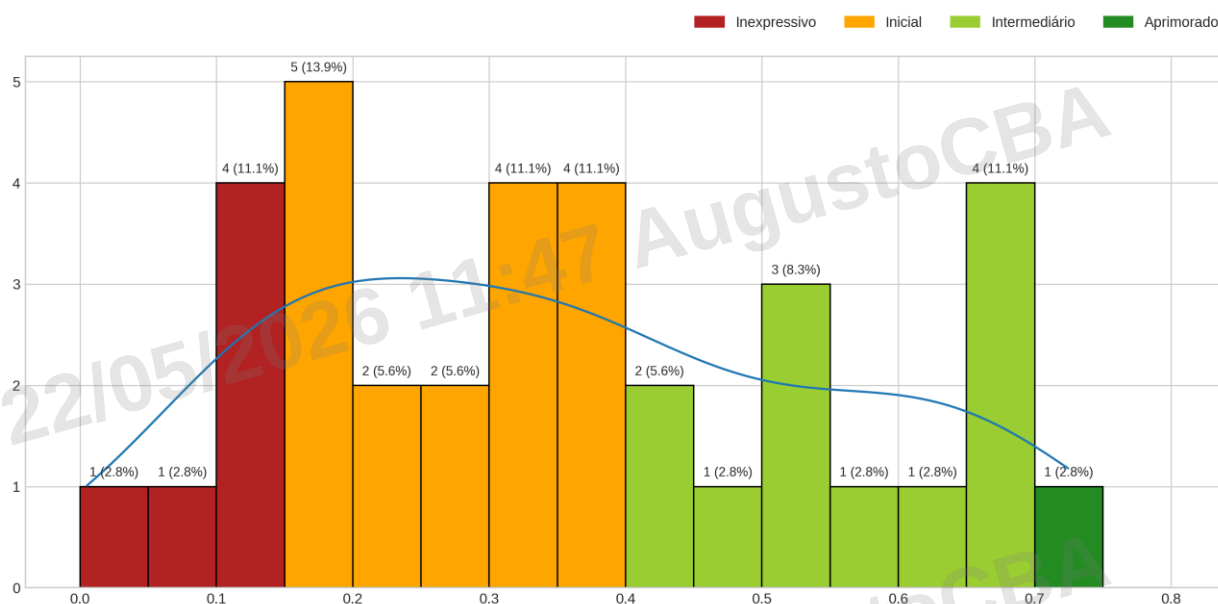
Diante do não envio do plano de ação por 2 organizações em atendimento ao TSID1 será proposta **DETERMINAÇÃO** reiterando a necessidade de se planejar e avaliar as medidas suficientes para cumprimento dos controles cibernéticos apontados no Processo TCE-RJ nº 105.895-5/2024.

4.2. Índice de segurança cibernética básica (iSegCiber)

A avaliação da maturidade em segurança da informação, realizada junto a 36 organizações jurisdicionadas, revela um cenário predominantemente incipiente e marcado por fragilidades estruturais. A análise do Índice de Segurança Cibernética Básica (iSegCiber) demonstra uma concentração de organizações com avaliações baixas, evidenciando que a estratégia de segurança vigente na maioria dos entes é reativa e carece de processos formalizados.

A distribuição de frequência das notas (Figura 9) apresenta uma curva deslocada para a esquerda, o que denota uma maior densidade de organizações nas faixas de pontuação inferior (entre 0,10 e 0,40).

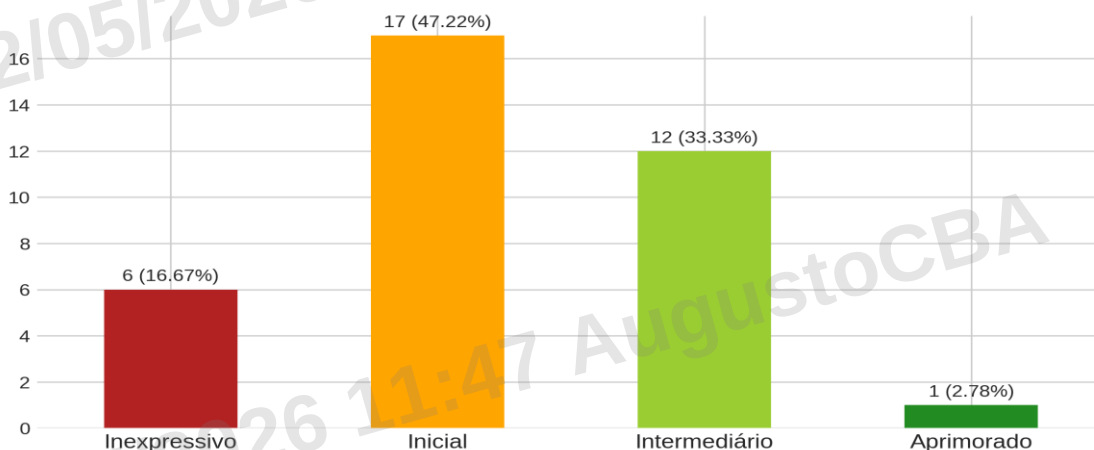
Figura 7 – Histograma apresentando a distribuição das notas do índice iSegCiber



(Fonte: elaboração própria)

Ao classificar os índices calculados nos níveis de maturidade estabelecidos pela metodologia, confirma-se o diagnóstico de vulnerabilidade: 63,9% das organizações (23 de 36) situam-se nos estratos inferiores (“Inexpressivo” ou “Inicial”). Apenas uma organização auditada (2,8%) atingiu o nível “Aprimorado”, conforme detalhado na Figura 8.

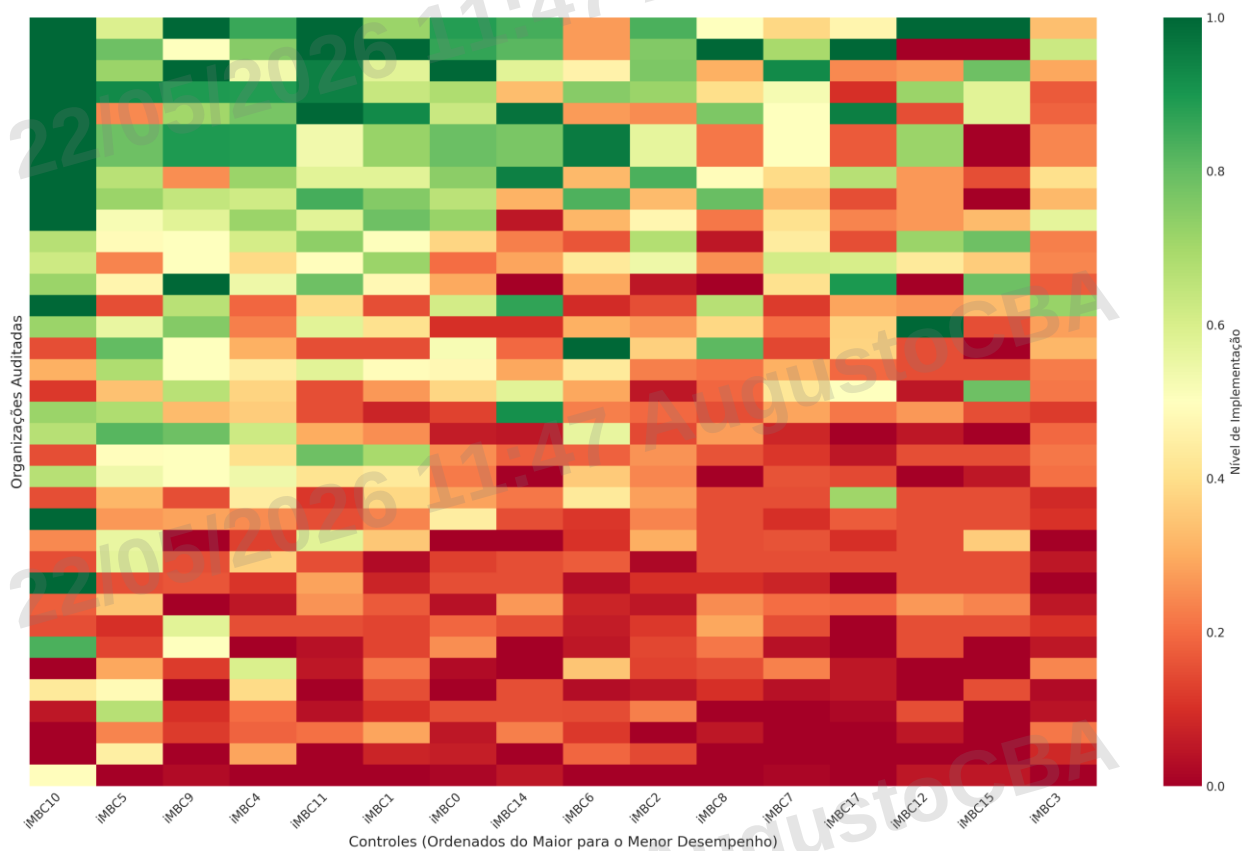
Figura 8 - Níveis de maturidade das organizações às medidas básicas de segurança cibernética



(Fonte: elaboração própria)

A falta de homogeneidade na aplicação dos controles é visível no mapa de calor abaixo (Figura 9). Observa-se uma predominância de tonalidades quentes (vermelho e laranja), indicando baixa aderência na maioria dos requisitos avaliados, salvo exceções pontuais em controles específicos.

Figura 9 - Matriz de calor evidenciando a concentração de organizações (eixo Y) com baixos níveis de implementação na maioria dos controles (eixo X)



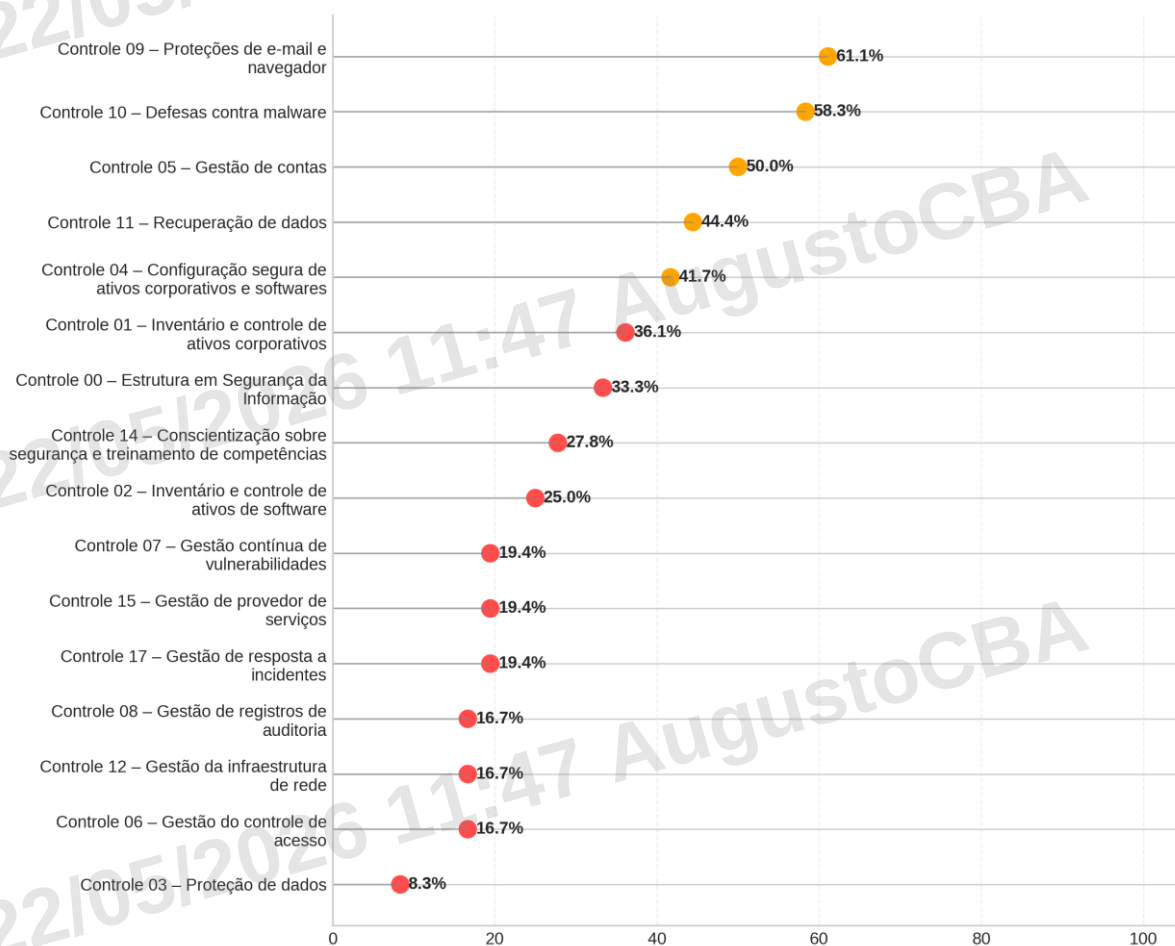
(Fonte: elaboração própria)

Em síntese, a média global de aderência situa-se abaixo de 0,40, denotando que os requisitos essenciais de segurança são atendidos, em média, de forma parcial e não estruturada.

4.2.1. Controles com maior aderência

A análise setorializada aponta que os controles com melhores índices de desempenho são aqueles frequentemente associados a soluções tecnológicas de mercado (“*commodities*” de segurança) ou necessidades operacionais básicas. O gráfico abaixo destaca os controles que atingiram os maiores percentuais de classificação nos níveis “Largamente Atingido” ou “Plenamente Atingido”.

Figura 10 - Percentual de organizações que atingiram níveis satisfatórios de conformidade (“Largamente” ou “Plenamente”) por controle



(Fonte: elaboração própria)

Destacam-se neste grupo:

- **Controle 09 – Proteções de e-mail e navegador (Nota média: 0,46):** Apresenta o maior índice de sucesso relativo, com 61,1% das organizações situadas nos níveis superiores de maturidade. O desempenho sugere que as organizações se beneficiam de camadas

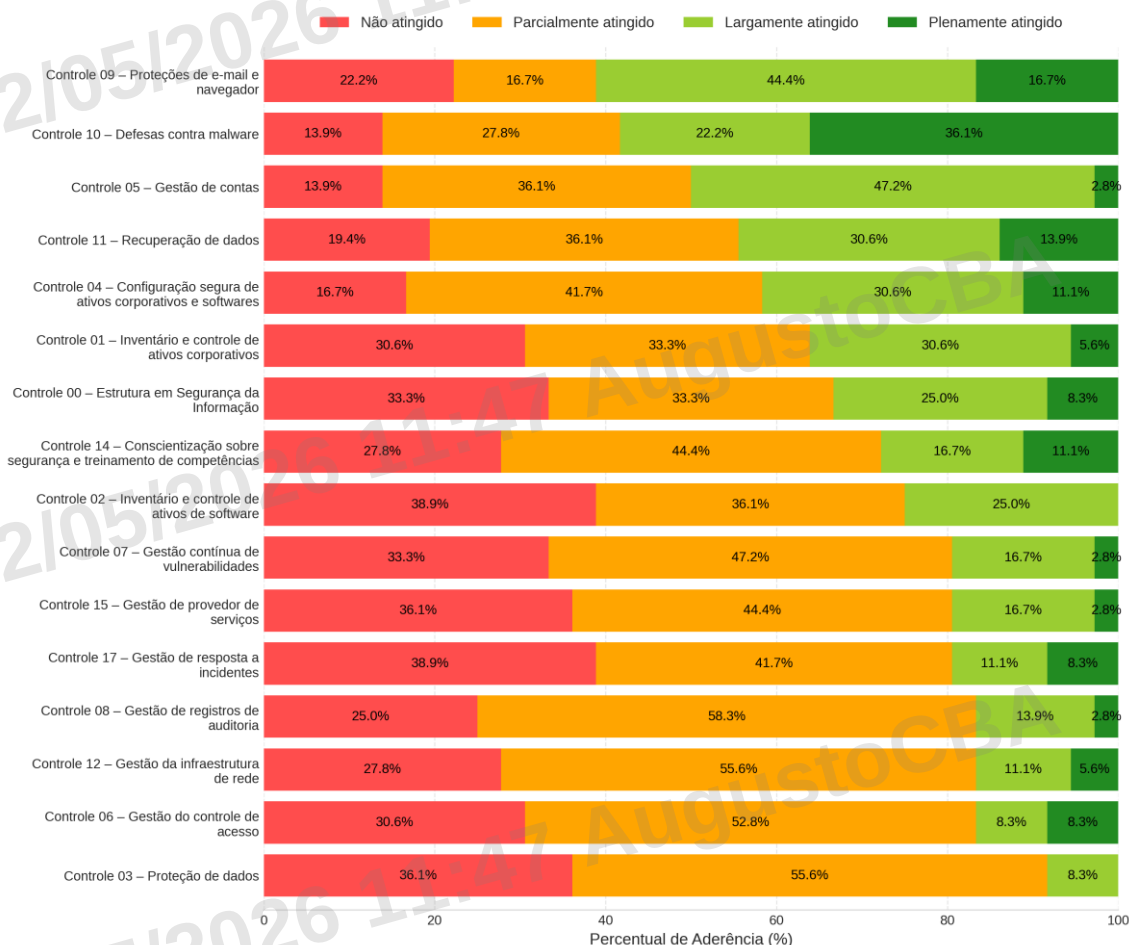
de segurança nativas providas por serviços de correio eletrônico e navegação contratados, garantindo uma proteção perimetral mínima.

- **Controle 10 – Defesas contra *malware* (Nota média: 0,59):** Apresenta a segunda melhor adoção de controles, com 58,3% das organizações situadas nos níveis superiores de maturidade. Este resultado sugere que a aquisição de ferramentas de antivírus/*antimalware* é uma das medidas de segurança mais disseminada.
- **Controle 05 – Gestão de contas (Nota média: 0,49):** A posição de destaque deste controle reflete a necessidade operacional básica de criação e manutenção de credenciais de acesso. Contudo, a aderência é predominantemente “Parcial” ou “Larga”, indicando que, embora as contas sejam criadas, processos de revisão e revogação podem não estar totalmente maduros.

4.2.2. Maiores riscos

Os controles com desempenho crítico revelam lacunas severas na gestão de ativos, infraestrutura e proteção da informação. O gráfico de barras empilhadas a seguir detalha a composição dos níveis de aderência, evidenciando a predominância das classificações “Não Atingido” (vermelho) e “Parcialmente Atingido” (laranja) nestes quesitos.

Figura 11 - Distribuição detalhada dos níveis de aderência por controle



(Fonte: elaboração própria)

A análise detalhada destes *gaps* aponta riscos iminentes:

- **Controle 03 – Proteção de dados (Nota média: 0,21):** Identificado como a maior vulnerabilidade do escopo auditado. Observa-se que 91,7% das organizações não atingiram níveis satisfatórios de implementação. A ausência de processos robustos de identificação e classificação de dados torna ineficazes medidas avançadas de proteção, expondo os entes a riscos elevados de desconformidade com a LGPD e vazamento de informações sensíveis.
- **Controle 12 – Gestão da infraestrutura de rede (Nota média: 0,25):** Com aproximadamente 83,4% das organizações em níveis críticos, constata-se deficiência na manutenção adequada dos ativos de rede, comprometendo a resiliência a vulnerabilidades conhecidas.
- **Controle 6 – Gestão do controle de acesso (Nota média: 0,32):** Também com 83,4% das organizações em níveis insuficientes (abaixo do “Intermediário”), constata-se problemas no controle de acesso das organizações, com medidas insuficientes para concessão e revogação de acesso, bem como a utilização de MFA para acesso às aplicações da organização.

- **Controle 8 – Gestão de logs (registros de auditoria) (Nota média: 0,27):** Ainda com 83,4% das organizações em níveis insuficientes (abaixo do “Intermediário”), verificam-se deficiências na definição de um processo de gestão de logs, com consequente coleta dos registros e armazenamento adequado.

4.2.3 Análise de Dados

A análise estatística da correlação dos dados coletados permitiu identificar dependências lógicas que explicam a baixa maturidade geral. Destacam-se os seguintes achados analíticos:

- **A importância do controle estruturante:** O Controle 00 (Estrutura em Segurança da Informação) possui a maior correlação com o índice geral de segurança (iSegCiber). Isso demonstra que o estabelecimento formal de comitês, políticas e normas é o maior preditor de sucesso para a implementação dos demais controles técnicos. Organizações sem governança formal tendem a ter desempenho técnico inferior em todas as outras áreas.
- **Inconsistência na ordem de implementação:** Observou-se que controles mais operacionais (Controles 09 e 10) possuem notas superiores a controles de base, como Inventário de Ativos (Controle 01 e 02) e Proteção de Dados (Controle 03). Essa inversão sugere um investimento em ferramentas pontuais sem a consolidação dos fundamentos de segurança, reduzindo a eficácia do gasto público em tecnologia.

A avaliação conclui que o ambiente auditado opera sob risco cibernético, caracterizado pela falta de visibilidade sobre os próprios ativos e dados. A estratégia de segurança vigente aparenta ser reativa e dependente de ferramentas isoladas, carecendo de uma abordagem baseada em riscos e processos integrados.

É primordial que as ações de remediação sejam priorizadas pelo fortalecimento da Higiene Cibernética Básica com ênfase em estabelecer e manter uma estrutura de segurança (Controle 00), a fim de institucionalizar a segurança da informação para assegurar a autoridade e recursos necessários, e em mapear os ativos e dados da organização (Controles 01, 02 e 03), com objetivo de aumentar o grau de aderência desses controles que são pré-requisitos obrigatórios para a eficácia de quaisquer outros controles de proteção ou recuperação.

Diante disso, será sugerida proposta de **RECOMENDAÇÃO** às organizações para que, no âmbito da fase 1 da fiscalização (qual seja Processo TCE-RJ nº 105.895-5/2024), priorizem a consolidação dos controles fundamentais para mitigação dos riscos cibernéticos: o Controle 0 de Estrutura de Segurança e os Controles 1 e 2 de Inventário de Ativos e *Softwares*, uma vez que estes constituem pré-requisitos estruturais para a eficácia e efetividade dos demais controles de proteção.

4.2.4 Desafios e Deficiências em Segurança da Informação

Com base nas declarações prestadas pelos gestores na seção de encerramento do questionário eletrônico enviado mediante TSID2, coletou-se subsídios fundamentais para a compreensão das possíveis causas raízes das lacunas de conformidade identificadas.

Predomina nas respostas a escassez crítica de recursos financeiros e humanos, resultando em obsolescência tecnológica, ausência de ferramentas de segurança corporativas e dificuldade na retenção de talentos técnicos. Esse cenário impõe às equipes de TI um modelo operacional eminentemente reativo, focado na continuidade do serviço em detrimento da formalização de processos e da gestão proativa de riscos.

Adicionalmente, barreiras culturais, como a baixa conscientização dos usuários, e a complexidade operacional em ambientes com grande dispersão geográfica e volume massivo de usuários dificultam a padronização dos controles e o alinhamento com normativos estaduais. Depreende-se que as deficiências de conformidade não provêm apenas de falhas gerenciais, mas de um déficit estrutural de capacidade de execução.

A superação dessas vulnerabilidades exige que a segurança da informação transcenda a esfera técnica, consolidando-se como pilar de governança corporativa com garantia de recursos e patrocínio efetivo da Alta Administração para a transição de uma postura reativa para um modelo de gestão de riscos formalizado e auditável.

4.3. Achados de Auditoria

O *Center for Internet Security* (CIS) define as medidas de segurança do Grupo de Implementação 1 (IG1) como a “Higiene Cibernética Essencial”. Este referencial constitui o padrão técnico mínimo de segurança que deve ser adotado por qualquer organização para garantir a confidencialidade, integridade e disponibilidade das informações.

Sob esse prisma, a Equipe de Auditoria considera que a adoção dessas salvaguardas básicas é condição indispensável para o atendimento aos deveres legais de segurança impostos à Administração Pública.

A falha em implementar esse nível mínimo de proteção configura, por consequência, inobservância aos requisitos estabelecidos nos incisos II e III do art. 6º da Lei de Acesso à Informação (Lei nº 12.527/2011) e nos deveres de segurança e prevenção previstos no inciso VII do art. 6º e nos arts. 46 e 47 da Lei Geral de Proteção de Dados Pessoais (Lei nº 13.709/2018).

Nesse contexto, os exames e procedimentos aplicados revelaram fragilidades nos controles das organizações auditadas. As situações encontradas, detalhadas nos achados a seguir, evidenciam lacunas na aplicação dessas medidas essenciais, expondo as informações custodiadas a riscos operacionais e legais.

4.3.1 Achado 1 – Medidas básicas de segurança cibernética insuficientes na gestão de vulnerabilidades

4.3.1.1. Critérios

- Lei Federal nº 12.527/2011 (LAI), art. 6º, incisos II e III (Dever da Administração de proteger a confidencialidade, integridade e disponibilidade das informações sob sua custódia);
- Lei Federal nº 13.709/2018 (LGPD), art. 6º, inciso VII, art. 46 e art. 47 (Dever da Administração de atender ao princípio da segurança nas atividades de tratamento de dados pessoais, por meio da utilização de medidas técnicas e administrativas na proteção dos dados);
- Controles CIS versão 8.1, medidas de segurança 7.1 (Estabelecer e manter um processo de gestão de vulnerabilidade), 7.2 (Estabelecer e manter um processo de remediação), 7.3 (Executar a gestão automatizada de *patches* do sistema operacional) e 7.4 (Executar a gestão automatizada de *patches* de aplicações);
- Norma Técnica ABNT NBR ISO/IEC 27002:2022, item 8.8 (Gestão de vulnerabilidades).

4.3.1.2. Evidências

As evidências que embasam este achado estão consolidadas no Anexo AN04 e encontram-se individualizadas em cada um dos relatórios individuais (AN08 a AN43) das organizações auditadas.

4.3.1.3. Situação encontrada

A gestão contínua de vulnerabilidades é um processo essencial para a segurança da informação, permitindo que a organização identifique, priorize e corrija falhas de segurança em seus ativos antes que elas sejam exploradas por agentes maliciosos. A ausência ou a ineficiência desse processo amplia significativamente a superfície de ataque e o risco de comprometimento da confidencialidade, integridade e disponibilidade dos dados e serviços.

O ciclo de vida da gestão de vulnerabilidades compreende, fundamentalmente, as etapas de avaliação (*assess*), priorização (*prioritize*), remediação (*remediate*) e monitoramento (*monitor*). Para operacionalizar esse ciclo, é imprescindível que a organização utilize fontes fidedignas de inteligência de ameaças e mantenha processos formalizados e ferramentas adequadas para varredura e correção.

A legislação vigente, notadamente o art. 6º, incisos II e III, da Lei de Acesso à Informação (LAI) e os artigos 46 e 47 da Lei Geral de Proteção de Dados (LGPD), impõem à Administração o dever de implementar medidas técnicas de segurança aptas a proteger as informações sob sua custódia.

No contexto da gestão de vulnerabilidades, o cumprimento desses requisitos legais materializa-se na adoção de práticas consagradas, como o item 8.8 da ABNT NBR ISO/IEC 27002:2022¹² e as medidas de higiene cibernética do Controle 07 dos Controles CIS v8.1¹³.

O tema já foi incorporado, sob diferentes aspectos, a normativos e diretrizes governamentais específicos. O Programa de Privacidade e Segurança da Informação (PPSI) do Governo Federal, por exemplo, disponibiliza o Guia de Gerenciamento de Vulnerabilidades¹⁴, que orienta a adoção dessas medidas no âmbito do Poder Executivo Federal.

Para assegurar uma gestão eficaz e conforme, a organização deve adotar, minimamente, as medidas básicas (de higiene cibernética) do Controle 07 dos Controles CIS versão 8.1: (1) o estabelecimento de um processo formal de gestão de vulnerabilidades, (2) a definição de um

¹² O item 8.8 da ISO/IEC 27002:2022 (Gestão de vulnerabilidades) estabelece que as informações sobre vulnerabilidades técnicas dos sistemas em uso devem ser obtidas, a exposição da organização avaliada e as medidas apropriadas tomadas.

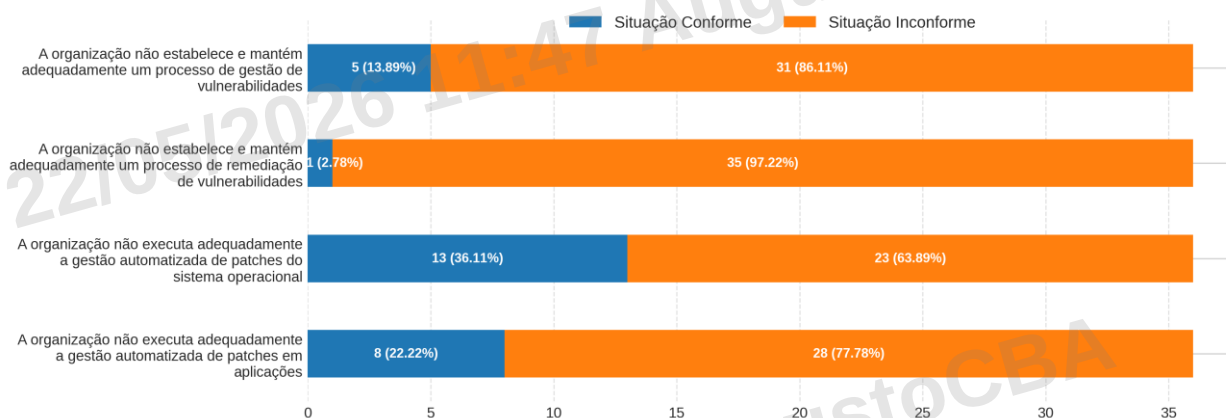
¹³ As medidas básicas do Controle 07 (Gestão contínua de vulnerabilidades) dos Controles CIS versão 8.1 representam o conjunto mínimo de medidas para estabelecer e manter o processo de gerenciamento de vulnerabilidades da organização.

¹⁴ BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Secretaria de Governo Digital. Programa de Privacidade e Segurança da Informação (PPSI): Guia de Gerenciamento de Vulnerabilidades. 2023. Disponível em: https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/ppsi/guia_gerenciamento_vulnerabilidades.pdf. Acesso em: 1 dez. 2025.

processo de remediação baseado em riscos, (3) a execução automatizada de atualizações (patches) em sistemas operacionais e (4) a execução automatizada de atualizações em aplicações.

Com base na análise dos itens 0701, 0702, 0703 e 0704 do questionário aplicado, da avaliação dos documentos encaminhados e dos comentários do gestor, a Equipe de Auditoria constatou as seguintes deficiências nas organizações auditadas:

Figura 12 – Distribuição das situações da gestão de vulnerabilidades



(Fonte: elaboração própria)

Essas situações ensejaram o presente achado e serão detalhadas nas seções subsequentes.

Processo de gestão de vulnerabilidade

A governança eficaz exige que a organização possua um processo formal, documentado e padronizado para gerir o ciclo de vida das vulnerabilidades.

A Medida 7.1 dos Controles CIS v8.1 requer a documentação desse processo, incluindo revisões anuais ou, quando houver, mudanças significativas no ambiente.

Em complemento, o item 8.8 da ABNT NBR ISO/IEC 27002:2022 dispõe que a organização deve definir e estabelecer responsabilidades claras para a gestão de vulnerabilidades técnicas, abrangendo desde o monitoramento e a avaliação de riscos até a correção e o rastreamento dos ativos.

Para garantir a efetividade do controle, e em consonância com o *Vulnerability Management Policy Template*¹⁵ do CIS, o processo deve definir claramente o escopo (quais ativos corporativos são aplicáveis), estabelecer os papéis envolvidos e detalhar as etapas de identificação, priorização, remediação e monitoramento. É imprescindível, ainda, que o processo

¹⁵ CENTER FOR INTERNET SECURITY (CIS). CIS Controls v8.1 Vulnerability Management Policy Template. CIS, 2025. Disponível em: <https://www.cisecurity.org/insights/white-papers/controls-v8-1-vulnerability-management-policy-template>. Acesso em: 1 dez. 2025.

formalize a monitoria constante de fontes de informação sobre novas ameaças e anúncios de vulnerabilidades aplicáveis ao inventário da organização.

Da análise das respostas ao item 0701 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 12, verificou-se que 31 (86,1%) das 36 organizações auditadas não estabelecem e mantêm adequadamente um processo de gestão de vulnerabilidades.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que estabeleçam, mantenham e revisem periodicamente seu processo de gestão de vulnerabilidades.

Processo de remediação de vulnerabilidade

Identificar vulnerabilidades é apenas a primeira etapa do processo. Uma vez identificadas é crucial remediá-las de forma tempestiva e priorizada.

A Medida 7.2 dos Controles CIS v8.1 exige o estabelecimento de uma estratégia de remediação baseada em riscos, com revisões mensais ou mais frequentes.

O processo deve incluir critérios claros para priorização (como a criticidade do ativo e a severidade da falha), procedimentos para tratamento de exceções (quando a correção não é viável) e mecanismos de escalonamento para a alta gestão em caso de não mitigação nos prazos definidos.

Da análise das respostas ao item 0702 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 12, verificou-se que 35 (97,2%) das 36 organizações auditadas não estabelecem e mantêm um processo adequado de remediação de vulnerabilidades.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que estabeleçam, mantenham e revisem periodicamente um processo de remediação de vulnerabilidades baseado em riscos.

Gestão automatizada de patches do sistema operacional e de aplicações

A aplicação de correções de segurança (*patches*) é a medida técnica mais direta para mitigar vulnerabilidades conhecidas. Dada a complexidade e a volumetria dos ambientes modernos, a automação é indispensável para garantir a consistência e a celeridade necessárias.

As Medidas 7.3 e 7.4 dos Controles CIS v8.1 determinam a execução automatizada de atualizações em sistemas operacionais e aplicações, respectivamente, com periodicidade mínima mensal. Em consonância com o *Vulnerability Management Policy Template* do CIS, o processo deve contemplar a verificação de sucesso da instalação para garantir a efetividade da correção. Adicionalmente, para assegurar a continuidade operacional, recomenda-se a realização de testes prévios em ambientes de homologação antes da distribuição em larga escala, visando mitigar riscos de instabilidade no ambiente de produção.

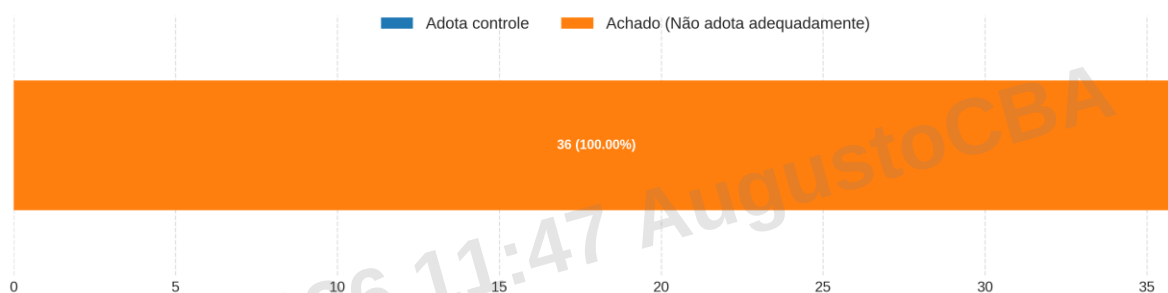
Da análise das respostas aos itens 0703 e 0704 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 12, verificou-se que 23 (63,9%) das 36 organizações auditadas não executam uma gestão automatizada de *patches* em sistemas operacionais e 28 (77,8%) delas não fazem em aplicações.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que implementem a gestão automatizada de *patches* para sistemas operacionais e aplicações, assegurando periodicidade adequada e validação das correções.

Conclusão

Com base nas situações avaliadas, verificou-se que nenhuma das organizações auditadas possuem medidas suficientes para realizar uma gestão contínua de vulnerabilidades.

Figura 13 – Quantitativo de organizações contidas no achado 1



(Fonte: elaboração própria)

As fragilidades identificadas nesse achado comprometem a postura de segurança da organização, facilitando a exploração de falhas conhecidas por atacantes.

Diante das situações apresentadas, serão sugeridas propostas de encaminhamento às organizações para que promovam a adequação de seus controles, alinhando-se às práticas da ABNT NBR ISO/IEC 27002:2022 e do CIS Controls v8.1.

4.3.1.4. Causas

- Não investigadas.

4.3.1.5. Efeitos

- Maior exposição ao risco nos ativos: Aumento significativo da probabilidade de ativos corporativos serem comprometidos, pois atacantes exploram ativamente as vulnerabilidades conhecidas para obter acesso;
- Possível perda ou exposição de dados: Risco de infecção por *malware* ou acesso não autorizado que pode resultar na leitura, modificação ou destruição de dados sensíveis da organização;

- Potencial interrupção de serviços: Paralisação de operações e serviços essenciais devido a ataques bem-sucedidos (como *ransomware*) que exploram falhas de segurança não corrigidas, resultando em perdas financeiras e de reputação.

4.3.1.6. Propostas de Encaminhamento

Ressalta-se que as propostas de encaminhamento individualizadas para cada organização auditada constam no bojo dos relatórios individuais presentes nos conjuntos de anexos AN08 a AN43. Dessa forma, seguem as sugestões gerais propostas pela Equipe de Auditoria:

- **Comunicação com Recomendação** às organizações que não possuem um processo estabelecido de gestão de vulnerabilidades para que adotem integralmente a medida de segurança 7.1 (Estabelecer e manter um processo de gestão de vulnerabilidade) prevista nos Controles CIS v8.1, atentando-se, minimamente, em estabelecer, manter e revisar, com frequência mínima anual, um processo de gestão de vulnerabilidades que seja documentado, aprovado, definindo o escopo, as etapas, as responsabilidades e os papéis;
- **Comunicação com Recomendação** às organizações que não possuem um processo estabelecido de remediação de vulnerabilidades para que adote integralmente a medida de segurança 7.2 (Estabelecer e manter um processo de remediação) prevista nos Controles CIS v8.1, atentando-se, minimamente, em estabelecer e manter um processo documentado de remediação de vulnerabilidades, alinhado ou parte do processo de gestão de vulnerabilidades e que defina uma estratégia de remediação baseada em risco, a qual deve ser revisada com frequência mínima mensal;
- **Comunicação com Recomendação** às organizações que não executam gestão automatizada de gestão de patches em sistemas operacionais para que adotem integralmente a medida de segurança 7.3 (Executar a gestão automatizada de patches do sistema operacional) prevista nos Controles CIS v8.1, atentando-se, minimamente, em assegurar a aplicação automatizada de atualizações nos sistemas operacionais dos ativos corporativos, com frequência mínima mensal;
- **Comunicação com Recomendação** às organizações que não executam gestão automatizada de gestão de patches em aplicações para que adotem integralmente a medida de segurança 7.4 (Executar a gestão automatizada de patches de aplicações) prevista nos Controles CIS v8.1, atentando-se, minimamente, em assegurar a aplicação automatizada de atualizações nas aplicações dos ativos corporativos, com frequência mínima mensal;

4.3.2. Achado 2 – Medidas básicas de segurança cibernética insuficientes na gestão de registros de auditoria (logs)

4.3.2.1. Critérios

- Lei Federal nº 12.527/2011 (LAI), art. 6º, incisos II e III (Dever da Administração de proteger a confidencialidade, integridade e disponibilidade das informações sob sua custódia);
- Lei Federal nº 13.709/2018 (LGPD), art. 6º, inciso VII, art. 46 e art. 47 (Dever da Administração de atender ao princípio da segurança nas atividades de tratamento de dados pessoais, por meio da utilização de medidas técnicas e administrativas na proteção dos dados);
- Norma Técnica ABNT NBR ISO/IEC 27002:2022, item 8.15 (*Logs*);
- Controles CIS versão 8.1, medidas de segurança 8.1 (Estabelecer e manter um processo de gestão de *log* de auditoria), 8.2 (Coletar *logs* de auditoria), 8.3 (Garantir o armazenamento adequado do registro de auditoria);
- Instrução Normativa PRODERJ/PRE nº 07/2025, Anexo Único, Item 8.3.7. (Procedimentos de *logging*);
- Resolução TJ/OE nº 28/2022, art. 22, inciso IV (Gestão de riscos de segurança da informação);
- Resolução CNMP nº 294/2024, art. 23, §3º, incisos II, III e IV (Planejamento, gestão e execução das ações em cibersegurança).

4.3.2.2. Evidências

As evidências que embasam este achado estão consolidadas no Anexo AN04 e encontram-se individualizadas em cada um dos relatórios individuais (AN08 a AN43) das organizações auditadas.

4.3.2.3. Situação encontrada

A gestão de registros de auditoria (*logs*) é um componente vital da defesa cibernética, permitindo à organização detectar, investigar e responder a incidentes de segurança. Os *logs* fornecem a trilha digital necessária para compreender a natureza de um ataque, identificar a extensão do comprometimento e recuperar os ativos afetados. A ausência de uma gestão ativa desses registros cria uma “cegueira operacional”, permitindo que invasores atuem na infraestrutura por longos períodos sem serem detectados.

A legislação vigente, notadamente o art. 6º, incisos II e III, da Lei de Acesso à Informação (LAI) e os artigos 46 e 47 da Lei Geral de Proteção de Dados (LGPD), impõem à Administração

o dever de implementar medidas técnicas de segurança aptas a proteger as informações sob sua custódia.

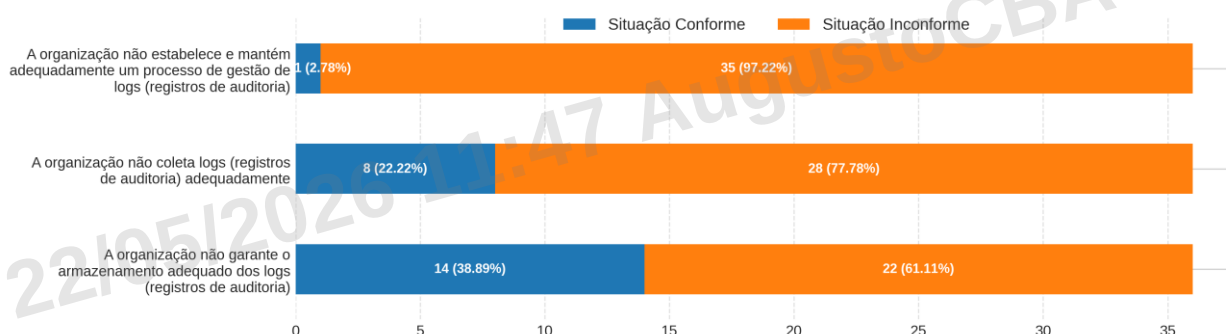
No contexto da gestão de *logs*, o cumprimento desses requisitos legais materializa-se na adoção de boas práticas, como o item 8.15 da ABNT NBR ISO/IEC 27002:2022¹⁶ e as medidas de higiene cibernética do Controle 08 dos Controles CIS v8.1¹⁷.

Importante destacar que a gestão de *logs* não é apenas uma recomendação de boas práticas, mas uma exigência presente em normativos estaduais e setoriais. No Poder Executivo estadual, a Instrução Normativa PRODERJ/PRE nº 07/2025 (Anexo Único, Item 8.3.7) estabelece explicitamente os procedimentos de *logging*, exigindo que *softwares* de segurança mantenham registros de acesso e que sistemas críticos enviem seus *logs* para servidores de armazenamento centralizados. Similarmente, o Poder Judiciário (Resolução TJ/OE nº 28/2022) e o Ministério Público (Resolução CNMP nº 294/2024) possuem diretrizes que reforçam a gestão de riscos e a execução de ações de cibersegurança, nas quais a auditoria de eventos é intrínseca. Em âmbito federal, o tema é abordado pelo Programa de Privacidade e Segurança da Informação (PPSI)¹⁸.

Para assegurar uma gestão eficaz e conforme, a organização deve adotar, minimamente, as medidas básicas (de higiene cibernética) do Controle 08 dos Controles CIS versão 8.1: (1) o estabelecimento de um processo formal de gestão de *logs*, (2) a efetiva coleta desses registros e (3) a garantia de seu armazenamento seguro e adequado.

Com base na análise das respostas aos itens 0801, 0802 e 0803 do questionário aplicado, da avaliação dos documentos encaminhados e dos comentários do gestor, a Equipe de Auditoria constatou as seguintes deficiências nas organizações auditadas:

Figura 14 – Distribuição das situações da gestão de *logs*



¹⁶ O item 8.15 da ISO/IEC 27002:2022 (*Log*) detalha os controles para geração, proteção e análise de registros, visando a obtenção de evidências de eventos de segurança.

¹⁷ As medidas básicas do Controle 08 (Gestão de registros de auditoria) dos Controles CIS versão 8.1 representam o conjunto mínimo de medidas para estabelecer e manter o processo de gerenciamento de *logs* da organização.

¹⁸ BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Secretaria de Governo Digital. Programa de Privacidade e Segurança da Informação (PPSI): Modelo de Política de Gestão de Registros (*Logs*) de Auditoria. 2023. Disponível em: https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/ppsi/modelo_politica_logs_auditoria.pdf. Acesso em: 1 dez. 2025.

(Fonte: elaboração própria)

Essas situações ensejaram o presente achado e serão detalhadas nas seções subsequentes.

Processo de gestão de *log* de auditoria

A governança sobre os registros de auditoria exige que a organização possua um processo formal, documentado e padronizado. A inexistência desse instrumento normativo impede que a organização defina uniformemente quais eventos devem ser registrados, por quanto tempo devem ser retidos e quem é responsável por sua análise.

A Medida 8.1 dos Controles CIS v8.1 estabelece a necessidade de manter este processo documentado e revisado anualmente. Em complemento, o item 8.15 da ISO/IEC 27002:2022 orienta que a política de *logs* deve determinar a finalidade da coleta e os requisitos de proteção.

Para ser efetivo, o processo deve definir claramente o escopo (quais ativos são monitorados), as responsabilidades da equipe e as diretrizes para coleta, revisão e retenção. A falta dessa definição expõe a organização ao risco de possuir *logs* irrelevantes ou insuficientes para responder a um incidente de segurança.

Da análise das respostas ao item 0801 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 14, verificou-se que 35 (97,2%) das 36 organizações auditadas não estabelecem e mantêm adequadamente um processo de gestão de *logs* (registros de auditoria).

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que estabeleçam, mantenham e revisem periodicamente seu processo de gestão de registros (*logs*) de auditoria.

Coleta de registros (*logs*) de auditoria

Estabelecido o processo de gestão, é mandatório que a organização execute tecnicamente a coleta dos registros.

A Medida 8.2 dos Controles CIS v8.1 preconiza, fundamentalmente, que a geração de *logs* esteja habilitada em todos os ativos corporativos do escopo e que existam garantias técnicas ou administrativas de que essa funcionalidade não seja desabilitada indevidamente.

Complementarmente, a conformidade com esta medida exige o estabelecimento de procedimentos claros para efetivamente coletar esses registros dos ativos de origem, transferindo-os para locais de armazenamento seguro. Para garantir a consistência temporal e a validade probatória desses registros em uma eventual análise forense, é altamente recomendável que também se adote a Medida 8.4 do IG2 dos Controles CIS, portanto, que os ativos estejam com data e hora sincronizadas via NTP (*Network Time Protocol*).

Da análise das respostas ao item 0802 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado

na Figura 14, verificaram-se deficiências em 28 (77,8%) das 36 organizações auditadas, seja pela ausência de habilitação de *logs* em ativos críticos, pela falta de proteções contra a desativação do recurso ou pela inexistência de rotinas eficazes de coleta e sincronização de tempo.

Diante do exposto, será sugerida proposta de recomendação às organizações nessa situação para que assegurem a habilitação, a proteção contra desativação e a coleta sincronizada de registros de auditoria em todos os ativos corporativos.

Armazenamento adequado dos registros (*logs*) de auditoria

A integridade e a disponibilidade dos *logs* são requisitos básicos para sua validade como evidência.

A Medida 8.3 dos Controles CIS v8.1 determina que a organização deve garantir armazenamento suficiente para reter os registros pelo tempo definido na política, além de protegê-los contra acesso ou modificação não autorizada.

O armazenamento adequado envolve não apenas capacidade de disco, mas a aplicação de controles de acesso rigorosos e, quando necessário, criptografia ou mecanismos de imutabilidade. Se os *logs* puderem ser alterados ou excluídos por usuários não autorizados (ou mesmo administradores mal-intencionados), a capacidade da organização de provar a ocorrência de um evento fica comprometida.

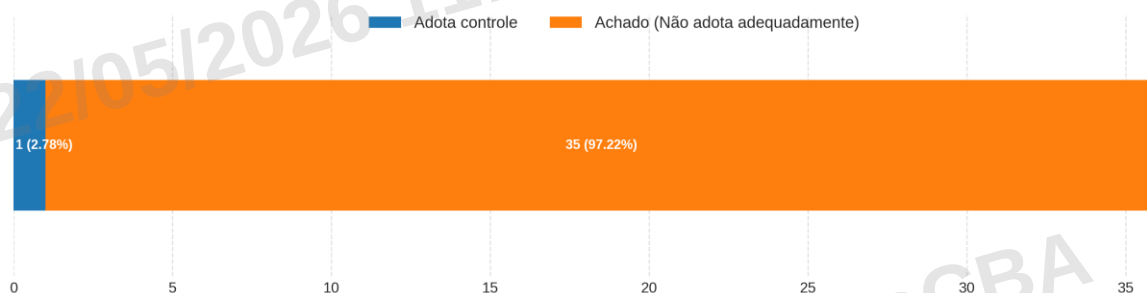
Da análise das respostas ao item 0803 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 14, constatou-se que 22 (61,1%) das 36 organizações auditadas não aplicam controles suficientes para garantir a retenção segura e a integridade dos registros de auditoria armazenados.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que assegurem a capacidade de armazenamento adequada e implementem controles de proteção para os registros de auditoria.

Conclusão

Com base nas situações avaliadas, verificou-se que 35 (97,2%) das organizações auditadas não possuem medidas suficientes para realizar a gestão de registros de auditoria (*logs*).

Figura 15 – Quantitativo de organizações contidas no achado 2



(Fonte: elaboração própria)

As fragilidades identificadas nesse achado comprometem a capacidade de monitoramento e resposta a incidentes da organização.

Dessa forma, será sugerida proposta de encaminhamento às organizações para que promovam a adequação de seus controles, alinhando-se às práticas da ABNT NBR ISO/IEC 27002:2022 e do CIS Controls v8.1.

4.3.2.4. Causas

- Não investigadas.

4.3.2.5 Efeitos

- Falha no registro de eventos de segurança da informação;
- Falha identificação de eventos de segurança da informação que possam levar a um incidente de segurança da informação;
- Falha na integridade das informações de registro de auditoria;
- Falha na disponibilidade das informações de registro de auditoria;
- Falha na confidencialidade das informações de registro de auditoria.

4.3.2.6. Propostas de Encaminhamento

Ressalta-se que as propostas de encaminhamento individualizadas para cada organização auditada constam no bojo dos relatórios individuais presentes nos conjuntos de anexos AN08 a AN43. Dessa forma, seguem as sugestões gerais propostas pela Equipe de Auditoria:

- **Comunicação com Recomendação** às organizações que não possuem um processo estabelecido de gestão de *logs* para que adotem integralmente a medida de segurança 8.1 (Estabelecer e manter um processo de gestão de registros (*logs*) de auditoria) prevista nos Controles CIS v8.1, atentando-se, minimamente, em formalizar, aprovar e revisar anualmente um processo documentado que defina claramente o escopo, as responsabilidades e as diretrizes para a coleta, análise e retenção de logs dos ativos corporativos;

- **Comunicação com Recomendação** às organizações que não coletam *logs* para que adotem integralmente a medida de segurança 8.2 (Coletar registros (*logs*) de auditoria) prevista nos Controles CIS v8.1, atentando-se, minimamente, em habilitar e coletar logs dos ativos do escopo do processo de gestão de registros, assegurando a sincronização de tempo (horário) via NTP e impedindo a desabilitação não autorizada da geração desses logs;
- **Comunicação com Recomendação** às organizações que não armazenam adequadamente os *logs* para que adotem integralmente a medida de segurança 8.3 (Garantir o armazenamento adequado dos registros (*logs*) de auditoria) prevista nos Controles CIS v8.1, atentando-se, minimamente, em assegurar capacidade de armazenamento suficiente para cumprir os períodos de retenção alinhados à gestão de dados e aplicar controles de acesso para impedir a modificação não autorizada dos registros.

4.3.3. Achado 3 – Medidas básicas de segurança cibernética insuficientes nas proteções de *e-mail* e navegador *web*

4.3.3.1. Critérios

- Lei Federal nº 12.527/2011 (LAI), art. 6º, incisos II e III (Dever da Administração de proteger a confidencialidade, integridade e disponibilidade das informações sob sua custódia);
- Lei Federal nº 13.709/2018 (LGPD), art. 6º, inciso VII, art. 46 e art. 47 (Dever da Administração de atender ao princípio da segurança nas atividades de tratamento de dados pessoais, por meio da utilização de medidas técnicas e administrativas na proteção dos dados);
- Norma Técnica ABNT NBR ISO/IEC 27002:2022, itens 8.1 (Dispositivos *endpoint* do usuário) e 8.23 (Filtragem da *web*);
- Controles CIS versão 8.1, medidas de segurança 9.1 (Garantir o uso apenas de navegadores e clientes de *e-mail* plenamente suportados) e 9.2 (Utilizar serviços de filtragem de DNS);
- Instrução Normativa PRODERJ/PRE nº 07/2025, Anexo Único, Item 8.13.1.1 (Proíbe o uso de *software* não homologado) e 8.13.4 (Acesso à Internet, redes sociais e comunicadores instantâneos);
- Resolução TJ/OE nº 28/2022, art. 22, inciso IV (Gestão de riscos de segurança da informação);
- Resolução CNMP nº 294/2024, art. 23, §3º, incisos II, III e IV (Planejamento, gestão e execução das ações em cibersegurança).

4.3.3.2. Evidências

As evidências que embasam este achado estão consolidadas no Anexo AN04 e encontram-se individualizadas em cada um dos relatórios individuais (AN08 a AN43) das organizações auditadas.

4.3.3.3. Situação encontrada

Navegadores *web* e clientes de *e-mail* constituem os principais vetores de interação dos usuários com ambientes externos e não confiáveis, tornando-se pontos de entrada frequentes para ataques cibernéticos. A ausência de controles robustos nessas ferramentas amplia a superfície de ataque, permitindo a exploração de códigos maliciosos e táticas de engenharia social que comprometem a confidencialidade, integridade e disponibilidade das informações corporativas.

A legislação vigente, notadamente a Lei de Acesso à Informação (LAI) e a Lei Geral de Proteção de Dados (LGPD), impõe à Administração o dever de implementar medidas técnicas de segurança.

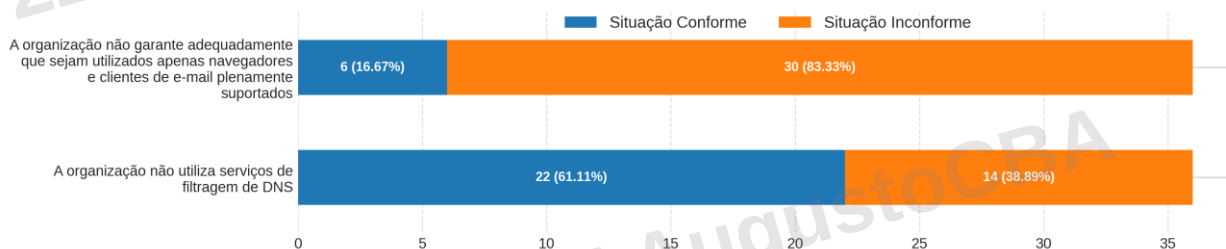
No contexto operacional do usuário, a conformidade com tais requisitos legais materializa-se através da adoção de práticas consagradas, como os controles 8.1¹⁹ e 8.23²⁰ da ABNT NBR ISO/IEC 27002:2022 e as medidas de higiene cibernética do Controle 09 dos Controles CIS v8.1²¹.

Esse controle já foi incorporado, sob diferentes aspectos, a normativos e diretrizes de diversos poderes e esferas da Administração Pública. Exemplos²² incluem o tratamento disposto nos itens 8.13.1.1 e 8.13.4 do Anexo Único da Instrução Normativa PRODERJ/PRE nº 07/2025, aplicável ao Poder Executivo do Estado do Rio de Janeiro.

Para assegurar uma proteção adequada e eficaz, é imperativo que a organização adote, minimamente, as medidas básicas (de higiene cibernética) do Controle 09 dos Controles CIS versão 8.1: (1) a garantia de uso exclusivo de navegadores e clientes de *e-mail* plenamente suportados pelos fabricantes e (2) a utilização de serviços de filtragem de DNS para bloqueio de domínios maliciosos.

Com base na análise das respostas aos itens 0901 e 0902 do questionário aplicado, da avaliação dos documentos encaminhados e dos comentários do gestor, a Equipe de Auditoria constatou as seguintes deficiências nas organizações auditadas:

Figura 16 – Distribuição das situações de proteção de *e-mail* e navegadores web



(Fonte: elaboração própria)

Essas situações ensejaram o presente achado e serão detalhadas nas seções subsequentes.

¹⁹ O item 8.1 da ISO/IEC 27002:2022, intitulado Dispositivos *Endpoint* do Usuário, trata da configuração segura e do gerenciamento de *softwares* nos dispositivos finais para impedir a instalação de aplicações não autorizadas ou vulneráveis.

²⁰ O item 8.23 da ISO/IEC 27002:2022, intitulado Filtragem da *web*, estabelece que o acesso a *sites* externos deve ser gerenciado para reduzir a exposição a conteúdo malicioso e impedir o acesso a endereços não confiáveis.

²¹ As medidas básicas do Controle 09 (Proteções de *e-mail* e navegador *Web*) dos Controles CIS versão 8.1 representam o conjunto mínimo de salvaguardas para mitigar riscos associados ao comportamento humano e à interação direta com a internet.

²² Tais práticas também encontram respaldo em normativos específicos, como o art. 22, inciso IV, da Resolução TJ/OE nº 28/2022, e os princípios dispostos nos incisos II, III e IV, do §3º, do art. 23, da Resolução CNMP nº 294/2024.

Uso apenas de navegadores e clientes de *e-mail* plenamente suportados

A utilização de *softwares* que não recebem mais suporte ou atualizações de segurança é um fator crítico de risco, pois expõe a infraestrutura a vulnerabilidades conhecidas para as quais não existem correções (*patches*).

A Medida 9.1 dos Controles CIS v8.1 exige que a organização assegure o uso exclusivo de navegadores e clientes de *e-mail* plenamente suportados. Essa prática requer a definição de uma política de *softwares* homologados, a manutenção de um inventário atualizado e a gestão centralizada para garantir que apenas as versões mais recentes e estáveis estejam em execução.

Em alinhamento, o item 8.1 da ISO/IEC 27002:2022 orienta o estabelecimento de configurações seguras que restrinjam a instalação de *softwares* não autorizados e forcem a aplicação de atualizações. A ausência dessas restrições permite que versões obsoletas ou inseguras permaneçam ativas no ambiente, servindo como porta de entrada para atacantes.

Essas práticas visam melhorar a proteção a vetores de ameaça, mitigando os riscos de utilização de aplicações obsoletas, vulneráveis e permissivas.

Da análise das respostas ao item 0901 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 16, verificou-se que 30 (83,3%) das 36 organizações auditadas não possuem controles adequados para impedir o uso de navegadores e clientes de *e-mail* não suportados ou para garantir a atualização tempestiva dessas ferramentas.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que implementem mecanismos de controle que assegurem o uso exclusivo de navegadores e clientes de *e-mail* homologados e plenamente suportados.

Serviços de filtragem de DNS

A filtragem de DNS atua como uma camada de defesa essencial, impedindo que os ativos corporativos se comuniquem com domínios maliciosos, mesmo quando um usuário clica inadvertidamente em um *link* nocivo.

A Medida 9.2 dos Controles CIS v8.1 recomenda a utilização de serviços de filtragem de DNS para bloquear o acesso a domínios conhecidos por distribuir *malware*, hospedar páginas de *phishing* ou atuar como servidores de Comando e Controle (C2). Sem essa proteção, a organização perde a capacidade de interromper a “cadeia de ataque” no momento da resolução de nomes, permitindo que a conexão maliciosa seja estabelecida.

Da análise das respostas ao item 0902 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 16, verificou-se que 14 (38,9%) das 36 organizações auditadas não utilizam serviços de filtragem de DNS em seus ativos corporativos, deixando a rede exposta a ameaças que

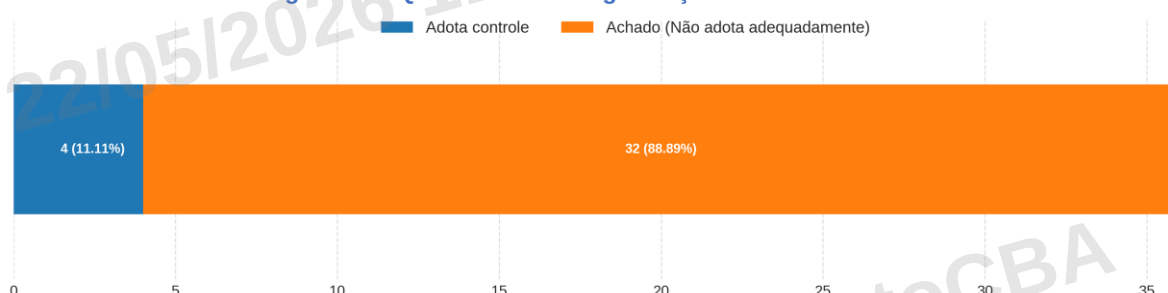
poderiam ser bloqueadas proativamente antes que o conteúdo malicioso atingisse o dispositivo do usuário.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que implementem serviços de filtragem de DNS em todos os ativos corporativos.

Conclusão

Com base nas situações avaliadas, verificou-se que 32 (88,9%) das 36 organizações auditadas não possuem medidas suficientes para proteger os clientes de e-mail e navegadores web dos ativos corporativos.

Figura 17 – Quantitativo de organizações contidas no achado 3



(Fonte: elaboração própria)

As deficiências identificadas nesse achado indicam uma fragilidade na defesa contra vetores de ataque comuns.

Dessa forma, será sugerida proposta de encaminhamento às organizações para que promovam a adequação de seus controles, alinhando-se às práticas da ABNT NBR ISO/IEC 27002:2022 e do CIS Controls v8.1.

4.3.3.4. Causas

- Não investigadas.

4.3.3.5. Efeitos

- Exposição a vulnerabilidades de fator humano;
- Uso de navegadores com vulnerabilidades conhecidas e exploradas;
- Uso de cliente de e-mail com configurações inseguras;
- Acesso a endereços web maliciosos.

4.3.3.6. Propostas de Encaminhamento

Ressalta-se que as propostas de encaminhamento individualizadas para cada organização auditada constam no bojo dos relatórios individuais presentes nos conjuntos de anexos AN08 a AN43. Dessa forma, seguem as sugestões gerais propostas pela Equipe de Auditoria:

- **Comunicação com Recomendação** às organizações que não asseguram a utilização adequada de clientes de *e-mail* e navegadores *web* para que adotem integralmente a medida de segurança 9.1 (Garantir o uso apenas de navegadores e clientes de *e-mail* plenamente suportados) prevista nos Controles CIS v8.1, atentando-se, minimamente, em definir os navegadores e clientes de *e-mail* autorizados e assegurar que somente as versões mais recentes e suportadas pelos fabricantes estejam em execução nos ativos corporativos;
- **Comunicação com Recomendação** às organizações que não utilizam serviços de filtragem de DNS para que adotem integralmente a medida de segurança 9.2 (Utilizar serviços de filtragem de DNS) prevista nos Controles CIS v8.1, atentando-se, minimamente, em implementar serviços de filtragem de DNS em todos os ativos corporativos para bloquear o acesso a domínios maliciosos conhecidos;

4.3.4. Achado 4 – Medidas básicas de segurança cibernética insuficientes nas defesas contra malware

4.3.4.1. Critérios

- Lei Federal nº 12.527/2011 (LAI), art. 6º, incisos II e III (Dever da Administração de proteger a confidencialidade, integridade e disponibilidade das informações sob sua custódia);
- Lei Federal nº 13.709/2018 (LGPD), art. 6º, inciso VII, art. 46 e art. 47 (Dever da Administração de atender ao princípio da segurança nas atividades de tratamento de dados pessoais, por meio da utilização de medidas técnicas e administrativas na proteção dos dados);
- Norma Técnica ABNT NBR ISO/IEC 27002:2022, itens 7.10 (Mídia de armazenamento) e 8.7 (Proteção contra *malware*);
- Controles CIS versão 8, medidas de segurança 10.1 (Instalar e manter *software anti-malware* em seus ativos corporativos), 10.2 (Configurar atualizações automáticas de assinatura *anti-malware*), 10.3 (Desabilitar a execução e reprodução automática para mídias removíveis);
- Instrução Normativa PRODERJ/PRE nº 07/2025, Anexo Único, Item 7.2.1.5 (Atualização proativa dos ativos de segurança da informação), 8.3.5 (Uso de dispositivos móveis) 8.13.7 (Proteção contra códigos maliciosos);
- Resolução TJ/OE nº 28/2022, art. 22, incisos II (Gestão de ativos) e IV (Gestão de riscos de segurança da informação);
- Resolução CNMP nº 294/2024, art. 23, §3º, incisos II, III e IV (Planejamento, gestão e execução das ações em cibersegurança).

4.3.4.2. Evidências

As evidências que embasam este achado estão consolidadas no Anexo AN04 e encontram-se individualizadas em cada um dos relatórios individuais (AN08 a AN43) das organizações auditadas.

4.3.4.3. Situação encontrada

A defesa contra códigos maliciosos (*malware*) é um componente crítico da segurança da informação, destinada a impedir a instalação, disseminação e execução de aplicações, códigos ou scripts maliciosos na infraestrutura corporativa. Para ser eficaz, essa proteção deve operar de forma automatizada e integrada em todos os pontos de entrada e ativos da organização, garantindo detecção e resposta rápidas.

A legislação vigente, notadamente a Lei de Acesso à Informação (LAI) e a Lei Geral de Proteção de Dados (LGPD), impõe à Administração o dever de implementar medidas técnicas de segurança aptas a proteger as informações sob sua custódia.

No contexto da defesa contra *malwares*, o cumprimento desses requisitos legais materializa-se na adoção de práticas consagradas, como os itens 7.10²³ e 8.7²⁴ da ABNT NBR ISO/IEC 27002:2022 e as medidas de higiene cibernética do Controle 10 dos Controles CIS v8.1²⁵.

É relevante destacar que a defesa contra *malware* não é apenas uma recomendação técnica, mas uma exigência positivada em normativos estaduais e setoriais. No Poder Executivo estadual, a Instrução Normativa PRODERJ/PRE nº 07/2025 estabelece deveres específicos de atualização proativa de ativos (Item 7.2.1.5) e proteção contra códigos maliciosos (Item 8.13.7). Similarmente, o Poder Judiciário e o Ministério Público possuem resoluções próprias que reforçam a gestão de riscos e ativos de segurança²⁶. O Governo Federal também aborda o tema no âmbito do PPSI²⁷.

Para assegurar uma proteção eficaz e conforme, a organização deve adotar, minimamente, as medidas básicas (de higiene cibernética) do Controle 10 dos Controles CIS versão 8.1: (1) a instalação e manutenção universal de *software anti-malware*, (2) a configuração de atualizações automáticas de assinaturas e (3) a desabilitação da execução automática em mídias removíveis.

Com base na análise das respostas aos itens 1001 e 1002 do questionário aplicado, da avaliação dos documentos encaminhados e dos comentários do gestor, a Equipe de Auditoria constatou as seguintes deficiências nas organizações auditadas:

Figura 18 – Distribuição das situações de defesa contra *malware*

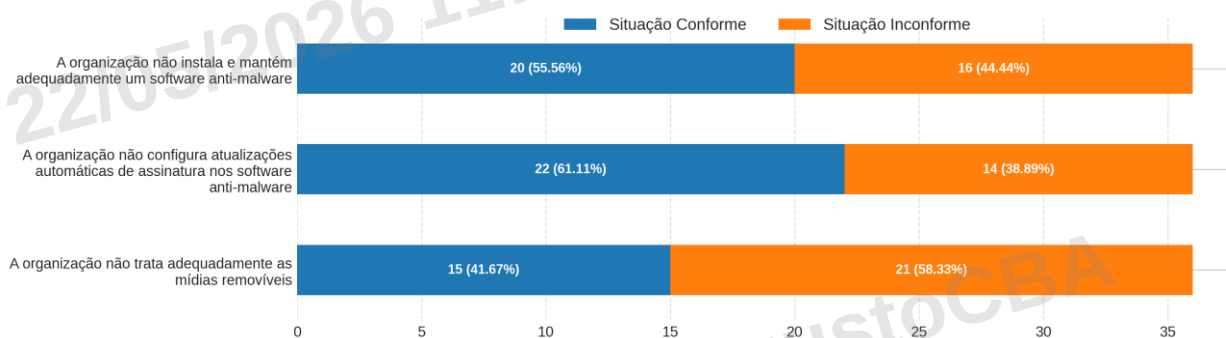
²³ O item 7.10 da ISO/IEC 27002:2022 (Mídia de armazenamento) trata do gerenciamento do ciclo de vida desses dispositivos para garantir a proteção das informações neles contidas.

²⁴ O item 8.7 da ISO/IEC 27002:2022 (Proteção contra *malware*) dispõe que a proteção deve ser implementada para detectar e prevenir a introdução de códigos maliciosos.

²⁵ As medidas básicas do Controle 10 (Defesas contra *malware*) dos Controles CIS v8.1 representam o conjunto mínimo de medidas para impedir ou controlar a instalação, disseminação e execução de aplicações, códigos ou scripts maliciosos em ativos corporativos.

²⁶ Outros dispositivos normativos que abordam o tema são o art. 22, incisos II e IV, da Resolução TJ/OE nº 28/2022, aplicável ao TJRJ, e os princípios dispostos nos incisos II, III e IV, do §3º, do art. 23, da Resolução CNMP nº 294/2024, aplicável aos Ministérios Públicos.

²⁷ BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Secretaria de Governo Digital. Programa de Privacidade e Segurança da Informação (PPSI): Modelo de Política de Defesas contra *Malware*. 2023. Disponível em: https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/ppsi/modelo_politica_defesas_malware.pdf. Acesso em: 1 dez. 2025.



(Fonte: elaboração própria)

Essas situações ensejaram o presente achado e serão detalhadas nas seções subsequentes.

Instalação e manutenção de um *software anti-malware*

A primeira linha de defesa contra códigos maliciosos é a presença de *software* de proteção ativo e atualizado em todos os ativos corporativos.

As Medidas 10.1 e 10.2 dos Controles CIS v8.1 exigem não apenas a instalação universal do agente *anti-malware*, mas também a garantia de que suas assinaturas (definições de vírus) sejam atualizadas automaticamente.

Em alinhamento, o item 8.7 da ISO/IEC 27002:2022 orienta a instalação e atualização regular de *software* de detecção. O *Malware Defense Policy Template* do CIS complementa essa diretriz alertando que a atualização não deve se restringir às assinaturas de vírus, mas deve contemplar também o próprio motor do *software* (*engine*) para corrigir falhas de segurança e incorporar novas funcionalidades de detecção.

O item da ISO 27002 recomenda ainda a realização de varreduras periódicas em computadores e mídias. A falta de automação nesse processo deixa janelas de oportunidade para que novas ameaças infectem a rede antes que as vacinas manuais sejam aplicadas.

É fundamental que o *software* esteja configurado para impedir que usuários comuns desabilitem ou modifiquem suas configurações de segurança, garantindo uma postura de defesa homogênea em todo o parque tecnológico.

Da análise das respostas ao item 1001 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 18, verificou-se que 16 (44,4%) das 36 organizações auditadas não possuem softwares *anti-malware* instalados adequadamente em todos os ativos corporativos e que 14 (38,9%) delas não realizam atualizações automaticamente em seu banco de assinatura de ameaças.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que assegurem a instalação, manutenção e atualização automática de *software* e assinatura *anti-malware* em todos os ativos corporativos.

Reprodução automática de mídias removíveis

Mídias removíveis (como *pen drives* e HDs externos) são vetores comuns para a introdução de *malware* em redes isoladas ou seguras. Uma medida preventiva crucial é impedir que o sistema operacional execute automaticamente programas contidos nessas mídias assim que elas são conectadas.

A Medida 10.3 dos Controles CIS v8.1 determina a desabilitação das funcionalidades de execução (*autorun*) e reprodução automática (*autoplay*) para mídias removíveis em todas as estações de trabalho e servidores. Para assegurar a uniformização da prática, essa configuração deve ser aplicada e reforçada centralmente (ex: via GPO), evitando que a ação dependa da configuração individual de cada usuário.

Além disso, segundo a Medida 10.4, é recomendável que o *software anti-malware* seja configurado para verificar automaticamente qualquer mídia removível no momento de sua conexão, antes que seu conteúdo seja acessado.

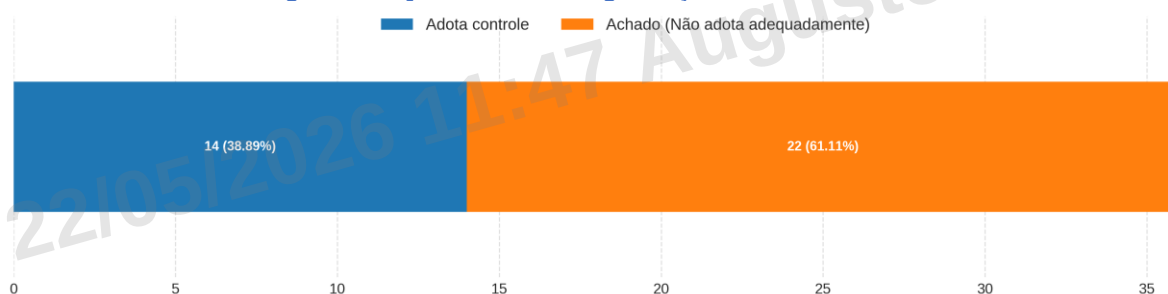
Da análise das respostas ao item 1002 do questionário submetido pelo TSID02, da documentação remetida como anexo à resposta e dos comentários do gestor, conforme ilustrado na Figura 18, verificou-se que 21 (58,3%) das 36 organizações auditadas não aplicam controles adequados para mitigar os riscos associados ao uso de mídias removíveis.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que desabilitem a execução automática de mídias removíveis nos ativos corporativos.

Conclusão

Com base nas situações avaliadas, verificou-se que 22 (61,1%) das 36 organizações auditadas não possuem medidas suficientes para se defenderem adequadamente contra *malwares*.

Figura 19 – Quantitativo de organizações contidas no achado 4



(Fonte: elaboração própria)

As deficiências identificadas nesse achado indicam fragilidades na capacidade da organização de prevenir e detectar ameaças comuns.

Dessa forma, será sugerida proposta de encaminhamento às organizações para que promovam a adequação de seus controles, alinhando-se às práticas da ABNT NBR ISO/IEC 27002:2022 e do CIS Controls v8.1.

4.3.4.4. Causas

- Não investigadas.

4.3.4.5. Efeitos

- Exposição a ataques por *malwares* conhecidos;
- Inabilidade de responder a novos *malwares* identificados pela comunidade;
- Exposição a vulnerabilidades de fator humano.

4.3.4.6. Propostas de Encaminhamento

Ressalta-se que as propostas de encaminhamento individualizadas para cada organização auditada constam no bojo dos relatórios individuais presentes nos conjuntos de anexos AN08 a AN43. Dessa forma, seguem as sugestões gerais propostas pela Equipe de Auditoria:

- **Comunicação com Recomendação** às organizações que não instalam e mantêm software *anti-malware* para que para que adotem integralmente a medida de segurança 10.1 (Implantar e manter software *anti-malware*) prevista nos Controles CIS v8.1, atentando-se, minimamente, em instalar e manter o software em todos os ativos corporativos (servidores, estações e dispositivos móveis), assegurando varreduras periódicas e em tempo real, atualizações automáticas e o bloqueio contra desativação ou modificação por parte dos usuários;
- **Comunicação com Recomendação** às organizações que não instalam e mantêm software *anti-malware* para que adotem integralmente a medida de segurança 10.2 (Configurar atualizações automáticas de assinaturas de *anti-malware*) prevista nos Controles CIS v8.1, atentando-se, minimamente, em habilitar e garantir a atualização automática das assinaturas e definições de vírus em todos os ativos corporativos;
- **Comunicação com Recomendação** às organizações que não desabilitam a execução automática de mídias externas para que adotem integralmente a medida de segurança 10.3 (Desabilitar a execução automática e a reprodução automática para mídias removíveis) prevista nos Controles CIS v8.1, atentando-se, minimamente, em desabilitar as funcionalidades de execução (*autorun*) e reprodução automática (*autoplay*) para mídias removíveis em todas as estações e servidores, aplicando essa configuração preferencialmente por meio de gestão centralizada.

4.3.5. Achado 5 – Medidas básicas de segurança cibernética insuficientes no processo de recuperação de dados

4.3.5.1. Critérios

- Lei Federal nº 12.527/2011 (LAI), art. 6º, incisos II e III (Dever da Administração de proteger a confidencialidade, integridade e disponibilidade das informações sob sua custódia);
- Lei Federal nº 13.709/2018 (LGPD), art. 6º, inciso VII, art. 46 e art. 47 (Dever da Administração de atender ao princípio da segurança nas atividades de tratamento de dados pessoais, por meio da utilização de medidas técnicas e administrativas na proteção dos dados);
- Norma Técnica ABNT NBR ISO/IEC 27002:2022, item 8.13 (*Backup das informações*);
- Controles CIS versão 8.1, medidas de segurança: 11.1 (Estabelecer e manter um processo de recuperação de dados), 11.2 (Executar *backups* automatizados), 11.3 (Proteger os dados de recuperação) e 11.4 (Estabelecer e manter uma instância isolada de dados de recuperação);
- Instrução Normativa PRODERJ/PRE nº 07/2025, Anexo Único, Item 8.1.3 (*Backup e recuperação de dados*);
- Resolução TJ/OE nº 28/2022, art. 22, IV (Gestão de riscos de segurança da informação);
- Resolução CNMP nº 294/2024, art. 23, §3º, incisos II, III e IV (Planejamento, gestão e execução das ações em cibersegurança).

4.3.5.2. Evidências

As evidências que embasam este achado estão consolidadas no Anexo AN04 e encontram-se individualizadas em cada um dos relatórios individuais (AN08 a AN43) das organizações auditadas.

4.3.5.3. Situação encontrada

A recuperação de dados (*backup*) é um controle essencial para garantir a disponibilidade e a integridade dos ativos de informação. Seu objetivo é assegurar a capacidade de restaurar dados e sistemas corporativos para um estado pré-incidente e confiável após a ocorrência de falhas, erros humanos ou ataques cibernéticos, como *ransomware*.

Um aspecto fundamental é que a recuperação de dados não deve ser tratada como um processo desorganizado ou reativo. A organização precisa de mecanismos robustos para se recuperar rapidamente de um incidente e garantir a continuidade de sua missão institucional.

O *Data Recovery Policy Template* do CIS estabelece que a recuperação deve seguir um ciclo de vida estruturado em quatro etapas essenciais: Planejar (*Plan*), criando uma estratégia

detalhada de ação; Executar *Backup* (*Backup*), transferindo dados dos ativos corporativos para locais de armazenamento seguros; Testar (*Test*), assegurando que a estratégia funciona e que os dados são efetivamente recuperáveis; e Recuperar (*Recover*), restaurando os dados e a funcionalidade operacional após um incidente.

A legislação vigente, notadamente o art. 6º, incisos II e III, da Lei de Acesso à Informação (LAI) e os artigos 46 e 47 da Lei Geral de Proteção de Dados (LGPD), impõem à Administração o dever de implementar medidas técnicas de segurança aptas a proteger as informações sob sua custódia.

No contexto de *backups*, o cumprimento desses requisitos materializa-se na adoção de práticas consagradas, como o item 8.13 da ABNT NBR ISO/IEC 27002:2022²⁸ e as medidas de higiene cibernética do Controle 11 dos Controles CIS v8.1²⁹.

É relevante destacar que a recuperação de dados é uma exigência positivada em normativos estaduais e setoriais³⁰. No Poder Executivo estadual, a Instrução Normativa PRODERJ/PRE nº 07/2025 (Item 8.1.3) estabelece diretrizes específicas para *backup* e recuperação. O Governo Federal, por meio do PPSI, disponibiliza um Modelo de Política de *Backup*³¹ que serve de referência para a Administração Pública.

Para executar uma recuperação de dados eficaz e conforme, a organização deve adotar, minimamente, as medidas básicas (de higiene cibernética) do Controle 11 dos Controles CIS versão 8.1: (1) estabelecer e manter um processo formal de recuperação, (2) executar *backups* automatizados, (3) proteger os dados de recuperação e (4) manter uma instância isolada desses dados.

Com base na análise das respostas aos itens 1101 e 1102 do questionário aplicado, da avaliação dos documentos encaminhados e dos comentários do gestor, a Equipe de Auditoria constatou as seguintes deficiências nas organizações auditadas:

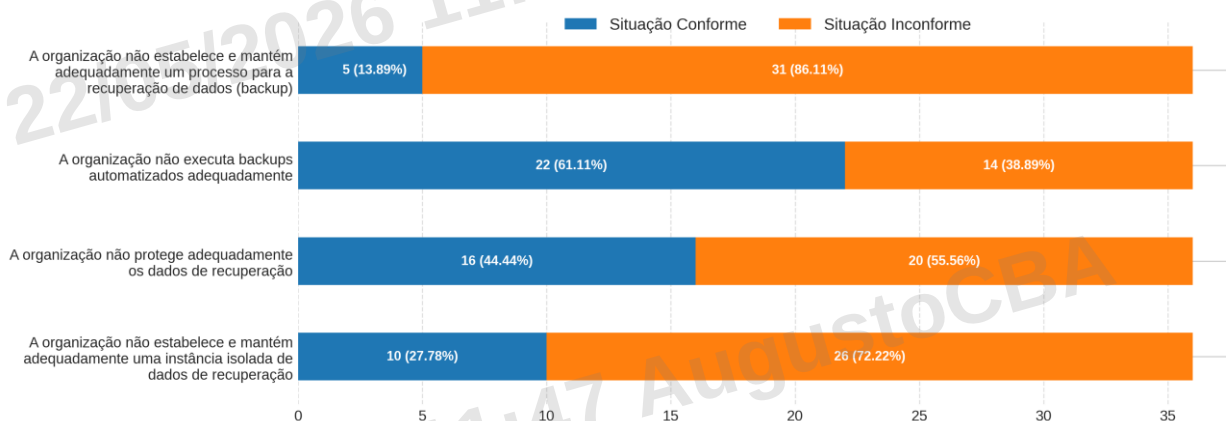
Figura 20 – Distribuição das situações da gestão de *backups*

²⁸ O item 8.13 da ISO/IEC 27002:2022 (*Backup* das informações) dispõe que cópias de segurança de informações, *software* e sistemas devem ser mantidas e testadas regularmente de acordo com uma política específica.

²⁹ As medidas básicas do Controle 11 (Recuperação de dados) dos Controles CIS v8.1 representam o conjunto mínimo de medidas para estabelecer e manter práticas de recuperação de dados suficientes para restaurar ativos corporativos dentro do escopo para um estado pré-incidente e confiável.

³⁰ Outros dispositivos normativos que abordam indiretamente o tema são o art. 22, inciso IV, da Resolução TJ/OE nº 28/2022, aplicável ao TJRJ, e os princípios dispostos nos incisos II, III e IV, do §3º, do art. 23, da Resolução CNMP nº 294/2024, aplicável aos Ministérios Públicos.

³¹ BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Secretaria de Governo Digital. Programa de Privacidade e Segurança da Informação (PPSI): Modelo de Política de Política de *Backup*. 2023. Disponível em: https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/ppsi/modelo_politica_backup.pdf. Acesso em: 1 dez. 2025.



(Fonte: elaboração própria)

Essas situações ensejaram o presente achado e serão detalhadas nas seções subsequentes.

Processo de recuperação de dados (*backup*)

A governança da recuperação de dados exige que a organização estabeleça, formalize e revise anualmente um processo de gestão de *backups*.

A Medida 11.1 dos Controles CIS v8.1 requer a definição desse processo, incluindo a revisão periódica. Em complemento, o item 8.13 da ISO/IEC 27002:2022 orienta o estabelecimento de uma política específica de *backup* para atender aos requisitos de retenção de dados da organização.

É fundamental que esse processo defina claramente o escopo dos ativos protegidos, as responsabilidades da equipe, os critérios de priorização (RPO/RTO) e os requisitos de segurança dos dados. Além disso, o processo deve estabelecer a obrigatoriedade de manter uma instância de recuperação isolada (*offline*, *off-site* ou em nuvem segregada) para proteção contra ameaças cibernéticas, como *ransomware*.

Da análise das respostas ao item 1101 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 20, verificou-se que 31 (86,1%) das 36 organizações auditadas não possuem um processo formalizado e adequado para a recuperação de dados.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que estabeleçam, mantenham e revisem periodicamente seu processo de recuperação de dados.

Execução e proteção dos *backups*

Além de estabelecer o processo de recuperação de dados, cabe à organização executar as rotinas de *backup* e proteger esses dados adequadamente.

As Medidas 11.2, 11.3 e 11.4 dos Controles CIS v8.1 determinam que os *backups* sejam realizados por meio de rotinas automatizadas, com frequência mínima semanal (ou maior,

conforme a criticidade), que sejam protegidos de forma equivalente ou superior aos dados originais, incluindo criptografia e controles de acesso estritos, e que a organização mantenha uma instância isolada dos dados (*offsite*, inacessível pela rede), impedindo que um atacante que comprometa a rede principal consiga destruir também as cópias de segurança.

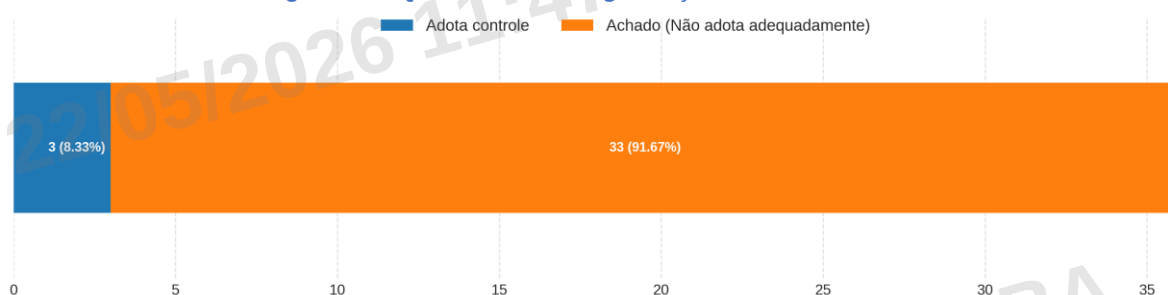
Da análise das respostas ao item 1102 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 20, verificou-se que 14 (38,9%) das 36 organizações auditadas necessitam de melhorias na execução automatizada de *backups*, 20 (55,5%) não protegem adequadamente seus *backups* e 26 (72,2%) não possuem uma instância isolada para armazenar cópia dos dados de recuperação.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que assegurem a execução automatizada, a proteção e o isolamento adequado dos dados de recuperação.

Conclusão

Com base nas situações avaliadas, verificou-se que 33 (91,7%) das 36 organizações auditadas não possuem medidas suficientes para realizar uma gestão adequada de *backups*.

Figura 21 – Quantitativo de organizações contidas no achado 5



(Fonte: elaboração própria)

As fragilidades identificadas nesse achado comprometem a capacidade da organização de reagir a incidentes e garantir a continuidade de seus serviços.

Diante das situações apresentadas, será sugerida proposta de encaminhamento às organizações para que promovam a adequação de seus controles, alinhando-se às práticas da ABNT NBR ISO/IEC 27002:2022 e do CIS Controls v8.1.

4.3.5.4. Causas

- Não investigadas.

4.3.5.5. Efeitos

- Impossibilidade de recuperação dos dados da organização;
- Ausência de mitigação para ataques do tipo *ransomware*;
- Falha na disponibilidade das informações da organização.

4.3.5.6. Propostas de Encaminhamento

Ressalta-se que as propostas de encaminhamento individualizadas para cada organização auditada constam no bojo dos relatórios individuais presentes nos conjuntos de anexos AN08 a AN43. Dessa forma, seguem as sugestões gerais propostas pela Equipe de Auditoria:

- **Comunicação com Recomendação** às organizações que não possuem um processo estabelecido de gestão de *backups* para que adotem integralmente a medida de segurança 11.1 (Estabelecer e manter um processo de recuperação de dados) prevista nos Controles CIS v8.1, atentando-se, minimamente, em formalizar, aprovar e revisar anualmente um processo documentado que inclua procedimentos detalhados de *backup* e defina o escopo, as responsabilidades, a priorização da recuperação e os requisitos de segurança dos dados salvos, incluindo a obrigatoriedade de manter uma instância de recuperação isolada;
- **Comunicação com Recomendação** às organizações que não realizam *backups* de forma automatizada para que adotem integralmente a medida de segurança 11.2 (Executar *backups* automatizados) prevista nos Controles CIS v8.1, atentando-se, minimamente, em realizar *backups* dos ativos definidos no escopo por meio de rotinas automatizadas, com frequência mínima semanal ajustada à criticidade dos dados;
- **Comunicação com Recomendação** às organizações que não protegem os dados de *backups* para que adotem integralmente a medida de segurança 11.3 (Proteger dados de recuperação) prevista nos Controles CIS v8.1, atentando-se, minimamente, em aplicar controles de segurança físicos e lógicos (como criptografia e restrição de acesso) aos dados de backup, garantindo proteção equivalente à dos dados originais;
- **Comunicação com Recomendação** às organizações que não possuem uma instância isolada para armazenar cópia de *backup* para que adotem integralmente a medida de segurança 11.4 (Estabelecer e manter uma instância isolada de dados de recuperação) prevista nos Controles CIS v8.1, atentando-se, minimamente, em estabelecer e manter uma instância isolada dos dados de recuperação, utilizando destinos de backup em sistemas *offline*, em nuvem ou em locais externos (*off-site*).

4.3.6. Achado 6 – Medidas básicas de segurança cibernética insuficientes na gestão da infraestrutura de rede

4.3.6.1. Critérios

- Lei Federal nº 12.527/2011 (LAI), art. 6º, incisos II e III (Dever da Administração de proteger a confidencialidade, integridade e disponibilidade das informações sob sua custódia);
- Lei Federal nº 13.709/2018 (LGPD), art. 6º, inciso VII, art. 46 e art. 47 (Dever da Administração de atender ao princípio da segurança nas atividades de tratamento de dados pessoais, por meio da utilização de medidas técnicas e administrativas na proteção dos dados);
- Norma Técnica ABNT NBR ISO/IEC 27002:2022, item 8.8 (Gestão de vulnerabilidades técnicas);
- Controles CIS versão 8.1, medidas de segurança: 12.1 (Assegurar que a infraestrutura de rede esteja atualizada);
- Instrução Normativa PRODERJ/PRE nº 07/2025, Anexo Único, Item 7.2.1.5 (Atualização proativa dos ativos de segurança da informação);
- Resolução TJ/OE nº 28/2022, art. 22, IV (Gestão de riscos de segurança da informação);
- Resolução CNMP nº 294/2024, art. 23, §3º, incisos II, III e IV (planejamento, a gestão e a execução das ações em cibersegurança).

4.3.6.2. Evidências

As evidências que embasam este achado estão consolidadas no Anexo AN04 e encontram-se individualizadas em cada um dos relatórios individuais (AN08 a AN43) das organizações auditadas.

4.3.6.3. Situação encontrada

A gestão da infraestrutura de rede é um pilar essencial para a segurança cibernética, focando na manutenção e proteção dos dispositivos que garantem a conectividade e o tráfego de dados na organização, como roteadores, *switches* e *firewalls*. A ausência de uma gestão ativa sobre esses ativos permite que vulnerabilidades não corrigidas sejam exploradas por atacantes para comprometer o perímetro da rede, interceptar comunicações ou interromper serviços críticos.

A legislação vigente, notadamente a Lei de Acesso à Informação (LAI) e a Lei Geral de Proteção de Dados (LGPD), impõe à Administração o dever de assegurar a confidencialidade, integridade e disponibilidade das informações.

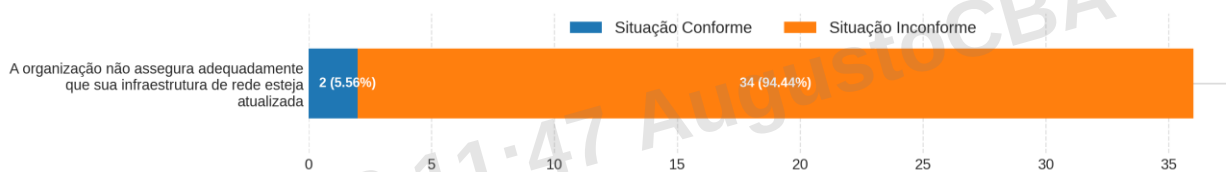
No contexto da gestão da infraestrutura de rede, o cumprimento desses requisitos materializa-se na adoção de práticas consagradas, como o item 8.8 da ABNT NBR ISO/IEC 27002:2022³² e a medida de higiene cibernética do Controle 12 dos Controles CIS v8.1³³.

É relevante destacar que a atualização e gestão desses ativos é uma exigência positivada em normativos estaduais e setoriais³⁴. No Poder Executivo estadual, a Instrução Normativa PRODERJ/PRE nº 07/2025 (Item 7.2.1.5) determina explicitamente a atualização proativa dos ativos de segurança da informação com as últimas correções.

Para assegurar uma gestão eficaz e conforme, a organização deve adotar, minimamente, a Medida 12.1 do Controle 12 dos Controles CIS versão 8.1: garantir que toda a infraestrutura de rede esteja atualizada e suportada.

Com base na análise das respostas ao item 1201 do questionário aplicado, da avaliação dos documentos encaminhados e dos comentários do gestor, a Equipe de Auditoria constatou as seguintes deficiências nas organizações auditadas:

Figura 22 – Distribuição das situações da gestão de infraestrutura de rede



(Fonte: elaboração própria)

Essas situações ensejaram o presente achado e serão detalhadas nas seções subsequentes.

Infraestrutura de rede atualizada

A primeira linha de defesa da infraestrutura de rede é a garantia de que todos os dispositivos operem com as versões de *software* (*firmware*) mais recentes e estáveis fornecidas pelos fabricantes.

A Medida 12.1 dos Controles CIS v8.1 exige a atualização proativa desses ativos.

Em alinhamento, o item 8.8 da ISO/IEC 27002:2022 orienta a implementação de um processo de gerenciamento de atualização para assegurar que os *patches* de segurança sejam instalados tempestivamente.

³² O item 8.8 da ISO/IEC 27002:2022 (Gestão de vulnerabilidades técnicas) estabelece que as informações sobre vulnerabilidades técnicas dos sistemas em uso devem ser obtidas, a exposição da organização avaliada e as medidas apropriadas tomadas.

³³ As medidas básicas do Controle 12 (Gestão de infraestrutura de rede) dos Controles CIS v8.1 representam o conjunto mínimo de medidas para estabelecer, implementar e gerenciar ativamente os dispositivos de rede, a fim de evitar que atacantes explorem vulnerabilidades em serviços e pontos de acesso.

³⁴ Outros dispositivos normativos que tratam da gestão de ativos e riscos são o art. 22, inciso IV, da Resolução TJ/OE nº 28/2022, aplicável ao TJRJ, e os princípios dispostos nos incisos II, III e IV, do §3º, do art. 23, da Resolução CNMP nº 294/2024, aplicável aos Ministérios Públicos.

É fundamental que a organização utilize apenas versões suportadas pelos fabricantes e que estabeleça uma rotina de verificação mensal para identificar novas atualizações. Dispositivos de rede desatualizados (“fim de vida” ou *End-of-Life*) ou sem os *patches* de segurança mais recentes tornam-se alvos fáceis para exploração, servindo como porta de entrada para invasões na rede interna.

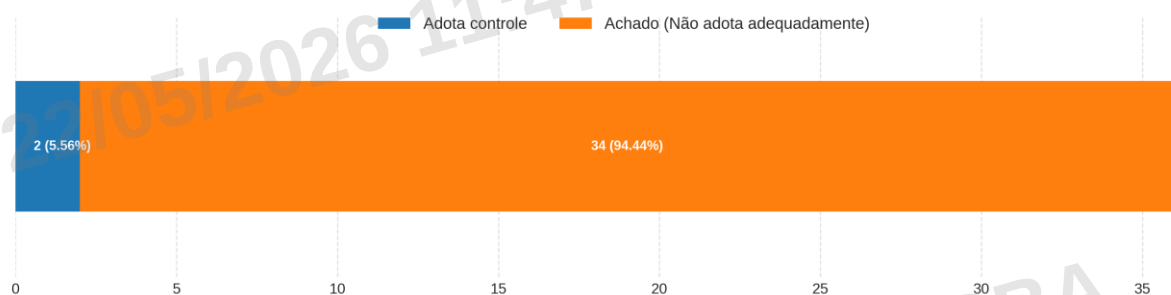
Da análise das respostas ao item 1201 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 22, verificou-se que 34 (94,4%) das 36 organizações auditadas não garantem adequadamente a atualização de sua infraestrutura de rede, expondo o ambiente a riscos de segurança conhecidos.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que estabeleçam práticas para garantir que toda a infraestrutura de rede esteja mantida em versões atualizadas e suportadas.

Conclusão

Com base nas situações avaliadas, verificou-se que 34 (94,4%) das 36 organizações auditadas não possuem medidas suficientes para manter os ativos de rede atualizados.

Figura 23 – Quantitativo de organizações contidas no achado 6



(Fonte: elaboração própria)

As fragilidades identificadas nesse achado comprometem a segurança do perímetro e a integridade das comunicações da organização.

Diante das situações apresentadas, será sugerida proposta de encaminhamento às organizações para que promovam a adequação de seus controles, alinhando-se às práticas da ABNT NBR ISO/IEC 27002:2022 e do CIS Controls v8.1.

4.3.6.4. Causas

- Não investigadas.

4.3.6.5. Efeitos

- Uso de equipamentos infraestrutura de rede com *software* com vulnerabilidades conhecidas e exploradas;
- Uso de equipamentos de infraestrutura de rede com configurações inseguras.

4.3.6.6. Propostas de Encaminhamento

Ressalta-se que as propostas de encaminhamento individualizadas para cada organização auditada constam no bojo dos relatórios individuais presentes nos conjuntos de anexos AN08 a AN43. Dessa forma, seguem as sugestões gerais propostas pela Equipe de Auditoria:

- **Comunicação com Recomendação** às organizações que não asseguram a atualização tempestiva dos ativos de rede para que adotem integralmente a medida de segurança 12.1 (Assegurar que a infraestrutura de rede esteja atualizada) prevista nos Controles CIS v8.1, atentando-se, minimamente, em utilizar as versões estáveis mais recentes de software e firmware nos dispositivos de rede por meio de atualizações automáticas ou processo alternativo documentado, assegurando a revisão mensal das versões para garantir o suporte do fornecedor;

4.3.7. Achado 7 – Medidas básicas de segurança cibernética insuficientes no programa de conscientização e treinamento em segurança

4.3.7.1. Critérios

- Lei Federal nº 12.527/2011 (LAI), art. 6º, incisos II e III (Dever da Administração de proteger a confidencialidade, integridade e disponibilidade das informações sob sua custódia);
- Lei Federal nº 13.709/2018 (LGPD), art. 6º, inciso VII, art. 46 e art. 47 (Dever da Administração de atender ao princípio da segurança nas atividades de tratamento de dados pessoais, por meio da utilização de medidas técnicas e administrativas na proteção dos dados);
- Norma Técnica ABNT NBR ISO/IEC 27002:2022, item 6.3 (Conscientização, educação e treinamento em segurança da informação);
- Controles CIS versão 8.1, medidas de segurança: 14.1 (Programa de conscientização de segurança), 14.2 (Treinamento para reconhecer ataques de engenharia social), 14.3 (Treinamento nas melhores práticas de autenticação), 14.4 (Treinamento nas Melhores Práticas de Tratamento de Dados), 14.5 (Treinamento sobre as causas da exposição não intencional de dados), 14.6 (Treinamento no Reconhecimento e Comunicação de Incidentes de Segurança), 14.7 (Treinamento sobre como identificar e comunicar se seus ativos corporativos estão faltando atualizações de segurança) e 14.8 (Treinamento sobre os perigos de se conectar e transmitir dados corporativos em redes inseguras);
- Instrução Normativa PRODERJ/PRE nº 07/2025, Anexo Único, Item 8.13.5.1 (Conscientização de Segurança da Informação);
- Resolução TJ/OE nº 28/2022, art. 22, IV (Gestão de riscos de segurança da informação) e VI (Política educacional e cultural em segurança da informação);
- Resolução CNMP nº 294/2024, art. 23, §3º, incisos II, III e IV (planejamento, a gestão e a execução das ações em cibersegurança).

4.3.7.2. Evidências

As evidências que embasam este achado estão consolidadas no Anexo AN04 e encontram-se individualizadas em cada um dos relatórios individuais (AN08 a AN43) das organizações auditadas.

4.3.7.3. Situação encontrada

A conscientização e o treinamento em segurança da informação são práticas imprescindíveis para a proteção corporativa, visto que o fator humano é frequentemente considerado o elo mais fraco na cadeia de segurança. É consideravelmente mais fácil para um

atacante induzir um usuário a clicar em um *link* malicioso ou abrir um anexo infectado do que encontrar e explorar uma vulnerabilidade de rede complexa.

Além dos ataques externos, riscos inerentes ao comportamento humano — como o manuseio incorreto de dados sensíveis, o envio de informações para destinatários errados, a perda de dispositivos portáteis e o uso de senhas fracas ou reutilizadas — representam ameaças constantes à integridade organizacional.

A legislação vigente, notadamente a Lei de Acesso à Informação (LAI) e a Lei Geral de Proteção de Dados (LGPD), impõe à Administração o dever de implementar medidas técnicas e administrativas de segurança.

No contexto de gestão de pessoas, o cumprimento desses requisitos materializa-se na adoção de práticas consagradas, como o item 6.3 da ABNT NBR ISO/IEC 27002:2022³⁵ e as medidas de higiene cibernética do Controle 14 dos Controles CIS v8.1³⁶.

É relevante destacar que a conscientização em segurança é uma exigência positivada em normativos estaduais e setoriais³⁷. No Poder Executivo estadual, a Instrução Normativa PRODERJ/PRE nº 07/2025 (Item 8.13.5.1) determina o desenvolvimento de programas de capacitação específicos. O Governo Federal, por meio do PPSI, disponibiliza um Modelo de Política de Desenvolvimento de Pessoas³⁸ que orienta a estruturação dessas ações.

Para assegurar uma conscientização eficaz e conforme, a organização deve adotar, minimamente, as medidas básicas (de higiene cibernética) do Controle 14 dos Controles CIS versão 8.1: (1) estabelecer um programa de conscientização de segurança estruturado que capacite a força de trabalho para: (2) reconhecer engenharia social, (3) aplicar boas práticas de autenticação e tratamento de dados, (4) evitar exposição acidental, (5) reconhecer incidentes e (6) utilizar redes de forma segura.

Com base na análise das respostas aos itens 1401 e 1402 do questionário aplicado, da avaliação dos documentos encaminhados e dos comentários do gestor, a Equipe de Auditoria constatou as seguintes deficiências nas organizações auditadas:

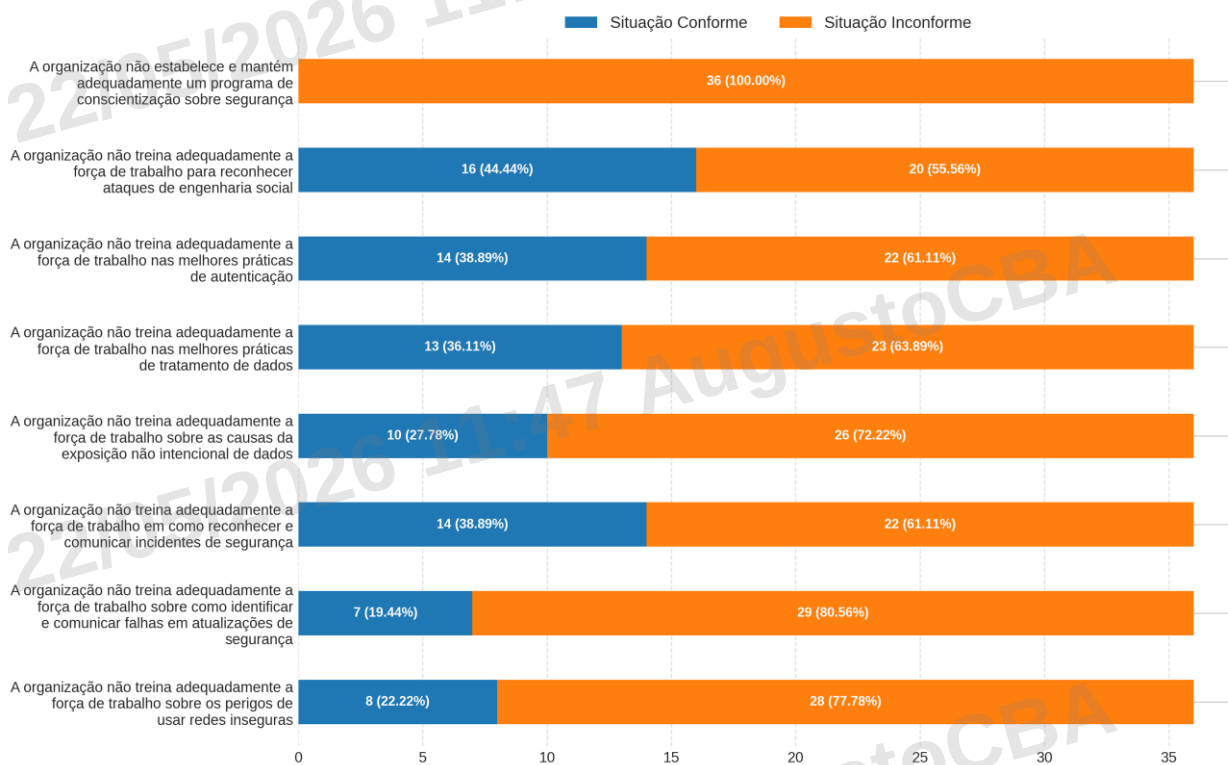
Figura 24 – Distribuição das situações de programa de conscientização e treinamento em segurança

³⁵ O item 6.3 da ISO/IEC 27002:2022 (Conscientização, educação e treinamento em segurança da informação) declara a necessidade de que o pessoal e as partes interessadas recebam treinamento, educação e conscientização apropriados às suas funções.

³⁶ As medidas básicas do Controle 14 (Conscientização sobre segurança e treinamento de competências) dos Controles CIS v8.1 representam o conjunto mínimo de medidas para estabelecer e manter um programa de conscientização de segurança capaz de influenciar o comportamento da força de trabalho e reduzir riscos cibernéticos.

³⁷ Outros dispositivos normativos que tratam de gestão de ativos e pessoas são o art. 22, incisos IV e VI, da Resolução TJ/OE nº 28/2022, aplicável ao TJRJ, e os princípios dispostos nos incisos II, III e IV, do §3º, do art. 23, da Resolução CNMP nº 294/2024, aplicável aos Ministérios Públicos.

³⁸ BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Secretaria de Governo Digital. Programa de Privacidade e Segurança da Informação (PPSI): Modelo de Política de Desenvolvimento de Pessoas em Privacidade e Segurança da Informação. 2023. Disponível em: https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/ppsi/modelo_politica_desenvolvimento_pessoas.pdf. Acesso em: 1 dez. 2025.



(Fonte: elaboração própria)

Essas situações ensejaram o presente achado e serão detalhadas nas seções subsequentes.

Programa de conscientização sobre segurança

A base da cultura de segurança é o estabelecimento e a manutenção de um programa formal de conscientização.

A Medida 14.1 dos Controles CIS v8.1 exige que esse programa eduque a força de trabalho sobre como interagir de forma segura com ativos e dados corporativos.

É crucial que o programa reconheça os diferentes perfis de risco (gestores, TI, financeiro, RH) e adapte o conteúdo de acordo. Em complemento, o item 6.3 da ISO/IEC 27002:2022 orienta que o programa deve estar alinhado à política de segurança da organização, considerar os controles implementados e o contexto organizacional.

Para ser efetivo, o programa deve ser formalmente documentado, aprovado e revisado anualmente (ou mediante mudanças significativas). Devem ser definidas claramente as responsabilidades de execução (Gestor de SI, DPO, RH). Além disso, deve estabelecer a obrigatoriedade de treinamento na integração (*onboarding*) de novos colaboradores e atualizações periódicas para toda a equipe, no mínimo anualmente.

Da análise das respostas ao item 1401 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado

na Figura 24, verificou-se que nenhuma (100%) das 36 organizações auditadas não possuem um programa de conscientização formalizado ou adequado.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que estabeleçam, mantenham e revisem periodicamente seu programa de conscientização sobre segurança.

Treinamento da força de trabalho em segurança da informação

Um programa de conscientização em segurança eficiente deve atender aos riscos mais comuns. As Medidas 14.2 a 14.8 dos Controles CIS v8.1 elencam os tópicos essenciais que devem compor o currículo de treinamento da organização:

- Engenharia Social (14.2): Reconhecimento de *phishing*, *BEC (Business Email Compromise)* e outras táticas de manipulação;
- Autenticação (14.3): Boas práticas de senhas fortes, MFA e proteção de credenciais;
- Tratamento de Dados (14.4 e 14.5): Manuseio seguro, política de mesa limpa e prevenção contra exposição acidental;
- Incidentes (14.6 e 14.7): Como identificar e reportar anomalias de segurança ou falta de atualizações;
- Redes (14.8): Riscos de conexões inseguras e trabalho remoto.

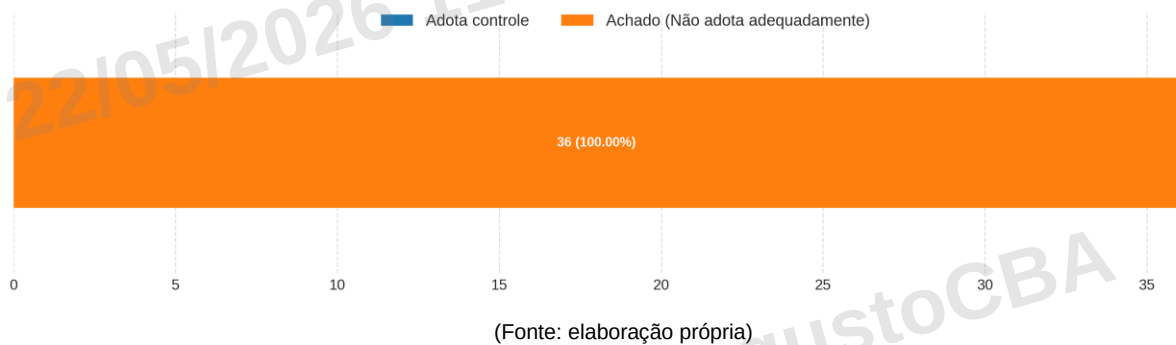
A organização pode conduzir simulações periódicas (ex: *phishing*) para reforçar o aprendizado e fornecer orientações específicas para o trabalho remoto seguro.

Da análise das respostas ao item 1402 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 24, verificou-se que um cenário deficiente no treinamento de tópicos de segurança para ampla maioria (>55%) das 36 organizações auditadas. Constatou-se que as organizações não oferecem treinamento adequado ou abrangente sobre esses temas críticos.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que implementem treinamentos regulares abordando os temas essenciais de segurança da informação para toda a força de trabalho.

Conclusão

Com base nas situações avaliadas, verificou-se que nenhuma das 36 organizações auditadas possuem medidas suficientes para estabelecer um programa de conscientização e treinamento de segurança da informação.



As lacunas na conscientização e treinamento expõem a organização a riscos significativos decorrentes do fator humano.

Diante das situações apresentadas, será sugerida proposta de encaminhamento às organizações para que promovam a adequação de seus controles, alinhando-se às práticas da ABNT NBR ISO/IEC 27002:2022 e do CIS Controls v8.1.

4.3.7.4. Causas

- Não investigadas.

4.3.7.5. Efeitos

- Exposição a vulnerabilidades de fator humano;
- Ausência de uma cultura organizacional em segurança da informação;
- Força de trabalho incapaz de lidar com ataques de engenharia social;
- Força de trabalho incapaz de lidar com melhores prática de autenticação;
- Força de trabalho incapaz de lidar com tratamento adequado dados;
- Força de trabalho incapaz de lidar com reconhecimento e comunicação de incidentes em segurança da informação;
- Força de trabalho incapaz de lidar com desatualizações de segurança em ativos corporativos;
- Força de trabalho incapaz de lidar com transmissão segura de dados.

4.3.7.6. Propostas de Encaminhamento

- **Comunicação com Recomendação** às organizações que não possuem programa de segurança para que adotem integralmente a medida de segurança 14.1 (Estabelecer e manter um programa de conscientização em segurança) prevista nos Controles CIS v8.1, atentando-se, minimamente, em estabelecer e manter um programa contínuo de conscientização que seja documentado, aprovado e revisado anualmente para educar a força de trabalho sobre como interagir de maneira segura com os ativos e dados corporativos e que torne o treinamento mandatório na admissão e na reciclagem anual para todos os colaboradores;

- **Comunicação com Recomendação** às organizações que não treinam seus colaboradores sobre ameaças de segurança para que adotem para que adote integralmente a medida de segurança 14.2 (Treinar os membros da força de trabalho para reconhecer ataques de engenharia social) prevista nos Controles CIS v8.1, atentando-se, minimamente, em capacitar a força de trabalho para reconhecer e resistir a ataques de engenharia social, como *phishing*, compromisso de *e-mail* corporativo (BEC), *pretexting* e acesso físico não autorizado (*tailgating*);
- **Comunicação com Recomendação** às organizações que não treinam seus colaboradores sobre ameaças de segurança para que adotem integralmente a medida de segurança 14.3 (Treinar os membros da força de trabalho sobre as melhores práticas de autenticação) prevista nos Controles CIS v8.1, atentando-se, minimamente, em capacitar a força de trabalho sobre o uso correto da autenticação multifator (MFA), a criação de senhas complexas e a gestão segura de credenciais;
- **Comunicação com Recomendação** às organizações que não treinam seus colaboradores sobre ameaças de segurança para que adotem integralmente a medida de segurança 14.4 (Treinar os membros da força de trabalho sobre as melhores práticas de manuseio de dados) prevista nos Controles CIS v8.1, atentando-se, minimamente, em capacitar a força de trabalho sobre o ciclo de vida do tratamento de dados sensíveis e a aplicação da política de mesa e tela limpas;
- **Comunicação com Recomendação** às organizações que não treinam seus colaboradores sobre ameaças de segurança para que adotem integralmente a medida de segurança 14.5 (Treinar os membros da força de trabalho sobre as causas da exposição não intencional de dados) prevista nos Controles CIS v8.1, atentando-se, minimamente, em capacitar a força de trabalho sobre os riscos e prevenções contra vazamentos acidentais, como o envio incorreto de informações sensíveis ou sua publicação em repositórios públicos;
- **Comunicação com Recomendação** às organizações que não treinam seus colaboradores sobre ameaças de segurança para que adotem integralmente a medida de segurança 14.6 (Treinar os membros da força de trabalho para reconhecer e relatar incidentes de segurança) prevista nos Controles CIS v8.1, atentando-se, minimamente, em capacitar a força de trabalho para identificar anomalias de segurança e realizar a comunicação tempestiva de incidentes;
- **Comunicação com Recomendação** às organizações que não treinam seus colaboradores sobre ameaças de segurança para que adotem integralmente a medida de segurança 14.7 (Treinar os membros da força de trabalho sobre como identificar e relatar se seus ativos corporativos estão faltando atualizações de segurança) prevista nos

Controles CIS v8.1, atentando-se, minimamente, em capacitar a força de trabalho para verificar e relatar à equipe de TI atualizações de software pendentes ou falhas em processos e ferramentas automatizadas;

- **Comunicação com Recomendação** às organizações que não treinam seus colaboradores sobre ameaças de segurança para que adotem integralmente a medida de segurança 14.8 (Treinar os membros da força de trabalho sobre os perigos de se conectar e transmitir dados corporativos em redes inseguras) prevista nos Controles CIS v8.1, atentando-se, minimamente, em capacitar a força de trabalho sobre os riscos de transmissão de dados em redes inseguras e fornecer orientações para a configuração segura de redes domésticas em cenários de trabalho remoto.

4.3.8. Achado 8 – Medidas básicas de segurança cibernética insuficientes na gestão de provedores de serviços

4.3.8.1. Critérios

- Lei Federal nº 12.527/2011 (LAI), art. 6º, incisos II e III (Dever da Administração de proteger a confidencialidade, integridade e disponibilidade das informações sob sua custódia);
- Lei Federal nº 13.709/2018 (LGPD), art. 6º, inciso VII, art. 46 e art. 47 (Dever da Administração de atender ao princípio da segurança nas atividades de tratamento de dados pessoais, por meio da utilização de medidas técnicas e administrativas na proteção dos dados);
- Norma Técnica ABNT NBR ISO/IEC 27002:2022, itens 5.19 (Segurança da informação nas relações com fornecedores) e 5.20 (Abordagem da segurança da informação nos contratos de fornecedores);
- Controles CIS versão 8.1, medida de segurança 15.1 (Estabelecer e manter um inventário de provedores de serviço);
- Instrução Normativa PRODERJ/PRE nº 07/2025, Anexo Único, Item 8.9 (Relacionamento com o fornecedor);
- Resolução TJ/OE nº 28/2022, art. 22, IV (Gestão de riscos de segurança da informação);
- Resolução CNMP nº 294/2024, art. 23, §3º, incisos II, III e IV (Planejamento, gestão e execução das ações em cibersegurança).

4.3.8.2. Evidências

As evidências que embasam este achado estão consolidadas no Anexo AN04 e encontram-se individualizadas em cada um dos relatórios individuais (AN08 a AN43) das organizações auditadas.

4.3.8.3. Situação encontrada

A gestão de provedores de serviços é um controle de governança fundamental em um cenário onde a Administração Pública depende cada vez mais de parceiros externos para processar dados sensíveis e operar infraestruturas críticas. A segurança da organização está intrinsecamente ligada à postura de segurança de seus fornecedores: se um parceiro falha na proteção, a contratante herda o risco, podendo sofrer impactos severos na confidencialidade, integridade e disponibilidade de suas informações.

A legislação vigente, notadamente a Lei de Acesso à Informação (LAI) e a Lei Geral de Proteção de Dados (LGPD), impõe à Administração o dever de implementar medidas técnicas e administrativas de segurança, responsabilidade que se estende à cadeia de suprimentos.

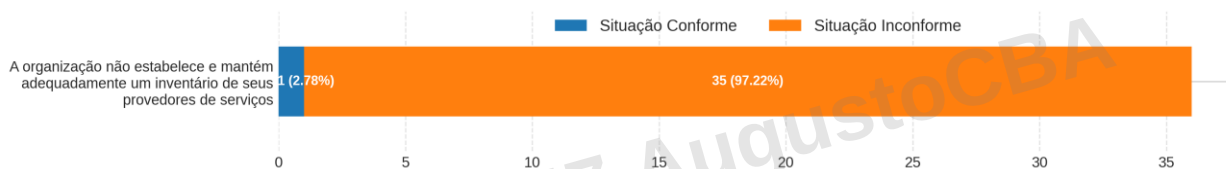
No contexto da gestão de terceiros, o cumprimento desses requisitos materializa-se na adoção de práticas consagradas, como os itens 5.19³⁹ e 5.20⁴⁰ da ABNT NBR ISO/IEC 27002:2022 e a medida de higiene cibernética do Controle 15 dos Controles CIS v8.1⁴¹.

A gestão de provedores também é objeto de diretrizes governamentais específicas. O Governo Federal, por meio do PPSI, disponibiliza um Modelo de Política de Gestão de Provedor de Serviços⁴² que orienta a estruturação desses controles na Administração Pública.

Para assegurar uma gestão eficaz e conforme, a organização deve adotar, minimamente, a Medida 15.1 do Controle 15 dos Controles CIS v8.1: estabelecer e manter um inventário atualizado de todos os provedores de serviços.

Com base na análise das respostas ao item 1501 do questionário aplicado, da avaliação dos documentos encaminhados e dos comentários do gestor, a Equipe de Auditoria constatou as seguintes deficiências nas organizações auditadas:

Figura 26 – Distribuição das situações da gestão de provedores de serviço



(Fonte: elaboração própria)

Essas situações ensejaram o presente achado e serão detalhadas nas seções subsequentes.

Inventário de provedores de serviços

O primeiro passo para mitigar os riscos da cadeia de suprimentos é conhecer quem são os parceiros. O inventário de provedores visa eliminar a “cegueira cibernética” em relação a terceiros, estabelecendo a visibilidade mínima necessária para mitigar os riscos básicos introduzidos por fornecedores de serviços.

A Medida 15.1 dos Controles CIS v8.1 exige o estabelecimento e a manutenção de um inventário abrangente. Alinhando-se a essa diretriz, a norma ABNT NBR ISO/IEC 27002:2022

³⁹ O item 5.19 da ISO/IEC 27002:2022 (Segurança da informação nas relações com fornecedores) estabelece que processos e procedimentos devem ser definidos e implementados para gerenciar os riscos associados ao uso dos produtos ou serviços dos fornecedores.

⁴⁰ O item 5.20 da ISO/IEC 27002:2022 (Abordagem da segurança da informação nos contratos de fornecedores) determina que os requisitos relevantes de segurança devem ser acordados e documentados com cada fornecedor, incluindo a manutenção de um registro desses acordos.

⁴¹ As medidas básicas do Controle 15 (Gestão de prestadores de serviços) dos Controles CIS v8.1 representam o conjunto mínimo de medidas para desenvolver um processo de avaliação de provedores que detêm dados sensíveis ou gerenciam plataformas críticas, garantindo que eles protejam esses ativos adequadamente.

⁴² BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Secretaria de Governo Digital. Programa de Privacidade e Segurança da Informação (PPSI): Modelo de Política de Gestão de Provedor de Serviços. 2023. Disponível em: https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/ppsi/modelo_politica_provedor_servicos.pdf. Acesso em: 1 dez. 2025.

reforça essa necessidade em duas frentes complementares: o item 5.19 orienta a organização a identificar e documentar os tipos de fornecedores que podem afetar a segurança da informação, enquanto o item 5.20 recomenda a manutenção de um registro centralizado de acordos com partes externas para rastrear o fluxo de informações.

Para ser efetivo, esse registro deve incluir, para cada provedor: o nome, os serviços prestados, a unidade de negócio responsável, os contatos corporativos e a classificação de risco (sensibilidade dos dados, criticidade para o negócio e requisitos regulatórios).

Além disso, é fundamental que o inventário seja revisado e atualizado anualmente ou sempre que houver mudanças contratuais significativas, garantindo que a organização mantenha visibilidade constante sobre sua superfície de risco externa.

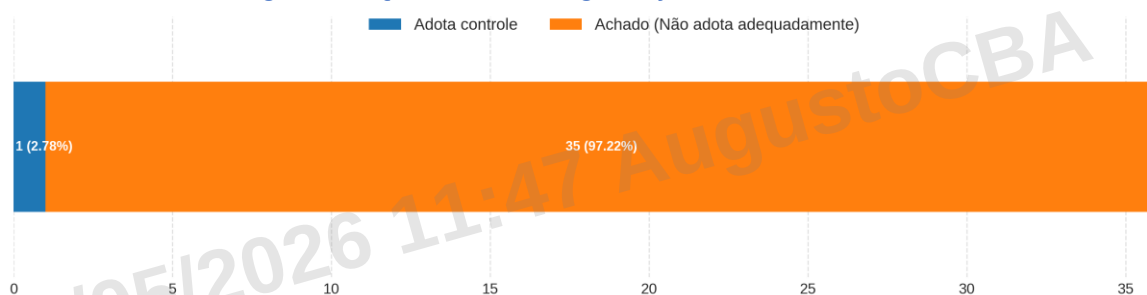
Da análise das respostas ao item 1501 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 16, verificou-se que 35 (97,2%) das 36 organizações auditadas não possuem um inventário formalizado ou adequado de seus prestadores de serviços.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que estabeleçam e mantenham um inventário atualizado de seus prestadores de serviços, classificando-os por nível de risco.

Conclusão

Com base nas situações avaliadas, verificou-se que 35 (97,2%) das 36 organizações auditadas não possuem medidas suficientes para estabelecer um inventário de provedores de serviço.

Figura 27 – Quantitativo de organizações contidas no achado 8



(Fonte: elaboração própria)

A ausência de controle sobre os provedores de serviços expõe a organização a riscos significativos oriundos de terceiros.

Dessa forma, será sugerida proposta de encaminhamento às organizações para que promovam a adequação de seus controles, alinhando-se às práticas da ABNT NBR ISO/IEC 27002:2022 e do CIS Controls v8.1.

4.3.8.4. Causas

- Não investigadas.

4.3.8.5. Efeitos

- Exposição a vulnerabilidades de terceiros;
- Desconhecimento de um ponto de contato para comunicação com os fornecedores;
- Desconhecimento da sensibilidade dos dados tratados pelos fornecedores;
- Ausência de gestão de riscos dos fornecedores.

4.3.8.6. Propostas de Encaminhamento

Ressalta-se que as propostas de encaminhamento individualizadas para cada organização auditada constam no bojo dos relatórios individuais presentes nos conjuntos de anexos AN08 a AN43. Dessa forma, seguem as sugestões gerais propostas pela Equipe de Auditoria:

- **Comunicação com Recomendação** às organizações que não possuem inventário adequado de provedores de serviço para que adotem integralmente a medida de segurança 15.1 (Estabelecer e manter um inventário de provedores de serviços) prevista nos Controles CIS v8.1, atentando-se, minimamente, em estabelecer e manter um inventário completo de provedores que inclua dados de contato, unidade de negócio e classificações de risco e sensibilidade, assegurando sua revisão anual ou mediante mudanças significativas.

4.3.9. Achado 9 – Medidas básicas de segurança cibernética insuficientes na gestão de respostas a incidentes

4.3.9.1. Critérios

- Lei Federal nº 12.527/2011 (LAI), art. 6º, incisos II e III (Dever da Administração de proteger a confidencialidade, integridade e disponibilidade das informações sob sua custódia);
- Lei Federal nº 13.709/2018 (LGPD), art. 6º, inciso VII, art. 46 e art. 47 (Dever da Administração de atender ao princípio da segurança nas atividades de tratamento de dados pessoais, por meio da utilização de medidas técnicas e administrativas na proteção dos dados);
- Norma Técnica ABNT NBR ISO/IEC 27002:2022, itens 5.24 (Planejamento e preparação da gestão de incidentes de segurança da informação) e 6.8 (Relato de eventos de segurança da informação);
- Controles CIS versão 8.1, medidas de segurança: 17.1 (Designar Pessoal para Gerenciar Tratamento de Incidentes), 17.2 (Estabelecer e manter informações de contato para relatar incidentes de segurança) e 17.3 (Estabelecer e manter um processo corporativo para relatar incidentes).

4.3.9.2. Evidências

As evidências que embasam este achado estão consolidadas no Anexo AN04 e encontram-se individualizadas em cada um dos relatórios individuais (AN08 a AN43) das organizações auditadas.

4.3.9.3. Situação encontrada

A gestão de incidentes de segurança é o conjunto de processos que permite à organização detectar, responder e recuperar-se de ataques cibernéticos de forma rápida e estruturada, minimizando danos, tempo de inatividade e custos. Sem um plano formal, as organizações tendem a reagir de forma desorganizada, muitas vezes falhando em conter a ameaça ou em identificar sua causa raiz, o que compromete a resiliência e a continuidade operacional.

A legislação vigente, notadamente a Lei de Acesso à Informação (LAI) e a Lei Geral de Proteção de Dados (LGPD), impõe à Administração o dever de implementar medidas técnicas e administrativas para garantir a segurança da informação.

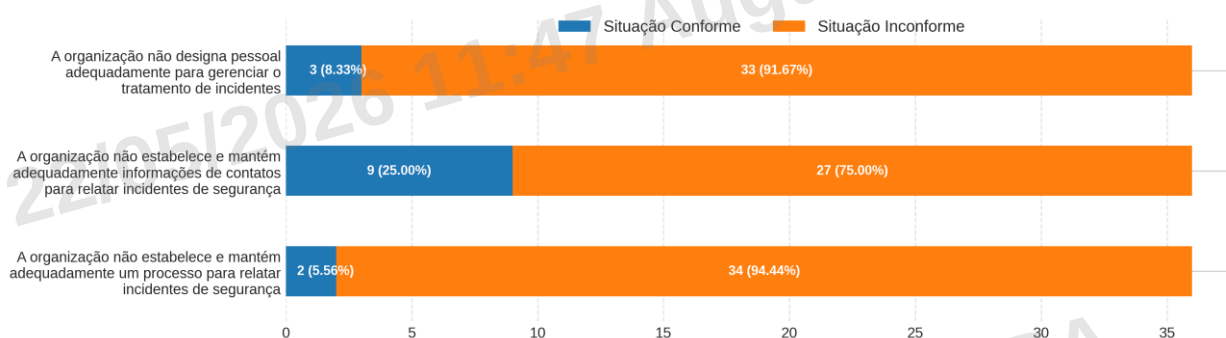
No contexto de gestão de incidentes, o cumprimento desses requisitos materializa-se na adoção de práticas consagradas, como os itens 5.24 e 6.8 da ABNT NBR ISO/IEC 27002:2022⁴³ e as medidas de higiene cibernética do Controle 17 dos Controles CIS v8.1⁴⁴.

É relevante destacar que a gestão de incidentes é uma exigência positivada em diretrizes governamentais. O Governo Federal, por meio do PPSI, disponibiliza um Guia de Resposta a Incidentes de Segurança⁴⁵ que orienta a estruturação dessas capacidades na Administração Pública.

Para assegurar uma gestão eficaz e conforme, a organização deve adotar, minimamente, as medidas básicas (de higiene cibernética) do Controle 17 dos Controles CIS versão 8.1: (1) designar pessoal responsável pelo tratamento de incidentes, (2) manter informações de contato atualizadas para notificação e (3) estabelecer um processo corporativo para o relato de incidentes pela força de trabalho.

Com base na análise das respostas aos itens 1701 e 1702 do questionário aplicado, da avaliação dos documentos encaminhados e dos comentários do gestor, a Equipe de Auditoria constatou as seguintes deficiências nas organizações auditadas:

Figura 28 – Distribuição das situações da gestão de resposta a incidentes



(Fonte: elaboração própria)

Essas situações ensejaram o presente achado e serão detalhadas nas seções subsequentes.

Plano de resposta a incidentes de segurança

A base da capacidade de resposta é a definição clara de “quem faz o quê” e “quem deve ser avisado”.

⁴³ O item 5.24 da ISO/IEC 27002:2022 (Planejamento e preparação da gestão de incidentes) orienta o planejamento para gerenciar incidentes. O item 6.8 (Relato de eventos de segurança) exige que a organização forneça um mecanismo para o relato de eventos suspeitos.

⁴⁴ As medidas básicas do Controle 17 (Gestão de respostas a incidentes) dos Controles CIS v8.1 representam o conjunto mínimo de medidas para estabelecer um programa de resposta a incidentes, incluindo políticas, planos, procedimentos e funções definidas, para preparar, detectar e responder rapidamente a um ataque.

⁴⁵ BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Secretaria de Governo Digital. Programa de Privacidade e Segurança da Informação (PPSI): Guia de Resposta a Incidentes de Segurança. 2023. Disponível em: https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/ppsi/guia_resposta_incidentes.pdf. Acesso em: 1 dez. 2025.

As Medidas 17.1 e 17.2 dos Controles CIS v8.1 exigem a designação formal de pessoal responsável e a manutenção de uma lista de contatos para notificação, bem como definição de atribuições à equipe e revisões periódicas das informações. Em complemento, o item 5.24 da ISO/IEC 27002:2022 estabelece que a organização deve planejar e se preparar, definindo papéis e responsabilidades.

Para ser efetivo, o plano deve: Designar um responsável principal e suplentes para a gestão de incidentes; Definir claramente as responsabilidades da equipe de resposta; Manter uma lista atualizada de contatos internos e externos (fornecedores, autoridades, seguradoras) que devem ser notificados; Estabelecer mecanismos primários e secundários de comunicação (*e-mail*, telefone, *chat* seguro).

Tais requisitos devem se materializar na elaboração de um Plano de Resposta a Incidentes, que deve ser formalmente documentado e aprovado pela organização. Para garantir sua eficácia contínua e a prontidão da equipe, esse plano deve ser objeto de revisão e atualização periódica, ocorrendo, no mínimo, anualmente ou sempre que houver mudanças significativas na estrutura organizacional ou no ambiente tecnológico.

Da análise das respostas ao item 1701 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 28, verificou-se que 33 (91,7%) das 36 organizações auditadas não designaram responsáveis e suplentes para gerenciarem sua resposta a incidentes de segurança e 27 (75%) delas não estabeleceram uma relação de contatos para notificação em casos da ocorrência de incidentes.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que estabeleçam formalmente e revisem periodicamente seu plano de resposta a incidentes, designando pessoal responsável e mantendo atualizadas as informações de contato.

Processo para relatar incidentes

A detecção rápida depende de uma força de trabalho capaz de detectar e reportar anomalias no ambiente organizacional.

A Medida 17.3 dos Controles CIS v8.1 exige o estabelecimento de um processo corporativo para o relato de incidentes. Alinhado a isso, o item 6.8 da ISO/IEC 27002:2022 requer que a organização forneça mecanismos claros para que as pessoas relatem eventos de segurança.

O *Incident Response Management Policy Template* do CIS destaca que este deve ser um processo distinto do Plano de Resposta técnica, focado na clareza e facilidade para o usuário final.

É fundamental que esse processo seja documentado, amplamente divulgado (*intranet*, *onboarding*) e que defina canais fáceis de usar (*e-mail* dedicado, formulário, telefone), bem como as informações mínimas que devem ser fornecidas e os prazos para o relato.

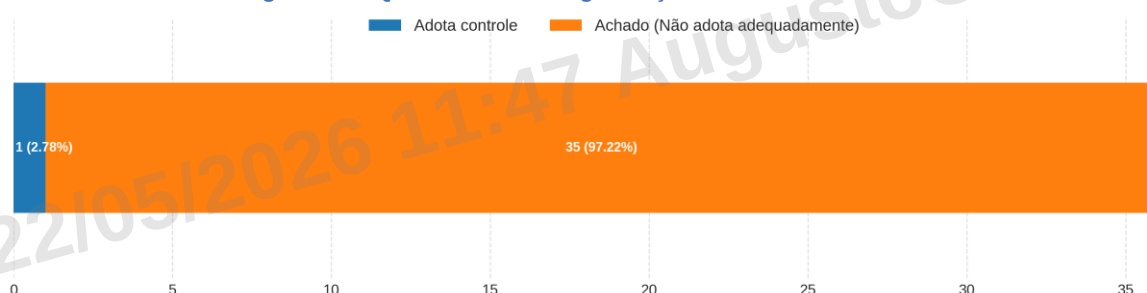
Da análise das respostas ao item 1702 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, conforme ilustrado na Figura 28, verificou-se que 34 (94,4%) das 36 organizações auditadas não possuem um processo estruturado e divulgado para que seus colaboradores relatem incidentes de segurança.

Diante disso, será sugerida proposta de recomendação às organizações nessa situação para que estabeleçam, mantenham e divulguem um processo corporativo para o relato de incidentes de segurança.

Conclusão

Com base nas situações avaliadas, verificou-se que 35 (97,2%) das 36 organizações auditadas não possuem medidas suficientes para responder minimamente a incidentes de segurança.

Figura 29 – Quantitativo de organizações contidas no achado 9



(Fonte: elaboração própria)

A ausência de uma estrutura formal de resposta a incidentes compromete a capacidade da organização de mitigar danos e cumprir suas obrigações legais de notificação e proteção de dados.

Dessa forma, será sugerida proposta de encaminhamento às organizações para que promovam a adequação de seus controles, alinhando-se às práticas da ABNT NBR ISO/IEC 27002:2022 e do CIS Controls v8.1.

4.3.9.4. Causas

- Não investigadas.

4.3.9.5. Efeitos

- Morosidade na resposta a incidentes de segurança;
- Tratamento inadequado de incidentes;
- Incapacidade de detecção de incidentes de segurança.

4.3.9.6. Propostas de Encaminhamento

Ressalta-se que as propostas de encaminhamento individualizadas para cada organização auditada constam no bojo dos relatórios individuais presentes nos conjuntos de anexos AN08 a AN43. Dessa forma, seguem as sugestões gerais propostas pela Equipe de Auditoria:

- **Comunicação com Recomendação** às organizações que não designaram responsáveis para gestão da resposta a incidentes para que adotem integralmente as medidas de segurança 17.1 (Designar pessoal para gerenciar o tratamento de incidentes) e 17.2 (Estabelecer e manter informações de contato para relato de incidentes de segurança) previstas nos Controles CIS v8.1, atentando-se, minimamente, em estabelecer, manter e revisar anualmente um plano de resposta a incidentes formalmente documentado e aprovado, que designe responsáveis (titular e suplente) para gerenciar o processo, defina as atribuições da equipe de gestão de incidentes e mantenha atualizadas as informações de contato das partes interessadas (internas e externas) a serem notificadas;
- **Comunicação com Recomendação** às organizações que não estabeleceram processo para comunicação de incidentes para que adotem integralmente a medida de segurança 17.3 (Estabelecer e manter um processo corporativo para o relato de incidentes) prevista nos Controles CIS v8.1, atentando-se, minimamente, em formalizar, divulgar e manter acessível um processo que instrua a força de trabalho sobre os canais oficiais, os prazos e as informações mínimas necessárias para o reporte de anomalias e incidentes de segurança.

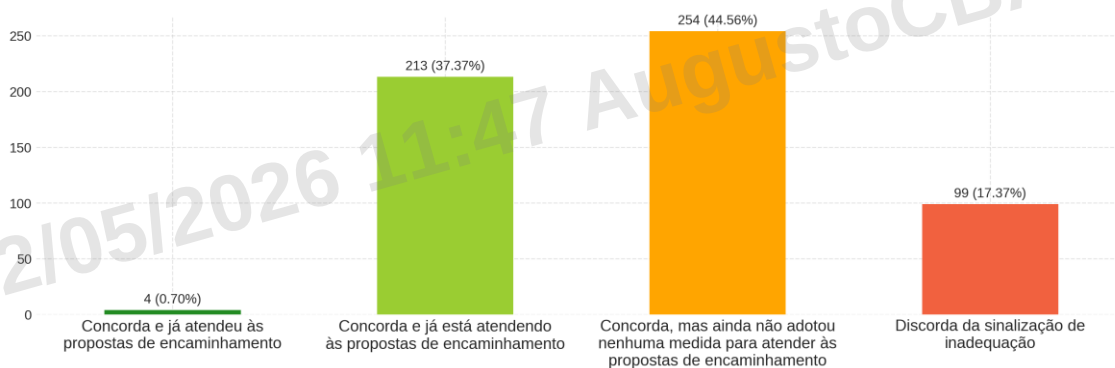
5. COMENTÁRIOS DO GESTOR E ANÁLISE DA EQUIPE

Visando fortalecer o caráter dialógico da fiscalização e assegurar o contraditório, foram encaminhados⁴⁶ relatórios individuais preliminares para cada organização auditada. Ao final do prazo, foram recebidas 27 respostas (77% dos 35 relatórios enviados). Considerando que o escopo da auditoria abrangeu a verificação de 29 situações inconformes distintas (agrupadas em 9 achados), o somatório das manifestações resultou em um universo de aproximadamente 570 avaliações individuais processadas pela Equipe.

Essa etapa permitiu o esclarecimento de pontos obscuros, a correção de informações imprecisas ou inconsistentes e o aperfeiçoamento das medidas propostas.

O panorama geral das respostas revela alta convergência entre o diagnóstico da auditoria e a visão dos gestores. Conforme ilustrado na Figura 30, em aproximadamente 82,6% dos casos, os auditados reconheceram as fragilidades apontadas.

Figura 30 – Cenário das manifestações dos gestores quanto às situações encontradas apontadas no Relatório Individual Preliminar



(Fonte: elaboração própria)

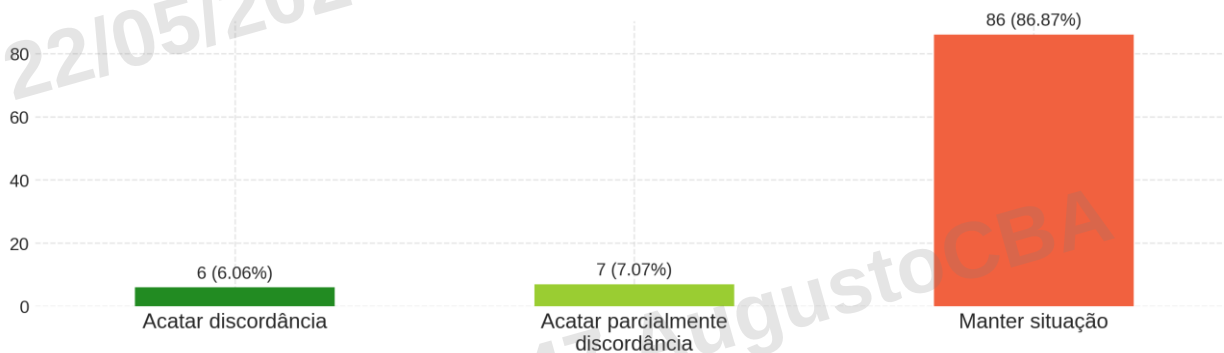
A predominância de concordâncias ratifica a materialidade dos achados, indicando que o levantamento reflete a realidade das organizações e que a atuação da auditoria já motivou o início do atendimento às propostas, demonstrando o benefício imediato do controle e evidenciando a oportunidade e a necessidade da atuação deste Tribunal para induzir melhorias.

No que tange às 99 sinalizações de discordância (17,4% do total), a Equipe empreendeu uma revisão técnica minuciosa. O procedimento consistiu no confronto entre as justificativas e evidências apresentadas nos comentários dos gestores e o conjunto probatório coletado durante a fase de execução.

O objetivo foi verificar se os argumentos trazidos eram suficientes para elidir a irregularidade ou justificar a situação encontrada. O resultado dessa reanálise encontra-se consolidado na Figura 31.

⁴⁶ Os relatórios individuais preliminares encontram-se presentes nos anexos individuais de cada auditado, AN08 a AN43.

Figura 31 – Resultado da análise técnica das discordâncias apresentadas



(Fonte: elaboração própria)

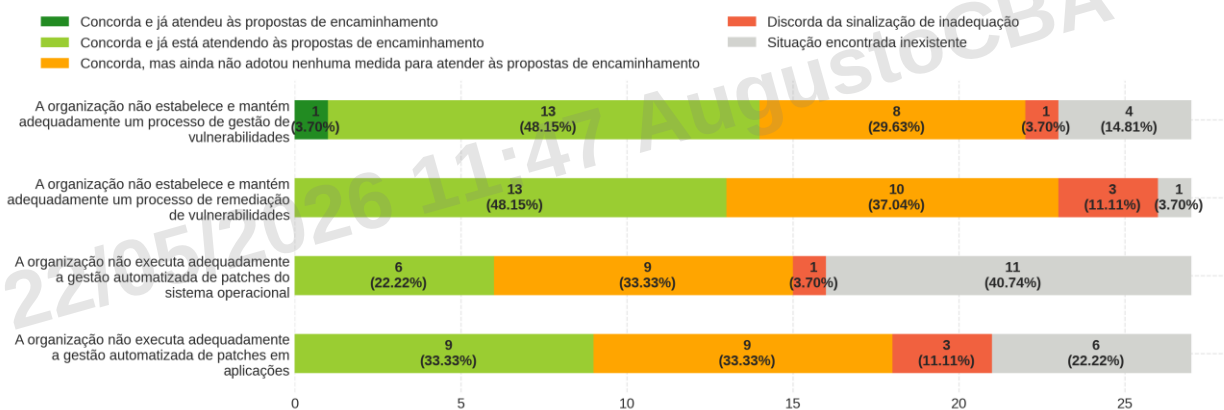
Apenas 13,13% das discordâncias foram acatadas (total ou parcialmente), ocorrendo nos casos em que foram apresentadas novas evidências que comprovavam a regularidade da situação ou a existência de controles compensatórios eficazes.

Nas subseções a seguir, apresenta-se uma visão detalhada da avaliação dos comentários dos gestores segregada por cada um dos achados de auditoria, apresentando os principais comentários e justificativas.

5.1. Achado 1 - Medidas básicas de segurança cibernética insuficientes na gestão de vulnerabilidades

Este achado trata da avaliação da maturidade das organizações quanto ao estabelecimento de processos formais para identificar, remediar e corrigir vulnerabilidades em seus ativos de TIC. A Figura 32 consolida as manifestações.

Figura 32 - Comentários dos gestores sobre as situações encontradas do Achado 1

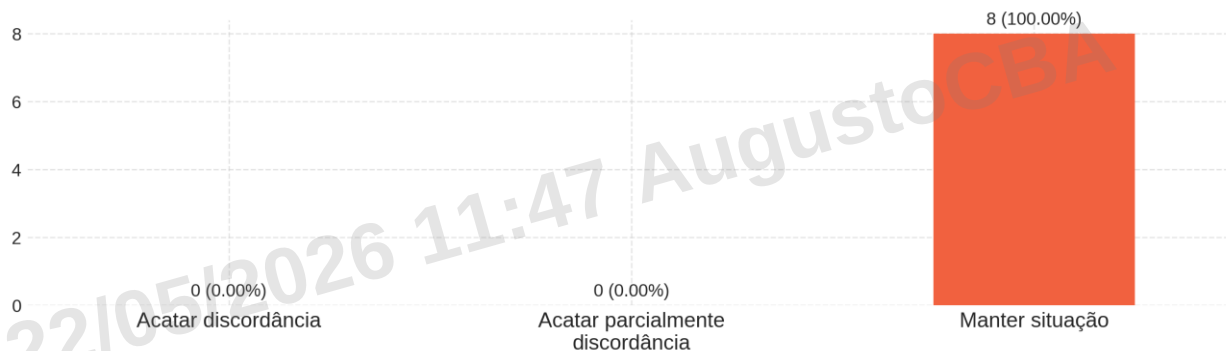


(Fonte: elaboração própria)

A maioria das organizações reconhece a fragilidade em seus processos de gestão de vulnerabilidades, citando limitações orçamentárias e sistemas legados como barreiras para a correção. Na análise das discordâncias (Figura 33), a equipe rejeitou 100% dos argumentos. Constatou-se que a mera existência de ferramentas (antivírus, *firewalls*) não substitui um

processo formal de gestão de vulnerabilidades com análise de risco e SLAs definidos. Ferramentas inadequadas para a finalidade, como repositórios de código, também foram citadas erroneamente como soluções de gestão de *patches*.

Figura 33 - Resultado da análise das discordâncias do Achado 1



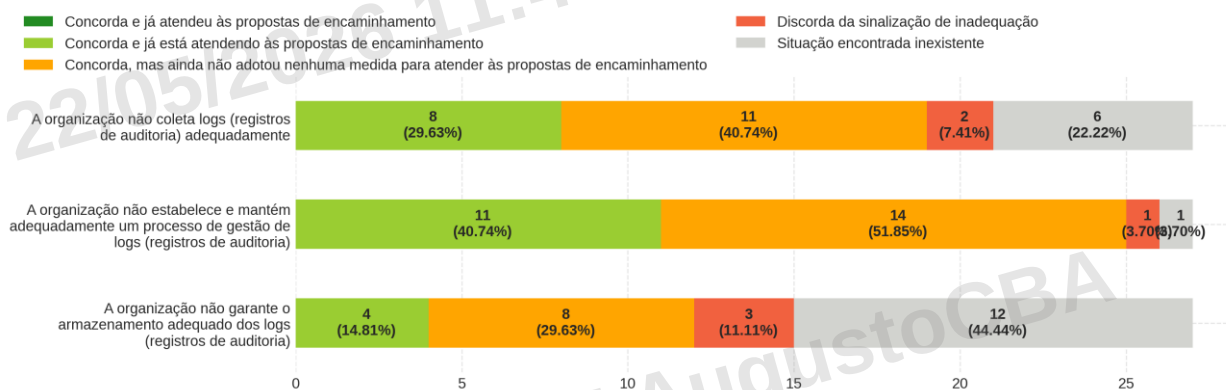
(Fonte: elaboração própria)

Conclui-se, portanto, pela manutenção integral dos apontamentos deste achado. Embora seja positivo que diversas organizações tenham informado o início de planos de ação para 2026, a contratação de consultorias para adequação à ISO 27001 e a busca por novas soluções de *Unified Endpoint Management* (UEM), a realidade atual permanece de alto risco. A ausência de formalização dos processos e a dependência de execuções manuais ou "empíricas" deixam a administração pública exposta a ameaças cibernéticas conhecidas.

5.2. Achado 2 - Medidas básicas de segurança cibernética insuficientes na gestão de registros de auditoria (*logs*)

Este achado trata da capacidade das organizações em gerar, gerenciar e armazenar registros de auditoria (*logs*), essenciais para a detecção de incidentes e a rastreabilidade de ações. A Figura 34 apresenta o panorama das respostas dos gestores.

Figura 34 - Comentários dos gestores sobre as situações encontradas do Achado 2

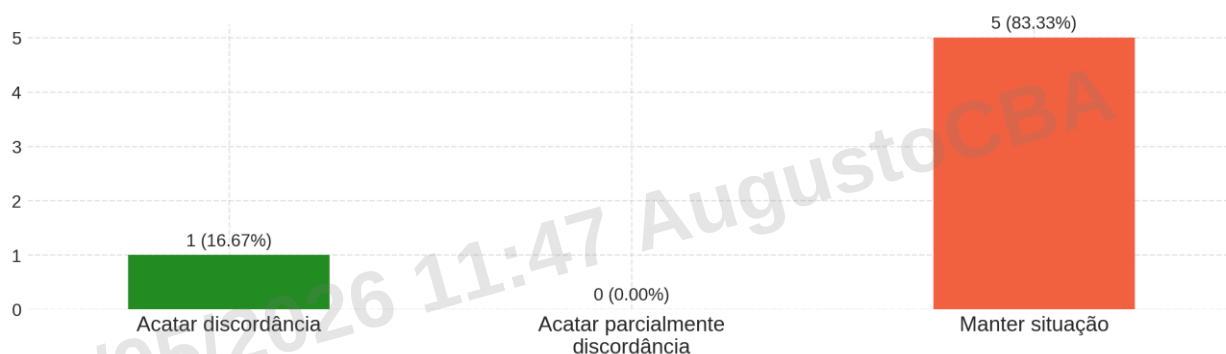


(Fonte: elaboração própria)

A elaboração do processo é o ponto mais crítico, com apenas 3,7% de conformidade entre os respondentes. A maioria classifica seus processos como empíricos. Já o armazenamento dos *logs* apresenta melhor cenário (44,4% de conformidade). Nas justificativas, algumas organizações demonstraram planos concretos para adoção de soluções SIEM (*Security Information and Event Management*) e sincronização NTP até 2026.

Quanto às discordâncias (Figura 35), a maioria (83,3%) foi rejeitada. Argumentos de que o *backup* substituiria a gestão de *logs* ou de que a responsabilidade seria integral do provedor de TIC foram refutados, pois a terceirização da infraestrutura não exime o proprietário dos dados de definir os requisitos de retenção e monitoramento. Houve um único acatamento, onde a organização comprovou tecnicamente a coleta centralizada de *logs* via ferramenta SIEM, apesar da falta de formalização do processo.

Figura 35 - Resultado da análise das discordâncias do Achado 2



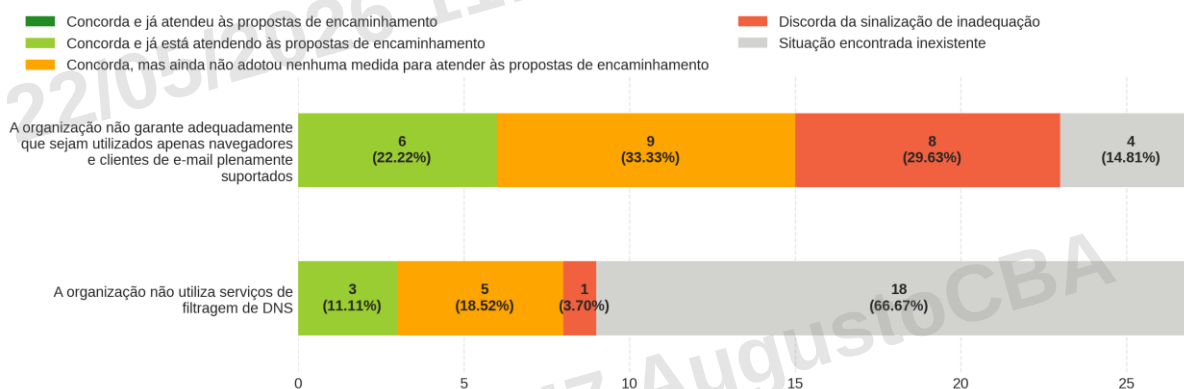
(Fonte: elaboração própria)

Diante do exposto, mantém-se a avaliação de alto risco para este domínio. A ausência generalizada de processos formais de gestão de *logs* impede que as organizações identifiquem ataques em tempo hábil e realizem investigações forenses adequadas. As recomendações do relatório final reforçam a necessidade urgente de formalizar políticas de *logging*, coletar eventos críticos e assegurar a proteção desses registros contra alterações não autorizadas.

5.3. Achado 3 - Medidas básicas de segurança cibernética insuficientes nas proteções de *e-mail* e navegador *web*

Este achado verificou a existência de controles para mitigar dois dos vetores de ataque mais comuns: a exploração de navegadores/clientes de *e-mail* desatualizados e o acesso a domínios maliciosos. A Figura 36 ilustra o posicionamento dos gestores.

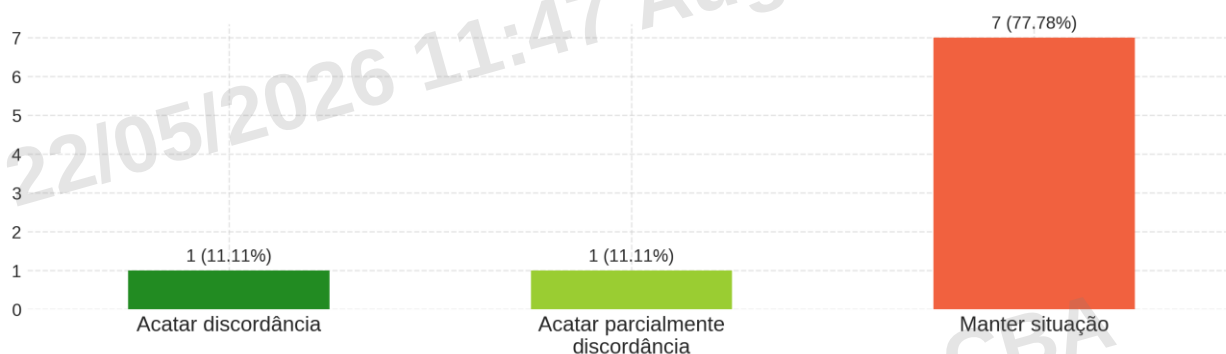
Figura 36 - Comentários dos gestores sobre as situações encontradas do Achado 3



(Fonte: elaboração própria)

Há uma disparidade clara: enquanto 66,7% das organizações respondentes possuem filtragem de DNS (conformidade), apenas 14,8% possuem controle adequado sobre navegadores e clientes de *e-mail*. Nessa situação houve uma alta discordância do apontamento realizado, motivando uma análise aprofundada pela equipe de auditoria. Nas discordâncias (Figura 37), 77,8% foram mantidas. A principal causa das situações foi a ausência de políticas formalizadas que sustentem as configurações técnicas alegadas.

Figura 37 - Resultado da análise das discordâncias do Achado 3



(Fonte: elaboração própria)

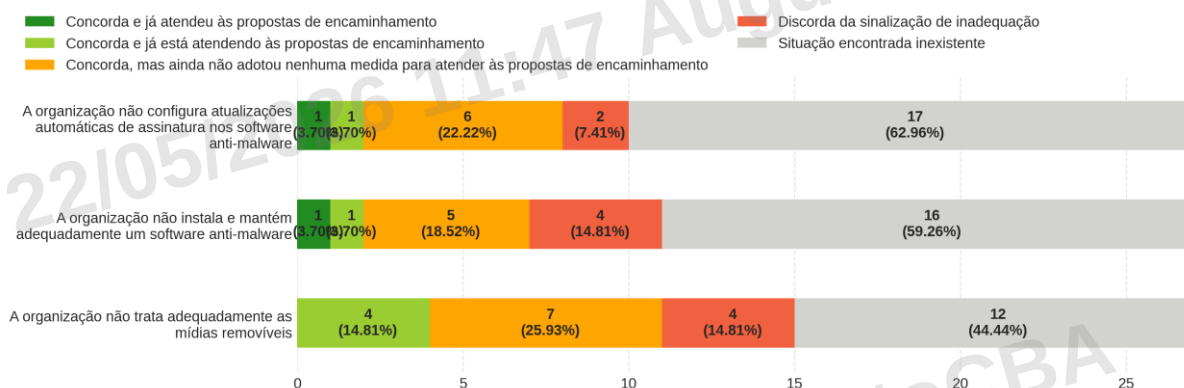
A revisão técnica das 9 contestações apresentadas resultou na manutenção da maioria dos apontamentos (77,8%), mas também reconheceu a validade de argumentos bem fundamentados. Houve acolhimento total em um caso em que a organização evidenciou inventário atualizado e restrição de privilégios administrativos via GPO. Em outro, houve acatamento parcial devido ao uso exclusivo de *webmail*, mitigando riscos de clientes de *e-mail* desatualizados.

Conclui-se que, embora as organizações tenham avançado na implementação de ferramentas de borda (como filtros de DNS), a gestão da superfície de ataque nos *endpoints* (navegadores e *e-mail*) carece de governança. A formalização de listas de *softwares* homologados e a implementação de bloqueios técnicos auditáveis são passos indispensáveis recomendados neste relatório para reduzir a exposição a ameaças.

5.4. Achado 4 – Medidas básicas de segurança cibernética insuficientes nas defesas contra malware

Este achado verifica a adoção de *softwares* de proteção contra códigos maliciosos (*anti-malware*), a configuração de suas atualizações automáticas e o controle de mídias removíveis (*pen drives*, HDs externos). A Figura 38 consolida a percepção dos gestores.

Figura 38 - Comentários dos gestores sobre as situações encontradas do Achado 4

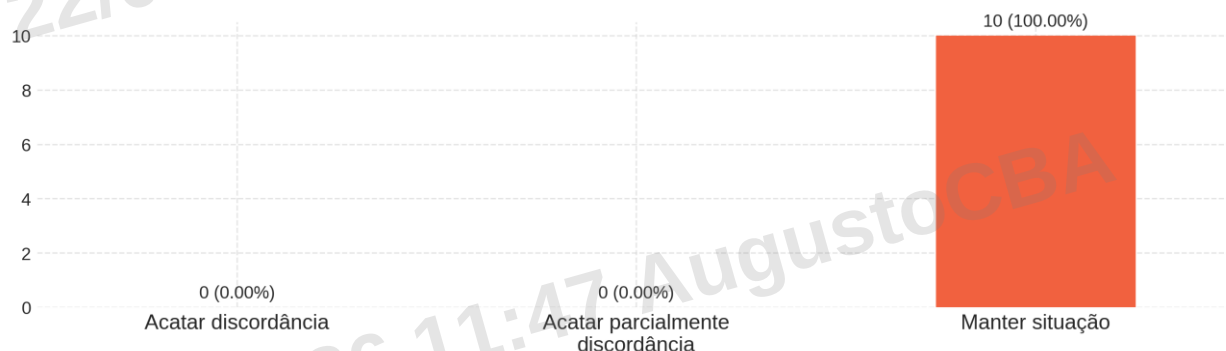


(Fonte: elaboração própria)

O cenário é majoritariamente positivo para a instalação de *anti-malware* (>60% de conformidade), mas frágil no tratamento de mídias removíveis (44,4%). Entre os que concordaram com os apontamentos, o comentário recorrente foi a obsolescência do parque (Windows 7) e a falta de recursos para adquirir soluções corporativas de *Endpoint Protection Platform* (EPP).

Todas as 10 discordâncias apresentadas foram rejeitadas (Figura 39). As contestações baseadas apenas na posse de ferramentas ou contratos de *outsourcing* não foram aceitas sem evidências de cobertura total (100% dos ativos) e gestão centralizada. Além disso, constatou-se confusão técnica: muitos alegaram que a varredura (*scan*) do antivírus substituiria a necessidade de desabilitar a execução automática (*autorun*) de mídias removíveis, o que não procede segundo as boas práticas.

Figura 39 - Resultado da análise das discordâncias do Achado 4



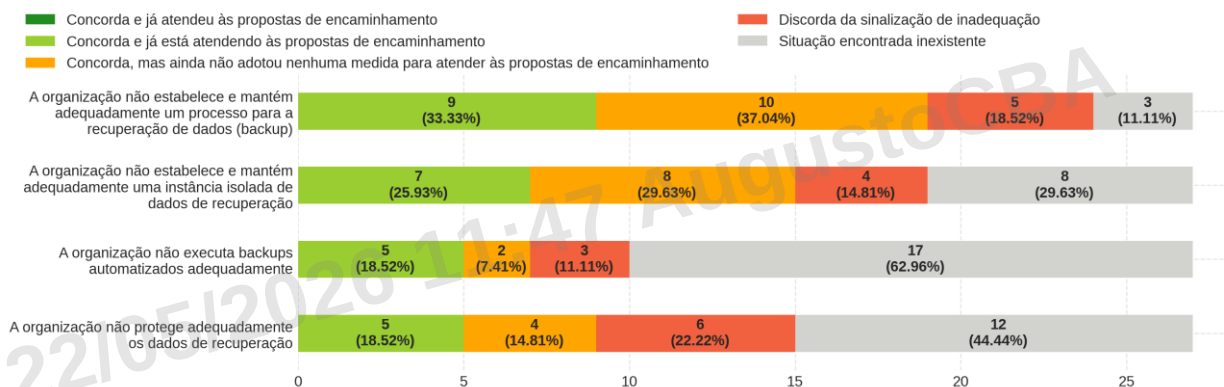
(Fonte: elaboração própria)

Conclui-se que a conformidade ao controle 10 do CIS Controls v8.1 exige não apenas a instalação do *software*, mas sua configuração segura, monitoramento contínuo e a capacidade de impedir alterações não autorizadas.

5.5. Achado 5 – Medidas básicas de segurança cibernética insuficientes no processo de recuperação de dados

Este achado avaliou a capacidade das organizações de recuperar seus dados (*backup*) em caso de incidentes, verificando a formalização do processo, a automação das rotinas, a proteção dos dados de recuperação (*backup*) e a existência de uma instância isolada de armazenamento. A Figura 40 apresenta a distribuição das respostas dos gestores.

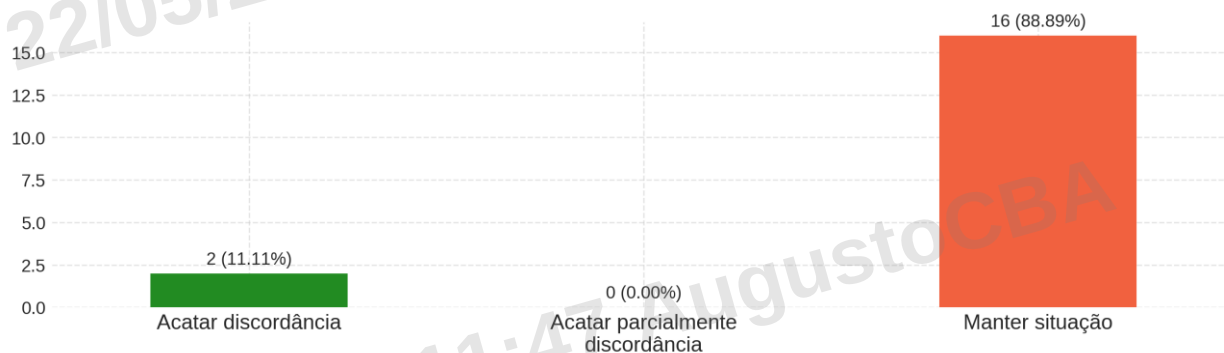
Figura 40 - Comentários dos gestores sobre as situações encontradas do Achado 5



(Fonte: elaboração própria)

Embora a execução de *backups* automatizados seja comum (63% de conformidade), a formalização de processos e a existência de instâncias isoladas ainda são deficientes. Destacam-se iniciativas de organizações que informaram processos de aquisição de *appliances* e *storages* dedicados para garantir a segregação e a imutabilidade dos dados, alinhando-se às recomendações para o exercício de 2026/2027.

Figura 41 - Resultado da análise das discordâncias do Achado 5



(Fonte: elaboração própria)

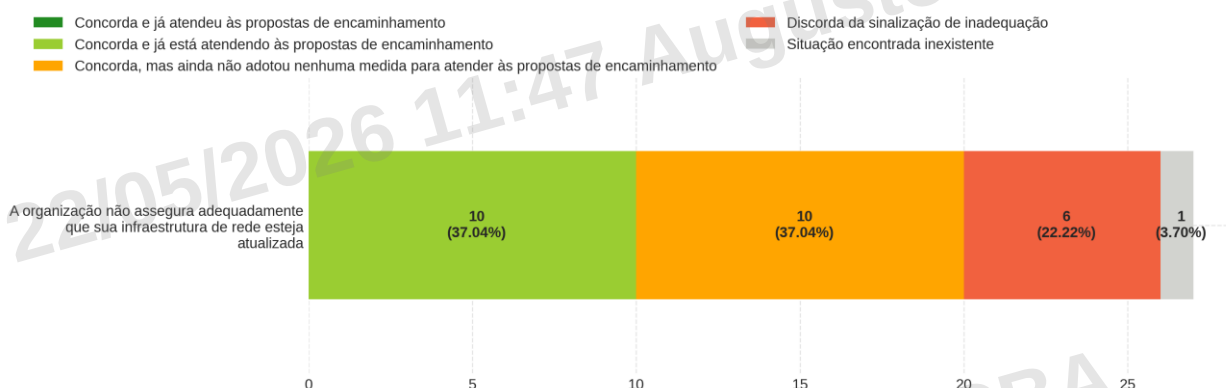
Nas discordâncias (Figura 41), a maioria foi mantida. A equipe reiterou que a terceirização da infraestrutura não transfere a responsabilidade pela governança (definição de RTO/RPO e testes). Alegações de uso de criptografia não foram aceitas como prova de isolamento da instância de *backup*.

Conclui-se pela manutenção das recomendações, enfatizando que a mera automação do *backup* não constitui um processo de recuperação resiliente. É imperativo que as organizações formalizem seus planos de recuperação, realizem testes práticos de restauração e implementem instâncias de armazenamento segregadas da rede de produção.

5.6. Achado 6 – Medidas básicas de segurança cibernética insuficientes na gestão da infraestrutura de rede

Este achado verificou se as organizações asseguram adequadamente que sua infraestrutura de rede (roteadores, *switches*, *firewalls*) esteja atualizada e segura. A Figura 42 apresenta o panorama das respostas obtidas.

Figura 42 - Comentários dos gestores sobre as situações encontradas do Achado 6

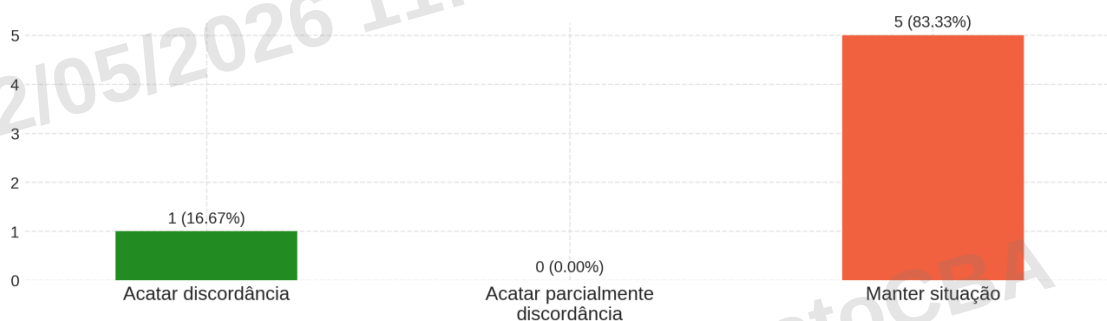


(Fonte: elaboração própria)

Cerca de 74% concordam com a fragilidade, citando obsolescência de equipamentos (*End-of-Life*) e falta de recursos. Dos que estão atendendo às propostas, foram mencionadas ações como o mapeamento da infraestrutura, expansão de *clusters* virtuais e uso de ferramentas de inventário como o GLPI para monitoramento.

Nas discordâncias (Figura 43), houve um acatamento onde a organização comprovou controle manual eficaz com histórico de versões. As demais (83,3%) foram mantidas, pois a preferência por processos manuais sem formalização ou a simples terceirização não garantem a segurança tempestiva da infraestrutura.

Figura 43 - Resultado da análise das discordâncias do Achado 6



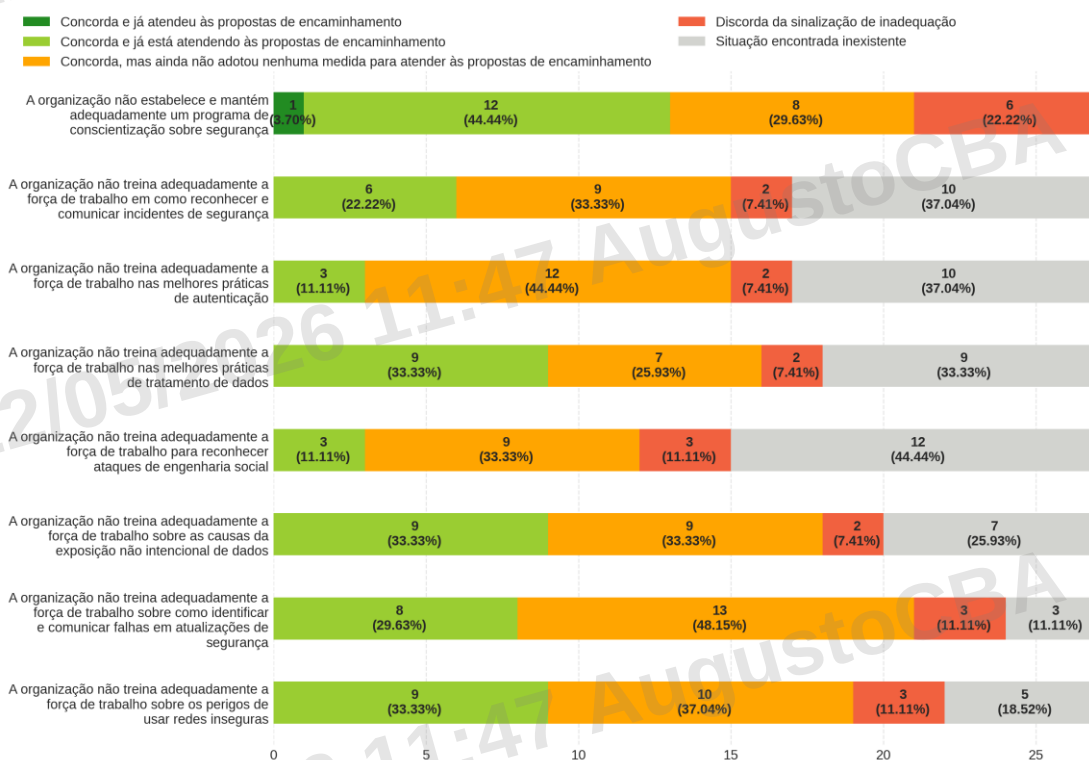
(Fonte: elaboração própria)

Conclui-se que o cenário de gestão de rede requer atenção prioritária. A coexistência de processos manuais não formalizados com parques tecnológicos obsoletos cria uma superfície de ataque considerável. As recomendações mantidas focam na formalização de procedimentos de gestão de *patches* para ativos de rede e na priorização da substituição de equipamentos que não recebem mais suporte de segurança dos fabricantes.

5.7. Achado 7 – Medidas básicas de segurança cibernética insuficientes no programa de conscientização e treinamento em segurança

Este achado avaliou a maturidade das organizações quanto ao estabelecimento de um programa de conscientização e o treinamento em temas críticos, como incidentes, autenticação, engenharia social e tratamento de dados. A Figura 44 apresenta o panorama das respostas.

Figura 44 - Comentários dos gestores sobre as situações encontradas do Achado 7

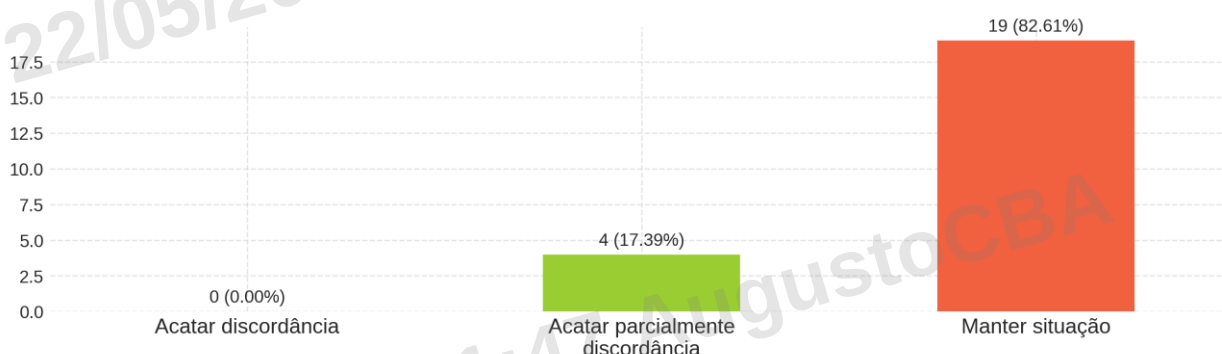


(Fonte: elaboração própria)

A predominância de concordâncias confirma a carência de treinamento formal. Foram citadas a dependência de dotação orçamentária ou o planejamento de ações futuras para os exercícios de 2026/2027. Nas discordâncias (Figura 45), 82,6% foram mantidas. Rejeitou-se a tese de ferramentas automatizadas de correção como medida mitigatória à necessidade de treinamento. Houve acatamento parcial em quatro casos nos quais as organizações comprovaram a realização de simulações de *phishing* e a existência de materiais educativos, embora sem cobertura universal ou integração com *onboarding*.

Destaca-se positivamente a iniciativa de órgãos que já utilizam cursos da Escola Virtual de Governo (EV.G) como medida mitigadora inicial.

Figura 45 - Resultado da análise das discordâncias do Achado 7



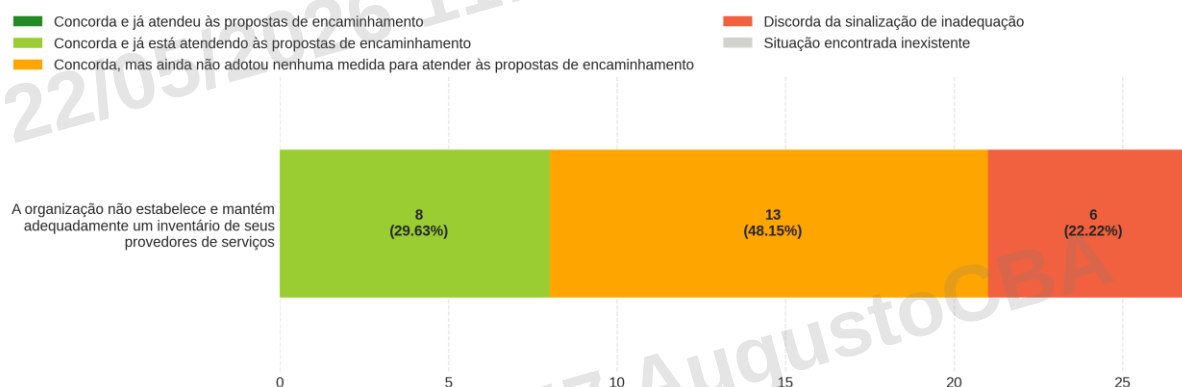
(Fonte: elaboração própria)

Conclui-se pela manutenção das recomendações, com ênfase na estruturação de programas formais. Não basta realizar palestras esporádicas; é imperativo instituir trilhas de aprendizado recorrentes, obrigatórias para novos colaboradores antes da concessão de acessos lógicos, e medir a eficácia dessas ações através de testes práticos (como simulações de *phishing*), garantindo que a cultura de segurança permeie toda a organização.

5.8. Achado 8 – Medidas básicas de segurança cibernética insuficientes na gestão de provedores de serviços

Este achado verificou se as organizações estabelecem e mantêm um inventário adequado de seus provedores de serviços, controle essencial para a gestão de riscos de terceiros. A Figura 46 ilustra o posicionamento dos gestores.

Figura 46 - Comentários dos gestores sobre as situações encontradas do Achado 8



(Fonte: elaboração própria)

Com 77,7% de concordância, a maioria admite a falha. Nas discordâncias (Figura 47), 5 de 6 casos foram mantidos, pois a existência de contratos administrativos não equivale a um inventário de provedores com atributos como classificação de risco. Um caso foi acatado mediante apresentação de planilha de inventário completa com os atributos exigidos.

Figura 47 - Resultado da análise das discordâncias do Achado 8



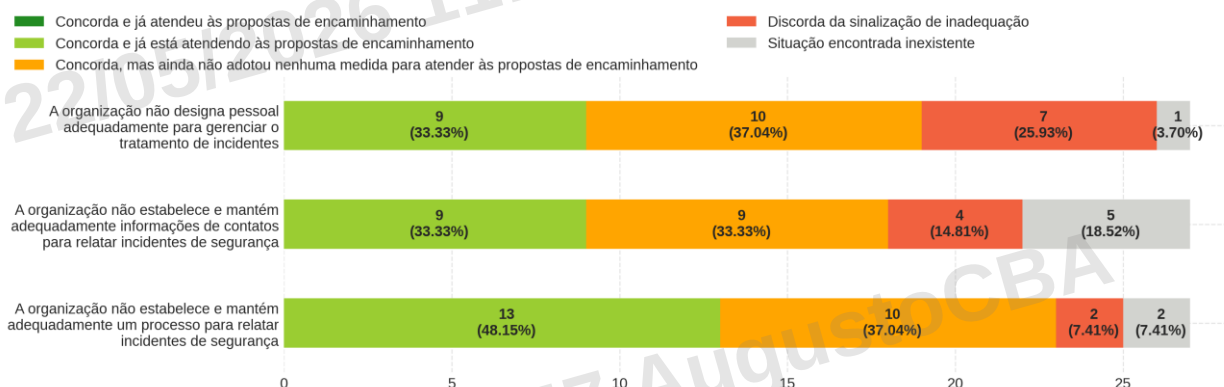
(Fonte: elaboração própria)

Conclui-se pela manutenção do achado para a maioria dos jurisdicionados. A gestão de fornecedores é um vetor crítico de ataques modernos. As recomendações do relatório final reforçam a necessidade de transformar listas administrativas em inventários de segurança vivos, que permitam à organização identificar rapidamente quais terceiros detêm dados críticos e como contatá-los em caso de incidentes cibernéticos.

5.9. Achado 9 – Medidas básicas de segurança cibernética insuficientes na gestão de respostas a incidentes

Este achado avaliou a preparação das organizações para lidar com crises cibernéticas, verificando a designação de responsáveis e contatos de emergência e o estabelecimento de processos de relato de incidentes. A Figura 48 apresenta o panorama das respostas.

Figura 48 - Comentários dos gestores sobre as situações encontradas do Achado 9

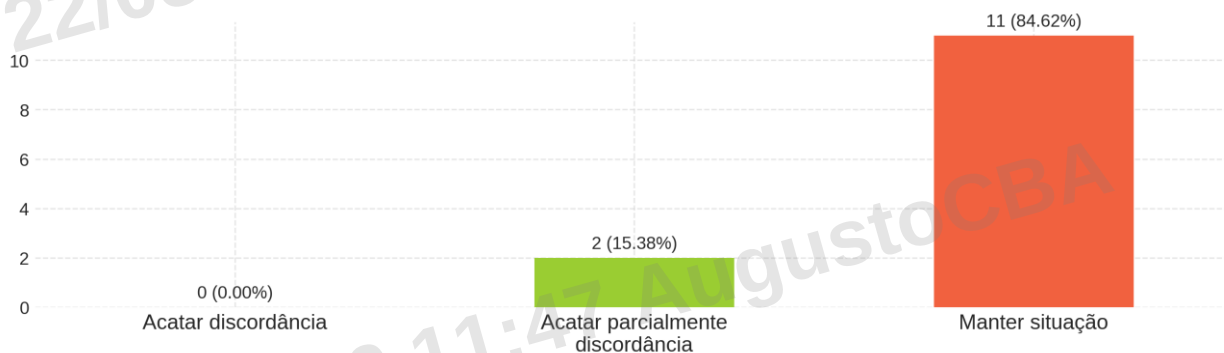


(Fonte: elaboração própria)

A capacidade de resposta é incipiente (37% de concordância sem ação). Algumas organizações comprovaram melhorias, como a publicação de planos de resposta e a criação de um canal específico de comunicação, alinhando-se integralmente às boas práticas recomendadas.

Nas discordâncias (Figura 49), houve dois acatamentos parciais onde a designação de responsáveis foi comprovada, mas faltavam suplentes ou documentação operacional. Outras contestações foram rejeitadas, esclarecendo-se que a figura do Encarregado de Dados (LGPD) não supre a necessidade de uma equipe de resposta a incidentes de segurança da informação (CSIRT).

Figura 49 - Resultado da análise das discordâncias do Achado 9



(Fonte: elaboração própria)

Conclui-se que, embora haja avanços pontuais na nomeação de responsáveis ("nomes no papel"), a operacionalização da resposta a incidentes ainda é frágil. A maioria das organizações carece de *playbooks* (procedimentos operacionais) testados, de redundância de pessoal (suplentes) e de canais de comunicação de emergência que cubram todo o espectro de ameaças cibernéticas, e não apenas vazamentos de dados pessoais.

5.10. Avaliação dos gestores sobre a fiscalização

Como parte do processo de melhoria contínua do controle externo, foi solicitado aos gestores que avaliassem a qualidade e a condução da fiscalização. Os resultados demonstram uma ampla aprovação da metodologia adotada. Houve unanimidade quanto à clareza do escopo e ao profissionalismo da equipe de auditoria. A relevância do trabalho foi reconhecida pela quase totalidade dos gestores, que destacaram o valor agregado à segurança do setor e demandaram fortemente (77%) por capacitação e materiais orientativos, reforçando um caráter pedagógico do controle externo.

Figura 50 - Avaliação dos gestores quanto à qualidade e condução da fiscalização



(Fonte: elaboração própria)

Apesar dos resultados positivos (vide Figura 50), foram apontadas oportunidades de melhoria, principalmente quanto à exiguidade dos prazos para resposta e envio de evidências (objeto de 5 discordâncias). Também foram registradas observações sobre a necessidade de calibrar as exigências à realidade estrutural de órgãos menores e de maior clareza na solicitação de evidências técnicas específicas. Tais *feedbacks* serão incorporados ao planejamento de futuras fiscalizações, visando aprimorar o equilíbrio entre rigor técnico e viabilidade operacional.

6. CONSIDERAÇÕES FINAIS

A presente fiscalização verificou a adoção de controles e medidas de segurança alinhadas às boas práticas de segurança da informação pelos órgãos e entidades da Administração Pública do Estado do Rio de Janeiro, tendo como referência as normas ABNT NBR ISO/IEC 27001:2022 e 27002:2022, bem como as medidas básicas do Grupo de Implementação 1 (IG1) dos Controles 7 a 17 do *framework* Controles CIS versão 8.1.

Adicionalmente, foram analisados os planos de ação oriundos dos encaminhamentos da primeira fase da auditoria (Processo TCE-RJ nº 105.895-5/2024).

A adoção das medidas supracitadas é imprescindível para o cumprimento de normativos estaduais — como a Instrução Normativa PRODERJ/PRE nº 07/2025 e a Resolução TJ/OE nº 28/2022 — e para assegurar a proteção das informações custodiadas e dos dados pessoais, em conformidade com os incisos II e III, do art. 6º, da Lei de Acesso à Informação (LAI) e com os arts. 46 e 47 da Lei Geral de Proteção de Dados Pessoais (LGPD).

Em linhas gerais, a fiscalização aponta um cenário de maturidade incipiente. Verificou-se que 23 dos 36 jurisdicionados (63,9%) se encontram nos níveis de maturidade "Inexpressivo" ou "Inicial". Dentre as fragilidades identificadas nesta segunda fase, destacam-se a ausência de programas de conscientização em segurança, a baixa adoção de processos de remediação de vulnerabilidades, a gestão insuficiente de *logs* de auditoria e de inventários de provedores de serviço.

Quanto à avaliação dos planos de ação da primeira fase, a análise indicou um descompasso entre a capacidade de planejamento e a efetiva execução, a existência de uma janela de vulnerabilidades e a existência de planos que não atendem aos encaminhamentos propostos.

A etapa de comentários do gestor revelou alta convergência (82,6%) entre o diagnóstico da auditoria e a visão dos gestores. Os principais entraves citados à adoção das medidas foram restrições orçamentárias, escassez de pessoal e obsolescência tecnológica.

Para alcançar mais efetividade à fiscalização e acelerar o processo de adequação às práticas de segurança, a Equipe, exercendo seu papel orientativo, desenvolveu relatórios individualizados aos jurisdicionados, com encaminhamentos específicos às suas situações. Nesse sentido, foram propostas até 27 medidas específicas por auditado, desenhadas para mitigar as lacunas identificadas em cada realidade organizacional.

Dessa forma, contata-se o caráter indutor e orientador desta auditoria que, em conjunto com as determinações e recomendações comunicadas, ensejará uma melhora significativa na higiene cibernética e no fortalecimento da governança de segurança das organizações fiscalizadas.

7. PROPOSTA DE ENCAMINHAMENTO

CONSIDERANDO o pleno atendimento ao objetivo proposto pela auditoria, qual seja, o de verificar a adoção de controles e sua aderência às boas práticas de segurança da informação;

CONSIDERANDO que o foco do presente trabalho é induzir os jurisdicionados a uma maior adoção de medidas de higiene cibernética;

CONSIDERANDO que a higiene cibernética não se esgota nos controles abordados nessa auditoria, e que deve ser encarada como um processo de melhoria contínua, norteado por um sistema de segurança da informação centrado na gestão de riscos e no uso de boas práticas consolidadas;

CONSIDERANDO o caráter orientador e dialógico do presente trabalho, assim como o alinhamento à diretriz de incremento de eficiência e efetividade na gestão administrativa;

CONSIDERANDO as informações sensíveis à segurança de informação dos jurisdicionados presentes nos autos do processo;

CONSIDERANDO que os resultados decorrentes das ações previstas no Plano de Ação poderão ser objeto de avaliação futura por meio de Monitoramento, considerando os preceitos definidos na Resolução TCE-RJ nº 422/2023;

CONSIDERANDO que a metodologia empregada neste trabalho não abordou as causas específicas dos problemas identificados e que as recomendações focam na implementação de medidas estabelecidas pelos controles CIS e pelas normas ABNT, conforme observado durante o processo de auditoria.

Sugere-se ao Egrégio Plenário desta Corte de Contas a adoção das seguintes propostas:

1. **MANUTENÇÃO DO CARÁTER SIGILOSO** do presente processo, classificando-o como informação reservada, nos termos do inciso I, § 3º, art. 8º c/c incisos IV, V, VIII do art. 9º da Resolução TCE-RJ nº 433/2023, pelo caráter sensível das análises e informações que constam no relatório e seus anexos;
2. **COMUNICAÇÃO COM DETERMINAÇÃO** à Secretaria Geral da Presidência, por meio da sua coordenadoria competente, para que adote as medidas necessárias para **CLASSIFICAR COMO INFORMAÇÃO PÚBLICA** o anexo AN07 nos termos do art. 4º c/c § 1º, do art. 8º, da Resolução TCE-RJ nº 433/2023, para conferir informação ao público geral sobre a natureza da fiscalização empreendida;
3. **COMUNICAÇÃO COM DETERMINAÇÃO** à Secretaria Geral da Presidência, por meio da sua coordenadoria competente, para que encaminhe, em anexo aos ofícios de comunicação da decisão, cópia do Acórdão proferido e dos respectivos relatórios individuais (AN08 a AN43) a cada organização auditada, de forma a garantir a ciência efetiva aos jurisdicionados

acerca da decisão proferida por esta Corte, **tendo em vista o caráter sigiloso do processo, em que cada jurisdicionado só deve ter acesso ao seu relatório individual;**

4. **COMUNICAÇÃO COM DETERMINAÇÃO** aos órgãos fiscalizados nesta auditoria, nos termos do artigo 15, inciso I, do Regimento Interno deste Tribunal, para que **promovam a atualização do plano de ação estruturado na fase anterior da fiscalização (Fiscalização nº 49/2024 acostada sob o Processo TCE-RJ nº 105.895-5/24), no prazo máximo de 60 (sessenta) dias a contar da ciência da decisão plenária**, formalizando essa atualização do plano em processo administrativo eletrônico para futuro monitoramento, e incorporando as medidas necessárias para que cumpram as **DETERMINAÇÕES** e considerem a adoção das **RECOMENDAÇÕES** dispostas nos seus respectivos **RELATÓRIOS INDIVIDUAIS anexos (AN08 a AN43)**, alertando-os de que o não atendimento injustificado os sujeita às sanções previstas no art. 63 da Lei Complementar Estadual n.º 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.

Plano de Ação				
Determinação / Recomendação	O que fazer	Como fazer	Quem vai fazer	Quando fazer

5. **COMUNICAÇÃO às Unidades de Controle Interno dos órgãos jurisdicionados desta fiscalização**, nos termos do artigo 15, inciso I, do Regimento Interno deste Tribunal, para que tomem **CIÊNCIA** do inteiro teor do presente Relatório de Auditoria Governamental, bem como do respectivo Relatório Individual de seu órgão (AN08 a AN43), e acompanhem a elaboração e execução do plano de ação desenvolvido a fim de assegurar seu efetivo cumprimento;
6. **ARQUIVAMENTO** do presente processo.

O presente relatório foi objeto de supervisão conforme as disposições da Portaria SGE nº 05/2019, no Manual de Auditoria Governamental do TCE-RJ, aprovado pela Resolução nº 373, de 16/06/21 e em material armazenado nos assentamentos internos desta Coordenadoria, estando, portanto, **APROVADO** por esta supervisão e encaminhado à sua apreciação para adoção das medidas cabíveis.

CAD-TI, 18/12/2025

AUGUSTO CÉSAR BENVENUTO DE ALMEIDA Matrícula 02/004823	Auditor de Controle Externo	Equipe de Auditoria
JOÃO PAULO DE FREITAS RAMIREZ Matrícula 02/004820	Auditor de Controle Externo	Equipe de Auditoria
BRUNO MATTOS SOUZA DE SOUZA MELO Matrícula 02/004258	Auditor de Controle Externo	Supervisor

DE ACORDO.

À **SUB-CIDADANIA**, em prosseguimento.

CAD-TI, 18/12/2025

ALBERTO DE FONTES TAVARES NETO
Coordenador-Geral
Matrícula 02/004260

Assinado Digitalmente por: ALBERTO DE FONTES
TAVARES NETO
 Data: 2025.12.19 11:59:02 -03:00
Razão: Processo 107097-1/2025
Local: TCERJ

Assinado Digitalmente por: JOAO PAULO DE
FREITAS RAMIREZ
 Data: 2025.12.18 23:41:34 -03:00
Razão: Processo 107097-1/2025
Local: TCERJ

Assinado Digitalmente por: BRUNO MATTOS
SOUZA DE SOUZA MELO
 Data: 2025.12.18 21:07:51 -03:00
Razão: Processo 107097-1/2025
Local: TCERJ

Assinado Digitalmente por: AUGUSTO CESAR
BENVENUTO DE ALMEIDA
 Data: 2025.12.18 20:56:25 -03:00
Razão: Processo 107097-1/2025
Local: TCERJ